

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC CẦN THƠ
TRƯỜNG CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG**



**BÁO CÁO
NIÊN LUẬN NGÀNH MẠNG MÁY TÍNH VÀ
TRUYỀN THÔNG**

**ĐỀ TÀI
TÌM HIỂU VÀ THỰC NGHIỆM CÁC DẠNG
TẤN CÔNG VÀ PHÒNG THỦ WEBSITE**

**Phân hệ
GIA CỐ HỆ THỐNG**

Sinh viên thực hiện :Võ Ngọc Anh Thư

Mã số sinh viên: B2004756

Khóa: 46

Năm học 2024 - 2025

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC CẦN THƠ
TRƯỜNG CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG**



**BÁO CÁO
NIÊN LUẬN NGÀNH MẠNG MÁY TÍNH VÀ
TRUYỀN THÔNG**

**ĐỀ TÀI
TÌM HIỂU VÀ THỰC NGHIỆM CÁC DẠNG TẤN
CÔNG VÀ PHÒNG THỦ WEBSITE**

**Phân hệ
GIA CỐ HỆ THỐNG**

Giảng viên hướng dẫn

Th.s Bùi Minh Quân

Sinh viên thực hiện

Võ Ngọc Anh Thư B2004756

Năm học 2024 - 2025

LỜI CẢM ƠN

Đầu tiên, bài báo cáo này là một tiền đề góp phần to lớn vào các bước tiếp theo của luận văn tốt nghiệp. Và để hoàn thành bài báo cáo này một cách thuận lợi, thành công, tất cả đều nhờ vào giảng viên bộ môn - thầy Bùi Minh Quân. Chúng em xin gửi lời cảm ơn sâu sắc đến thầy vì đã định hướng, hướng dẫn, truyền đạt những kiến thức quý báu cho chúng em trong suốt thời gian học tập vừa qua, giúp chúng em tiếp thu thêm nhiều kiến thức bổ ích, sáng tạo hơn trong lĩnh vực học tập. Đặc biệt, chúng em vô cùng biết ơn vì sự hỗ trợ hết mình của thầy trong quá trình làm bài báo cáo này.

Tuy nhiên, do vốn kiến thức còn nhiều hạn chế, dù chúng em đã cố hết sức nhưng bài báo cáo chắc chắn sẽ khó tránh khỏi nhiều thiếu sót, chưa hoàn thiện và nhiều chỗ còn chưa chính xác. Kính mong thầy xem xét và góp ý để bài báo cáo của chúng em được hoàn thiện hơn.

Chúng em xin chân thành cảm ơn.

LỜI CAM ĐOAN

Em xin cam đoan niên luận “Tìm hiểu và thực nghiệm các dạng tấn công và phòng thủ website” được hoàn thành hoàn toàn dựa trên kết quả nghiên cứu của em dưới sự hướng dẫn của Thầy Bùi Minh Quân và chưa từng xuất hiện trên các công trình khoa học nào.

ĐÁNH GIÁ CỦA GIẢNG VIÊN

This image shows a full page of primary-ruled paper. It consists of multiple sets of three horizontal dashed lines, which are commonly used in elementary school writing practice to guide letter height and placement. The lines are evenly spaced across the entire page, providing a template for handwriting practice. There is no text or other markings on the paper.

MỤC LỤC

PHẦN GIỚI THIỆU	10
1.1 Đặt vấn đề	10
1.2 Lịch sử giải quyết vấn đề	10
1.3 Mục tiêu đề tài.....	10
1.4 Đối tượng và phạm vi nghiên cứu.....	11
1.5 Nội dung nghiên cứu.....	11
1.5.1 Quy trình nghiên cứu	11
1.5.2 Công nghệ sử dụng	11
PHẦN NỘI DUNG.....	12
CHƯƠNG 1: TỔNG QUAN VỀ THỰC NGHIỆM	12
1.Mô tả thực nghiệm	12
2.Các dữ liệu mô phỏng thực nghiệm	12
3.Các khái niệm sử dụng trong đề tài.....	12
3.1 Khái niệm về VMware.....	12
3.2 Khái niệm về Kali Linux.....	13
3.3 Khái niệm về phpAdmin.....	13
3.4 Khái niệm về Infinity	13
CHƯƠNG 2: THIẾT KẾ VÀ CÀI ĐẶT MÔI TRƯỜNG	13
1.Thiết kế kiến trúc hệ thống thực nghiệm	13
2.Thiết kế quy trình thực nghiệm.....	13
3.Tiến hành mô tả thực nghiệm.....	13
3.1 Mô tả thực nghiệm scan website	14

3.2 Mô tả thực nghiệm tấn công.....	18
3.2.1 Tấn công DDOS.....	18
3.2.2 Thực nghiệm tấn công MITM	30
3.3.3 Mô tả thực nghiệm SQL và hash mật khẩu	36
3.3.4 Thực nghiệm tấn công XSS	40
CHƯƠNG 3: QUY TRÌNH GIA CỐ HỆ THỐNG.....	45
GIA CỐ WEBSITE VỚI NHIỀU CÁCH THỨC	45
1.Sử dụng chứng chỉ SSL.....	45
2.Gia cố tấn công XSS	59
3.Gia cố lỗ hổng SQL Injection	61
CHƯƠNG 4: THỰC HIỆN CÁC CÔNG CỤ THEO DÕI, LƯU TRỮ CÁC TÁC VỤ ĐƯỢC THỰC THI.....	65
1. Sử dụng công cụ fail2ban.....	65
2.Sử dụng công cụ Snort	68
KẾT QUẢ ĐẠT ĐƯỢC	75
TÀI LIỆU THAM KHẢO	78

DANH MỤC HÌNH

Hình 1: Công cụ ZAP có sẵn trên kali linux	14
Hình 2: Giao diện của công cụ.....	15
Hình 3: Copy đường dẫn trang website và chèn vào công cụ.....	16
Hình 4: Quá trình quét	17
Hình 5: Kết quả quét xong	17
Hình 6: Tải ứng dụng hỗ trợ	19
Hình 7: Tải ứng dụng hỗ trợ	19
Hình 8 Chạy ứng dụng hỗ trợ	20
Hình 9: Tải ứng dụng LOIC để thực hiện tấn công DDos	20
Hình 10: Tải về và giải nén ứng dụng.....	21
Hình 11: Cấp quyền cho ứng dụng để ứng dụng thực thi	21
Hình 12: Chạy ứng dụng hỗ trợ	21
Hình 13: Địa chỉ IP của máy tấn công 1	22
Hình 14: Địa chỉ IP của máy tấn công 2	22
Hình 15: IP của máy tính (ubuntu) bị tấn công.....	23
Hình 16: Thông số máy Client chưa bị tấn công	23
Hình 17: Thực thi chương trình	24
Hình 18: Giao diện công cụ LOIC	24
Hình 19: Giao diện dành cho máy tính (kali linux) tấn công.....	25
Hình 20: Thông số máy Server 1 khi tấn công dùng wireshark để xem quá trình.....	26
Hình 21: Thông số Server 2 khi tấn công dùng wireshark để xem quá trình.....	26
Hình 22: Wireshark bắt các gói tin tấn công.....	27
Hình 23: Lock on với địa chỉ của web đã đăng ký.....	28
Hình 24: Wireshark từ máy kali tấn công HTTP	28
Hình 25: Thông số máy Client khi bị tấn công.....	29

Hình 26: Công cụ wireshark	30
Hình 27: Công cụ wireshark thực hiện tác vụ.....	31
Hình 28: : Tiến hành ghi log file của trang website muốn truy cập.....	31
Hình 29: Trang website được tạo dùng cho mục đích thử nghiệm	32
Hình 30: Dữ liệu được lưu vào CSDL	32
Hình 31: Tiến hành đăng nhập dữ liệu đã đăng ký	33
Hình 32: Đăng nhập thành công	33
Hình 33: Log file ghi nhận lịch sử truy cập	34
Hình 34: Đưa log file đã tạo phía trên vào đường dẫn.....	34
Hình 35: Công cụ wireshark khi nhận log file	35
Hình 36: Dùng công cụ tìm kiếm để tìm log file cần tìm	35
Hình 37: Bắt được gói tin khi đăng ký và gói tin đăng nhập cũng như vậy.....	36
Hình 38: Dùng câu lệnh truy xuất để dò tìm.....	37
Hình 39: Phát hiện trong CSDL có người trùng tên với dữ liệu dò tìm.....	37
Hình 40: Dùng câu lệnh truy xuất để dò tìm khác	38
Hình 41: Truy xuất được vào trang quản lý của admin	39
Hình 42: CSDL các user	40
Hình 43: Quá trình hash password của người dùng bất kì	40
Hình 44: Kết quả phát hiện XSS	41
Hình 45: Sử dụng câu lệnh để tấn công	42
Hình 46: Câu lệnh script được thực thi	42
Hình 47: Dùng công cụ BurpSuite để kiểm tra XSS.....	43
Hình 48: Login user có trong CSDL	44
Hình 49: Kết quả sau khi bị tấn công.....	45
Hình 50: Tạo chứng chỉ SSL.....	46
Hình 51: Điền tên domain vào	47

Hình 52: Chọn option free cho chứng chỉ SSL	47
Hình 53: Yêu cầu đã được tạo.....	48
Hình 54: Lưu các thông tin SSL trong lúc tạo	48
Hình 55: Điền các thông tin SSL trong lúc tạo vào các mục	49
Hình 56: Chọn Add và nhận được kết quả như trên	49
Hình 57: Trạng thái ssl trong lúc đợi chứng chỉ cấp.....	49
Hình 58: Trạng thái web đang đợi cấp.....	50
Hình 59: Các khóa chứng chỉ được cấp	50
Hình 60: Điền vào khóa riêng được cấp	51
Hình 61: Điền vào chứng chỉ được cấp.....	51
Hình 62: Trạng thái website sau khi được cấp chứng chỉ SSL	51
Hình 63: Thông tin chứng chỉ SSL	52
Hình 64: Trang web đã được cấp chứng chỉ và hiện là kết nối an toàn	52
Hình 65: :Chọn kiểm tra tên miền.....	53
Hình 66: Kiểm tra phiên bản nikto.....	53
Hình 67: Dùng lệnh kiểm tra trang website	54
Hình 68: Dùng lệnh kiểm tra ssl của trang website	55
Hình 69: Lệnh lưu trữ các trạng thái	56
Hình 70: File kết quả được ghi	57
Hình 71: Nội dung file kết quả.....	57
Hình 72: Dùng logfile ghi nhận lại lịch sử ứng dụng.....	58
Hình 73: Tiến hành đăng nhập và đăng ký	59
Hình 74: Các dữ liệu không còn bị bắt trên đường truyền.....	59
Hình 75: Thực thi chèn lệnh script.....	60
Hình 76: Kết quả sau khi chèn đoạn script	61
Hình 77: Dữ liệu các cột trong CSDL chưa được kiểm tra.....	61

Hình 78: Kiểm tra các cột trong CSDL.....	62
Hình 79: Hacker sẽ không thể chèn các câu lệnh vào để tấn công trang web.....	62
Hình 80: Hacker sẽ không thể chèn các câu lệnh vào để dò tìm người dùng trang web.....	63
Hình 81: Trước khi gia cố.....	64
Hình 82: Sau khi gia cố.....	64
Hình 83: Tải công cụ fail2ban	66
Hình 84: Copy file	66
Hình 85: Địa chỉ ip của máy ubuntu	67
Hình 86: Cấu hình.....	67
Hình 87: Thay đổi cấu hình	68
Hình 88: Kết quả thu được.....	68
Hình 89: Tải công cụ Snort trên ubuntu.....	69
Hình 90: Xóa các công cụ không sử dụng	69
Hình 91: Download công cụ gói tin Snort	69
Hình 92: Tiến hành giải nén.....	70
Hình 93: Dùng lệnh copy	70
Hình 94: Liệt kê các tệp đã được copy	70
Hình 95: Khởi động ứng dụng	71
Hình 96: ứng dụng hoạt động	71
Hình 97: Đặt các rules theo quy định của admin	71
Hình 98: Tạo rules cho ứng dụng.....	71
Hình 99: Thông tin cấu hình và card mạng.....	73
Hình 100: Thay đổi các thông tin để ứng dụng.....	73
Hình 101: Khởi động ứng dụng	73
Hình 102: Ping thông điệp từ máy kali	74
Hình 103: Thông điệp máy ubuntu nhận được và ghi nhận.....	74

PHẦN GIỚI THIỆU

1.1 Đặt vấn đề

Trong bối cảnh ngày càng tăng việc sử dụng mạng internet và các hệ thống mạng nội bộ, bảo mật thông tin trở thành một vấn đề cần thiết. Do đó, việc bảo trì, bảo vệ các hệ thống website dần trở thành mối quan tâm của các nhà phát triển, các doanh nghiệp và cả khách hàng.

Để có thể nhận biết được các dấu hiệu của một cuộc tấn công và các tác hại của việc bị tấn công, xâm nhập bất hợp pháp đối với người dùng. Việc thực hiện chủ đề thực nghiệm, tìm hiểu về các dạng tấn công website này sẽ cần thiết có việc đảm bảo tính hiệu quả, an toàn, uy tín của các doanh nghiệp đối với khách hàng và an toàn cho cả thời đại số ngày nay.

1.2 Lịch sử giải quyết vấn đề

Lịch sử giải quyết vấn đề tấn công website có thể được chia thành các giai đoạn chính dựa trên sự phát triển của công nghệ và phương pháp bảo mật. Dưới đây là một số giai đoạn quan trọng:

- Trước những năm 2000: Trong giai đoạn này, internet và các trang web còn mới mẻ, và nhiều lỗ hổng bảo mật được phát hiện và khai thác một cách dễ dàng. Công nghệ bảo mật cơ bản như các tường lửa và mã hóa đã được sử dụng, nhưng vẫn chưa đủ hiệu quả để ngăn chặn các cuộc tấn công phức tạp.
- Phát triển của OWASP (Open Web Application Security Project): OWASP được thành lập vào năm 2001 và đã giới thiệu danh sách các lỗ hổng bảo mật phổ biến nhất trong các ứng dụng web. Các nhà phát triển và chuyên gia bảo mật bắt đầu áp dụng các phương pháp phòng thủ dựa trên các hướng dẫn của OWASP
- Xuất hiện của các công cụ tấn công tự động hóa: Các hacker đã sử dụng các công cụ tự động để tìm kiếm và khai thác lỗ hổng bảo mật trên website. Ngành công nghiệp bảo mật phải đối mặt với việc phát triển các công cụ tấn công ngày càng phức tạp.

1.3 Mục tiêu đề tài

Nghiên cứu này nhằm mục đích cung cấp các kiến thức về những dấu hiệu của việc tấn công website và hiểu rõ tác nhân, quy trình gây ra các tác hại từ việc bị tấn công website đồng thời có thể khuyến khích tìm hiểu thêm, áp dụng, phát triển các cách gia cố, theo dõi, nhận biết các cách gia cố các lỗ hổng.

1.4 Đối tượng và phạm vi nghiên cứu

Đối tượng của tấn công website có thể đa dạng và phức tạp, phụ thuộc vào mục tiêu cụ thể của việc nghiên cứu hoặc cuộc tấn công. Có các dạng website sau:

- Website công ty: Các công ty thương mại điện tử, doanh nghiệp hoặc tổ chức có website đại diện hoặc thương mại điện tử là đối tượng chính của cuộc tấn công. Nghiên cứu có thể tập trung vào việc phát hiện và khai thác lỗ hổng bảo mật, xâm nhập vào hệ thống, hoặc đánh cắp thông tin quan trọng.
- Website chính phủ và tổ chức phi lợi nhuận: Các tổ chức chính phủ hoặc phi lợi nhuận thường chứa nhiều thông tin nhạy cảm và là mục tiêu của các cuộc tấn công từ các nhóm tin tặc hoặc quốc gia. Nghiên cứu có thể tập trung vào việc phát hiện và ngăn chặn các cuộc tấn công mạng này.
- Website cá nhân và blog: Các trang web cá nhân, blog hoặc diễn đàn cũng có thể là đối tượng của cuộc tấn công. Nghiên cứu có thể liên quan đến bảo vệ thông tin cá nhân, ngăn chặn spam hoặc tấn công từ bot.

Phạm vi nghiên cứu của tấn công website có thể bao gồm các lĩnh vực sau:

- Phát hiện và khai thác lỗ hổng bảo mật.
- Tìm hiểu các công cụ tấn công và tiến hành các dạng tấn công.
- Tìm hiểu các công cụ phòng thủ và tiến hành gia cố.
- Tìm hiểu các công cụ theo dõi, giám sát hệ thống.

1.5 Nội dung nghiên cứu

1.5.1 Quy trình nghiên cứu

- Dùng công cụ tạo máy ảo VMWare tạo ra 2-3 máy ảo để thực hiện các quá trình.
- Tải các công cụ hỗ trợ cho việc quét (scan) website.
- Thực thi tấn công các lỗi được phát hiện sau khi quét.
- Xem, đánh giá các thông báo, thông số của việc bị tấn công và tiến hành gia cố hệ thống sau tấn công.

1.5.2 Công nghệ sử dụng

Một số công nghệ mà chúng em sử dụng cho hệ thống như: VMWare, Kali-linux,...

PHẦN NỘI DUNG

CHƯƠNG 1: TỔNG QUAN VỀ THỰC NGHIỆM

1. Mô tả thực nghiệm

Thực nghiệm được thực hiện trên hệ thống ảo được tạo ra dựa trên phương pháp dùng VMWare. Trong từng dạng tấn công hoặc phòng thủ sẽ sử dụng số lượng các máy ảo tùy theo nhu cầu của thực nghiệm.

1. Tấn công DDOS

Ddos là dạng tấn công được thực hiện trên nhiều máy cùng lúc tấn công vào một máy nào đó và cuộc tấn công diễn ra trên diện rộng.

Đối với dạng tấn công này sẽ thực nghiệm trên 2 máy kali-linux và 1 máy ubuntu.

2. Tấn công SQL, XSS

Tấn công SQL là dạng tấn công lợi dụng lỗ hổng từ các truy xuất các dữ liệu từ CSDL và đánh cắp thông tin người dùng.

Đối với dạng tấn công này thực nghiệm trên 1 máy kali-linux.

3. Tấn công MITM

Là dạng tấn công sử dụng các công cụ để bắt các gói tin truyền đi trên đường truyền và lợi dụng các thông tin đó để thực hiện các hành vi phi pháp.

Đối với dạng tấn công này thực nghiệm trên 1 máy kali-linux.

2. Các dữ liệu mô phỏng thực nghiệm

Tạo ra trang đăng nhập và cơ sở dữ liệu người dùng (users) để quản lý người dùng và đồng thời tiến hành các thử nghiệm các dạng tấn công và gia cố trên đó nhằm thể hiện rõ các quy trình cũng như các bước thực hiện.

3. Các khái niệm sử dụng trong đề tài

3.1 Khái niệm về VMware

VMware là môi trường cho phép tạo ra các giải pháp ảo hóa cho các hệ thống máy chủ và hạ tầng máy tính, cho phép một máy chủ vật lý có thể chạy nhiều hệ điều hành và ứng dụng đồng thời thông qua việc tạo ra các máy ảo.

3.2 Khái niệm về Kali Linux

Kali Linux là một hệ điều hành được sử dụng nhiều trong lĩnh vực bảo mật, bởi cả những hacker tìm cách xâm nhập hệ thống và những chuyên gia về bảo mật muốn bảo vệ các tài nguyên thông tin. Kali Linux cung cấp rất nhiều công cụ cho phép nhiều ứng dụng cũng như công cụ có những tác vụ liên quan đến bảo mật và thử nghiệm tấn công website.

3.3 Khái niệm về phpAdmin

PhpMyAdmin là phần mềm mã nguồn mở được viết bằng ngôn ngữ PHP giúp quản trị cơ sở dữ liệu MySQL thông qua giao diện web.

3.4 Khái niệm về Infinity

Infinity Free là một dịch vụ cung cấp deploy web miễn phí đồng thời với nền tảng có cung cấp chứng chỉ SSL free.

CHƯƠNG 2: THIẾT KẾ VÀ CÀI ĐẶT MÔI TRƯỜNG

1.Thiết kế kiến trúc hệ thống thực nghiệm

Tự tạo 1 trang website đơn giản tiến hành deploy lên các trang host free để có thể tiến hành scan website nhằm phát hiện các lỗ hổng để có thể thực hiện các tấn công và gia cố phía sau.

2.Thiết kế quy trình thực nghiệm

- Scan website tiến hành tìm ra lỗ hổng để tấn công demo
- Thực hiện các tấn công
- Tìm các phương pháp phòng thủ cho website

3.Tiến hành mô tả thực nghiệm

Quy trình tiến hành thực nghiệm

1. Tiến hành scan website
2. Thực nghiệm các dạng tấn công
3. Tiến hành gia cố hệ thống
4. Thêm các công cụ theo dõi, giám sát hệ thống

3.1 Mô tả thực nghiệm quét (scan) website

Khái niệm:

Đây là một trong cách thức để kiểm tra bảo mật được xem là một hoạt động vô cùng quan trọng nhằm đảm bảo tính an toàn cho website trong quá trình vận hành và sử dụng. Đây là một trong những việc cần thiết giúp doanh nghiệp xây dựng hệ thống an ninh mạng vững chắc để tránh khỏi các rủi ro và thiệt hại khi hacker tấn công.

Mục đích:

Kiểm tra bảo mật website còn trở nên quan trọng bởi những lý do sau đây:

- Xác định được các lỗ hổng trong hệ thống và các vi phạm bảo mật tiềm ẩn từ trang web.
- Phân tích và đo lường trạng thái các lỗ hổng tiềm ẩn của hệ thống.
- Phát hiện mọi rủi ro bảo mật có thể có trong hệ thống.
- Giúp các nhà phát triển website khắc phục và loại bỏ các vấn đề bảo mật thông qua việc mã hóa.

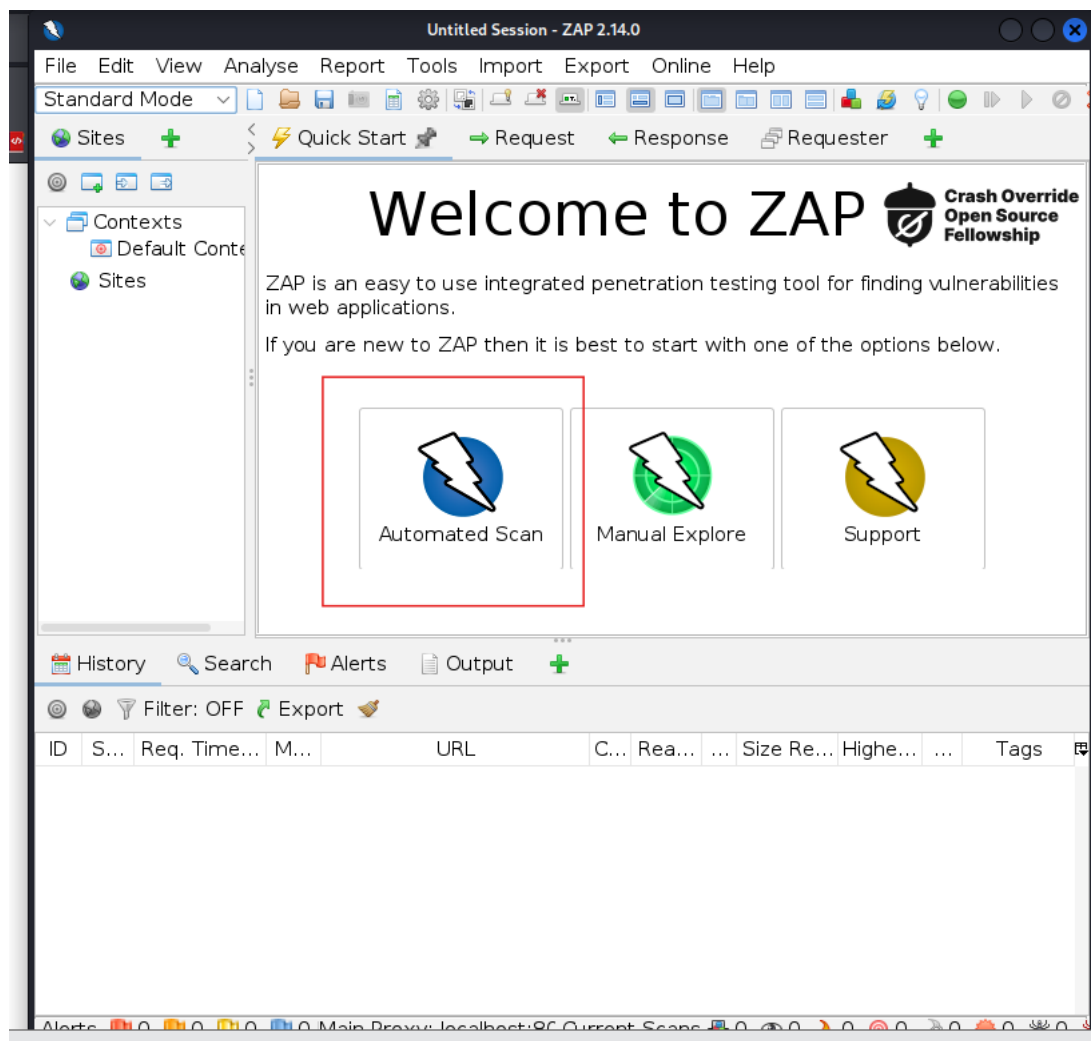
Quá trình mô phỏng thực nghiệm quét (scan) website với công cụ hỗ trợ ZAP

Dùng công cụ hỗ trợ là ZAP (có sẵn trên hệ điều hành kali-linux)

Tải công cụ hỗ trợ và tiến hành với quyền root

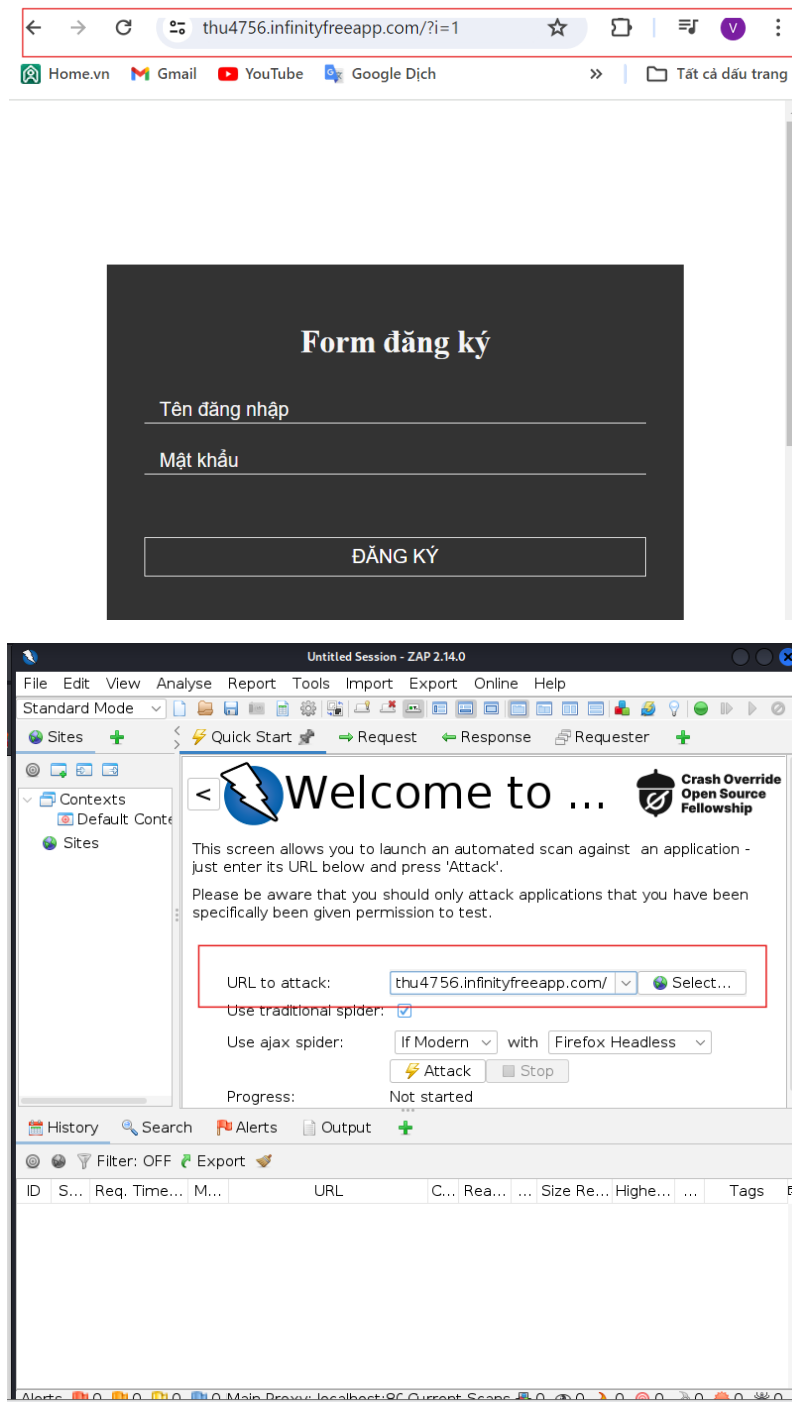


Hình 1: Công cụ ZAP có sẵn trên kali linux



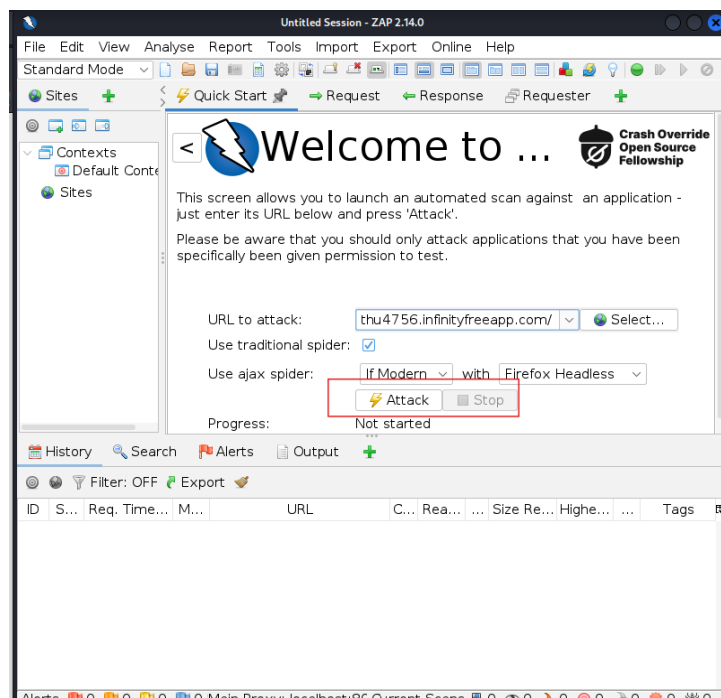
Hình 2: Giao diện của công cụ

Chọn Automated Scan để thực hiện tiến trình quét nhanh website.

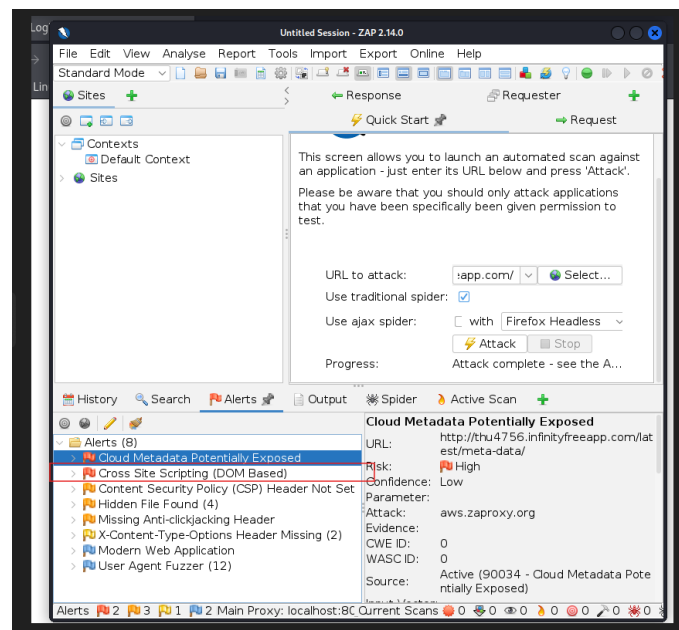


Hình 3: Copy đường dẫn trang website và chèn vào công cụ

Copy đường dẫn (URL) của website muốn quét (scan) dán vào URL to attack và tiến hành chọn Attack để thực thi tiến trình quét để kiểm tra.



Hình 4: Quá trình quét



Hình 5: Kết quả quét xong

☐	Sửa	Chép	Xóa bỏ	13	vv	c4055e3a20b6b3af3d10590ea446ef6c
☐	Sửa	Chép	Xóa bỏ	14	tt	acc9105df5383111407fd5b41255e23
☐	Sửa	Chép	Xóa bỏ	15	qq	099b3b060154898840f0ebdfb46ec78f
☐	Sửa	Chép	Xóa bỏ	16	#javascript.alert(5397)	f5a7b32e29177417d14da8f133cfd0f
☐	Sửa	Chép	Xóa bỏ	17	?name=abc<img src=random.gif	b7a52f9690afde68bddcf6bf741fd7f

☐ Theo dõi bảng ☐ Lưu mục đã chọn ☐ Sửa ☐ Chép ☐ Xóa bỏ ☐ Xuất

Hình 6: Hình CSDL sau khi bị quét

Kết quả thu được sau khi scan

Phát hiện lỗi XSS (Cross site scripting), lỗi dữ liệu đám mây có khả năng bị lộ thường xảy ra khi thông tin metadata của các máy ảo (VMs) hoặc các dịch vụ điện toán đám mây khác có thể bị tiết lộ (Cloud Metadata Potentially Exposed), bên cạnh đó cơ sở dữ liệu (csdl) cũng được thêm các dòng dữ liệu mới trong quá trình quét.

3.2 Mô tả thực nghiệm tấn công

3.2.1 Tấn công DDOS

Khái niệm:

- Về cơ bản, DDOS được viết tắt từ Distributed Denial of Service, tấn công DDoS là nỗ lực làm sập một dịch vụ trực tuyến bằng cách làm tràn ngập nó với traffic từ nhiều nguồn.
- Cụ thể, đối tượng tấn công DDoS không chỉ đơn thuần là đang sử dụng máy tính của mình để tấn công, mà cũng có thể dùng máy tính của người khác để sử dụng để tấn công. Những kẻ tấn công này, sẽ lợi dụng quyền kiểm soát máy tính của người dùng gửi một số lượng lớn dữ liệu đến một website hay số lượng gói tin rác đến một địa chỉ email nào đó.

Mục đích:

- Trong quá trình sử dụng, mạng của bạn hay mạng của hệ thống bị chậm bất thường khi truy cập vào website hay không mở được các ứng dụng hiện hành dù mạng internet vẫn đang ổn định.
- Không thể truy cập vào một trang của Website.
- Nhận được nhiều thư rác trong tài khoản một cách bất thường.

Mô phỏng thực nghiệm tấn công DDoS với số lượng tập tin nhỏ.

- Do có sự hạn chế về các công cụ vật lý nên thực nghiệm chỉ có thể dùng 2 máy (kali-linux) để tấn công do đó có thể xem tấn công Ddos (được xem nhưng tấn công ddos với quy mô nhỏ) và công cụ này vẫn có thể tấn công Ddos trên nhiều máy.
- Dùng công cụ hỗ trợ Low Orbit Ion Cannon (LOIC) và tạo thêm 1 Client (Ubuntu) và sử dụng công cụ hỗ trợ Wireshark để có thể bắt các gói tin để có thể quan sát.

Khái niệm:

Wireshark là một ứng dụng dùng để bắt (capture), phân tích và xác định các vấn đề liên quan đến network như: bắt gói tin, xem kết nối, hoặc các truy cập bất thường.

Mục đích:

Cụ thể, sử dụng wireshark có thể capture các gói tin (package) trong thời gian thực (real time), lưu trữ chúng lại và phân tích chúng offline. Ngoài ra, nó cũng bao gồm các filter, color coding và nhiều tính năng khác, cho phép người dùng tìm hiểu sâu hơn về lưu lượng mạng cũng như inspect (kiểm tra) các packets.

Quy trình thực hiện

1. Tải công cụ LOIC để thực hiện tấn công
2. Nhập địa chỉ IP muốn tấn công
3. Chọn phương thức, cổng, số lượng gói tin muốn tấn công
4. Tiến hành tấn công
5. Dùng wireshark bên máy tấn công để tiến hành theo dõi quá trình tấn công
6. Dùng wireshark bên máy nạn nhân để xem diễn biến tấn công
7. Xem các thông số bên máy nạn nhân khi bị tấn công
8. Tiến hành phân tích các thông số

Tiến hành thực nghiệm

Tải công cụ hỗ trợ và tiến hành với quyền root

\$ apt-get install mono-complete



Hình 6: Tải ứng dụng hỗ trợ

Chọn y

```
0 upgraded, 1/5 newly installed, 0 to remove and 5/ not upgraded.
Need to get 72.5 MB of archives.
After this operation, 254 MB of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:1 http://kali.download/kali kali-rolling/main amd64 binfmt-support amd64 2.2.2-2 [64.0 kB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 mono-runtime-common amd64 6.8.0.105+dfsg-3.3 [1,171 kB]
Get:3 http://http.kali.org/kali kali-rolling/main amd64 libmono-corlib4.5-dll all 6.8.0.105+dfsg-3.3 [1,253 kB]
Get:4 http://http.kali.org/kali kali-rolling/main amd64 libmono-system-core4.0-cil all 6.8.0.105+dfsg-3.3 [305 kB]
```

Hình 7: Tải ứng dụng hỗ trợ

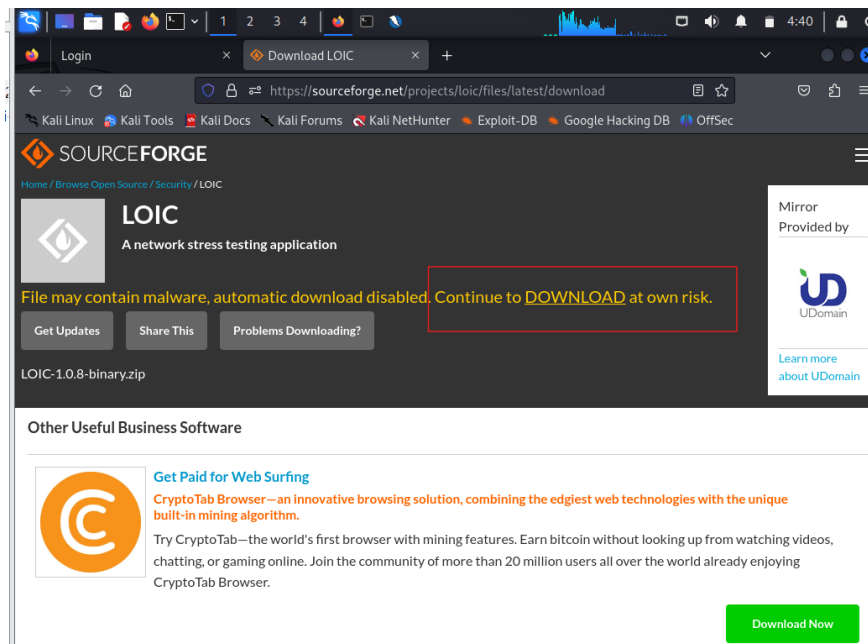
Tải thêm nload : \$ apt-get install nload



Hình 8 Chạy ứng dụng hỗ trợ

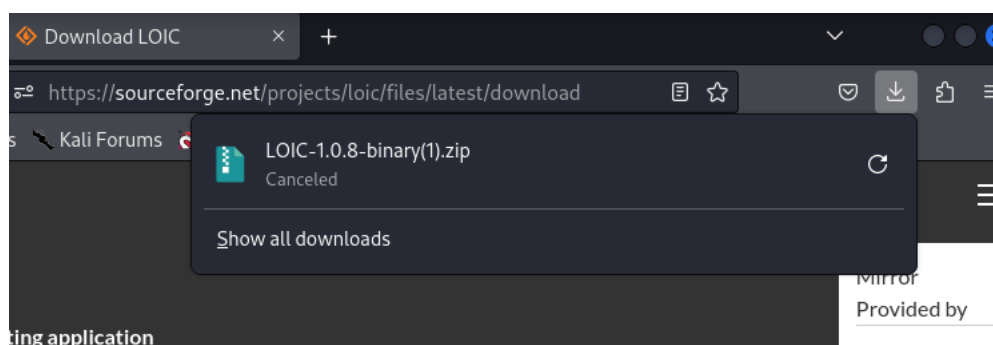
Tải LOIC từ trình duyệt với đường link :

<https://sourceforge.net/projects/loic/files/latest/download>



Hình 9: Tải ứng dụng LOIC để thực hiện tấn công DDos

Đi vào thư mục chứa file này và tiến hành giải nén



```
(root@kali)-[/home/kali]
# cd Downloads

(root@kali)-[/home/kali/Downloads]
# ls
code_1.85.2-1705561292_amd64.deb      Hoic      LOIC-1.0.8-binary.zip  usr
code-1.85.2-1705561377.el7.x86_64.rpm  Hoic.rar  LOIC.exe

(root@kali)-[/home/kali/Downloads]
# unzip LOIC-1.0.8-binary.zip
```

Hình 10: Tải về và giải nén ứng dụng

Trước khi sử dụng công cụ hỗ trợ cần phải cấp quyền thực thi

```
(root@kali)-[/home/kali/Downloads]
# ls
code_1.85.2-1705561292_amd64.deb      Hoic      LOIC-1.0.8-binary.zip  usr
code-1.85.2-1705561377.el7.x86_64.rpm  Hoic.rar  LOIC.exe

(root@kali)-[/home/kali/Downloads]
# chmod +x LOIC.exe
```

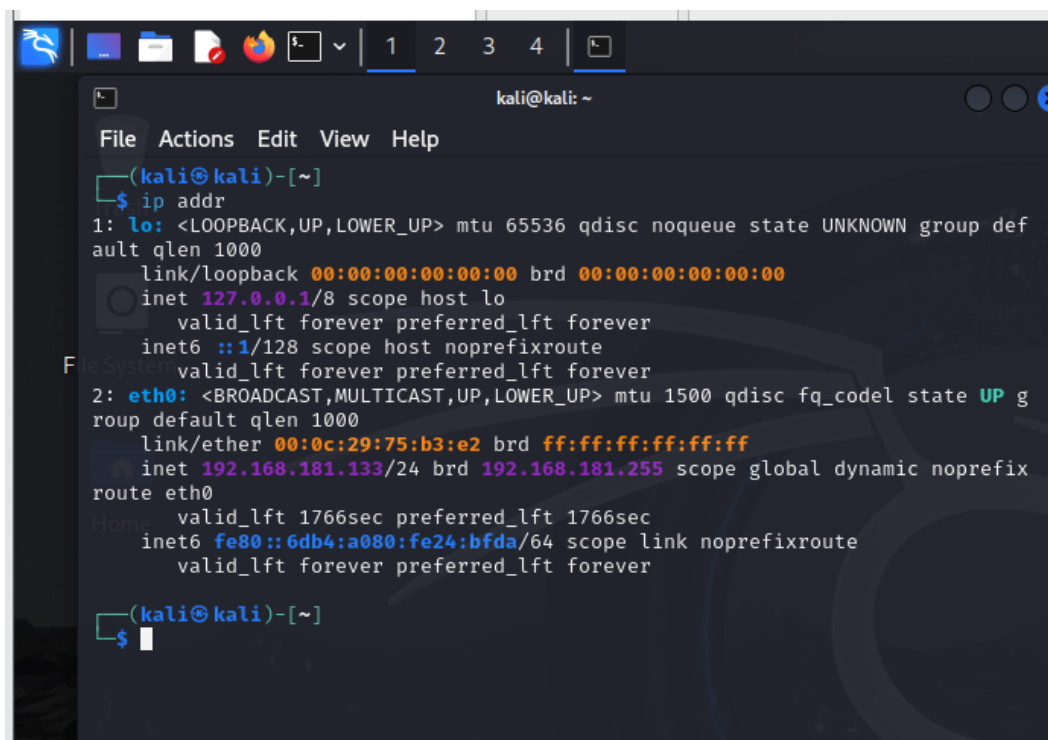
Hình 11: Cấp quyền cho ứng dụng để ứng dụng thực thi

Sử dụng công cụ

```
(root@kali)-[/home/kali/Downloads]
# ./LOIC.exe
```

Hình 12: Chạy ứng dụng hỗ trợ

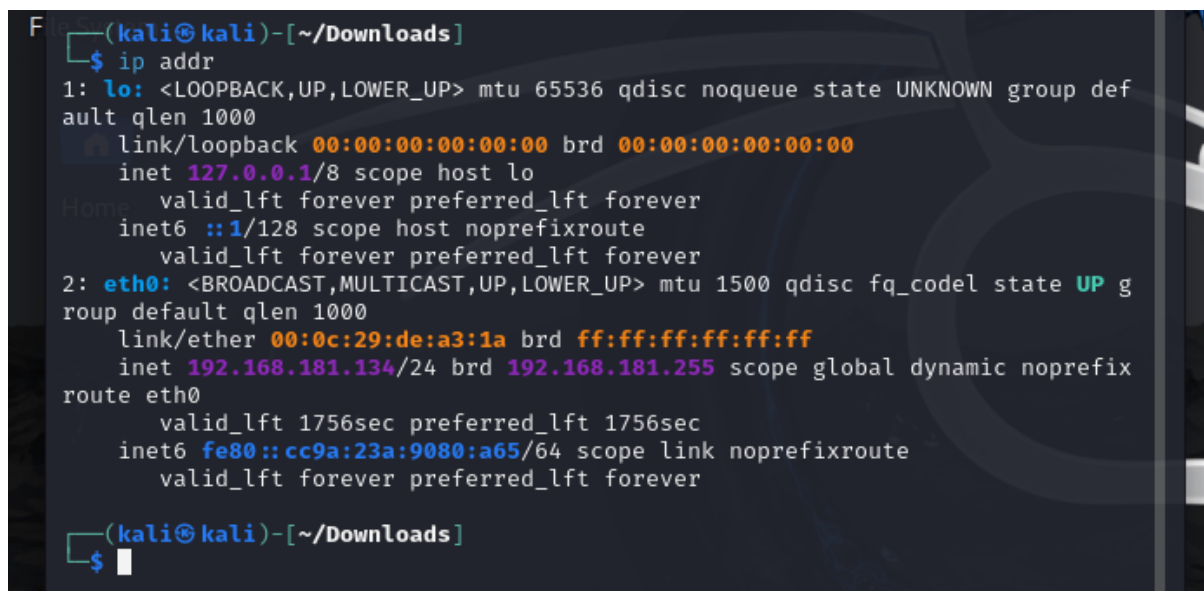
Địa chỉ IP của máy tấn công 1



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 00:0c:29:75:b3:e2 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.181.133/24 brd 192.168.181.255 scope global dynamic noprefixroute eth0  
        valid_lft 1766sec preferred_lft 1766sec  
    inet6 fe80::6db4:a080:fe24:bfd4/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(kali@kali)-[~]  
$
```

Hình 13: Địa chỉ IP của máy tấn công 1

Địa chỉ IP máy tấn công 2



```
(kali@kali)-[~/Downloads]  
$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 00:0c:29:de:a3:1a brd ff:ff:ff:ff:ff:ff  
    inet 192.168.181.134/24 brd 192.168.181.255 scope global dynamic noprefixroute eth0  
        valid_lft 1756sec preferred_lft 1756sec  
    inet6 fe80::cc9a:23a:9080:a65/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(kali@kali)-[~/Downloads]  
$
```

Hình 14: Địa chỉ IP của máy tấn công 2

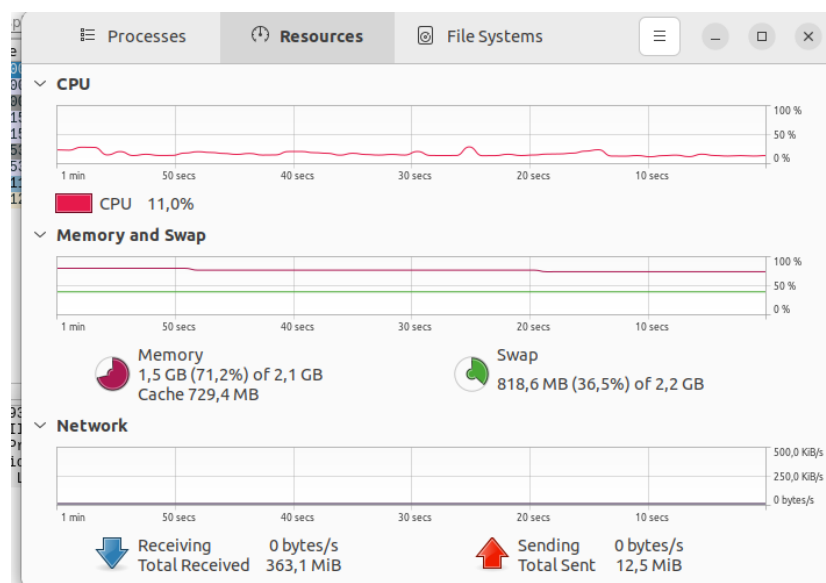
Tạo máy Client Ubuntu


```
thu@thu: ~  
thu@thu:~$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 00:0c:29:44:64:23 brd ff:ff:ff:ff:ff:ff  
    altname enp2s1  
    inet 192.168.181.128/24 brd 192.168.181.255 scope global dynamic noprefixroute ens33  
        valid_lft 1638sec preferred_lft 1638sec  
    inet6 fe80::4293:e5e9:da4c:a1f0/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
thu@thu:~$
```

Hình 15: IP của máy tính (ubuntu) bị tấn công

Các thông số quan sát của CPU máy ubuntu khi chưa bị tấn công.

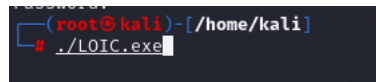
Thể hiện việc dùng CPU và network ở mức từ trung bình tới thấp thể hiện các tiến trình sử dụng trên máy ubuntu ở mức bình thường.



Hình 16: Thông số máy Client chưa bị tấn công

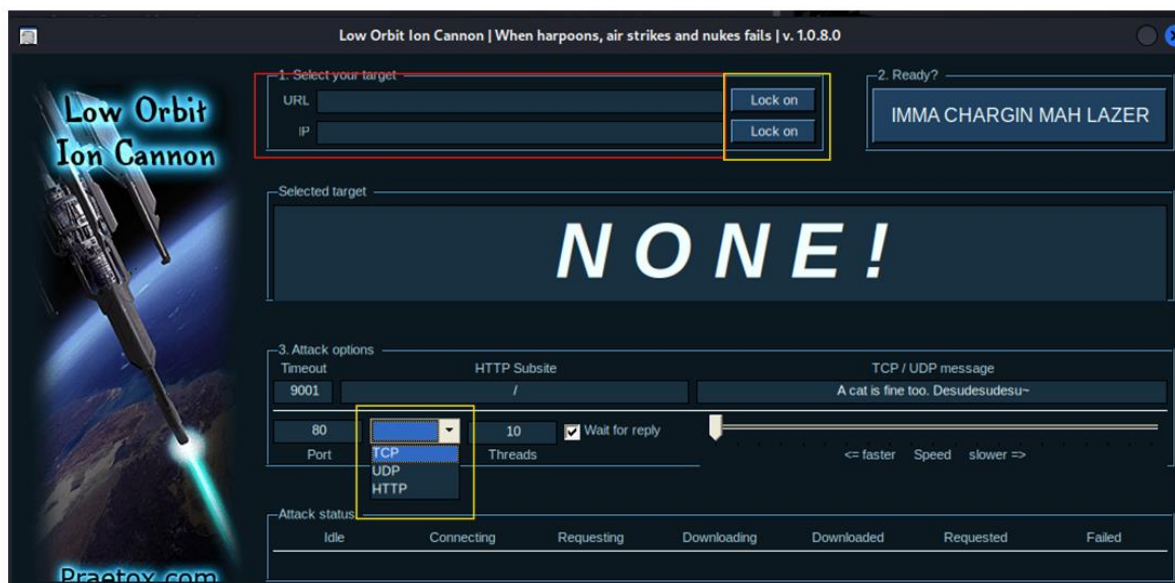
Bên phía tấn công phải đăng nhập vào tài khoản root và thực hiện câu lệnh khởi động công cụ tấn công theo câu lệnh sau:

```
./LOIC.exe
```



Hình 17: Thực thi chương trình

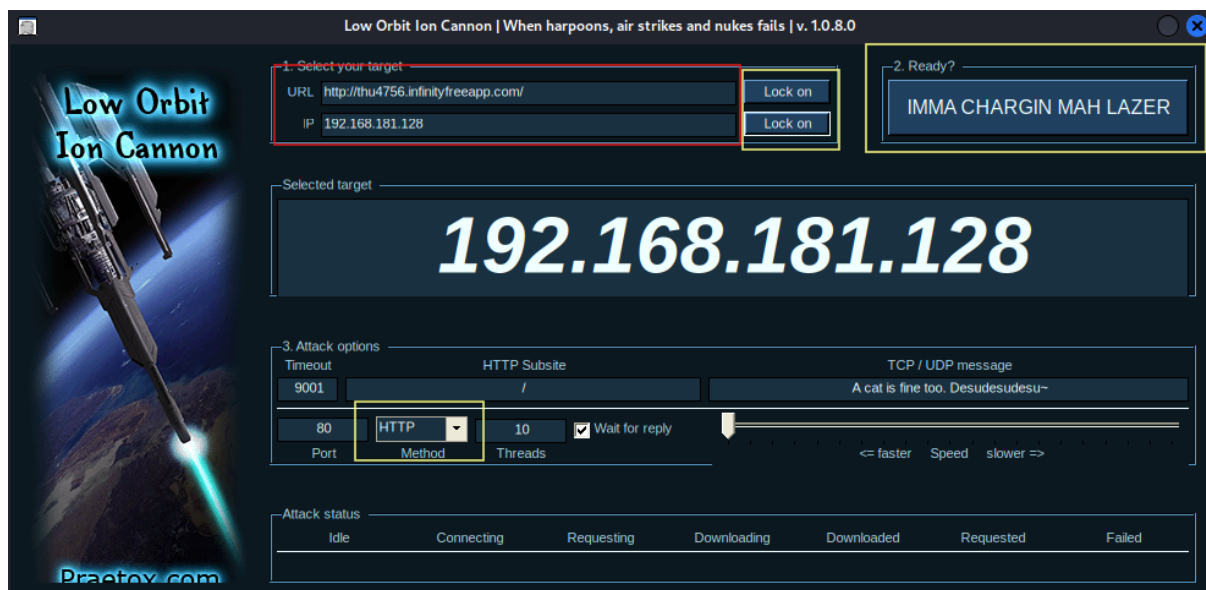
Giao diện của công cụ LOIC và các phương thức chọn tấn công.



Hình 18: Giao diện công cụ LOIC

Điền các thông tin URL, địa chỉ máy (điền: khung màu đỏ) và phương thức mong muốn tấn công (chọn: khung màu vàng).

Chọn các nút button để thực thi xác định và khóa địa chỉ điểm đến để thực hiện tấn công. Chọn IMMA CHARGIN MAH LAZER để tiến hành thực hiện cuộc tấn công.



Hình 19: Giao diện dành cho máy tính (kali linux) tấn công

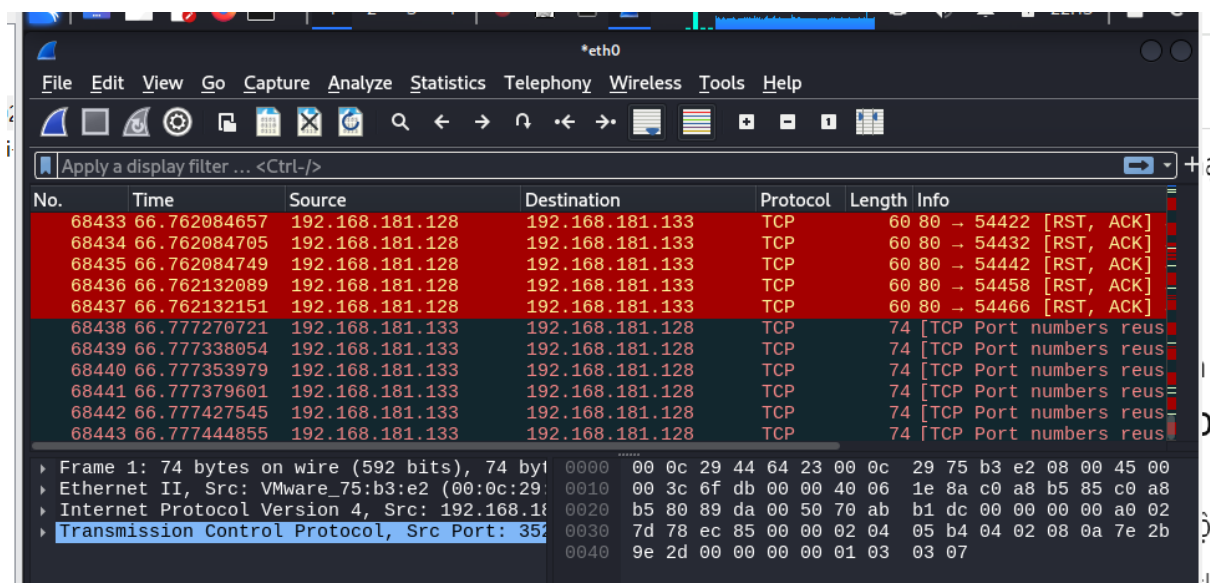
Đồng thời mở công cụ wireshark bên phía máy tấn công nhằm có thể theo dõi tiến trình tấn công.

Các tiến trình được ghi lại bởi wireshark của máy kali 1 và máy kali 2 cũng có những thông số gần tương đương.

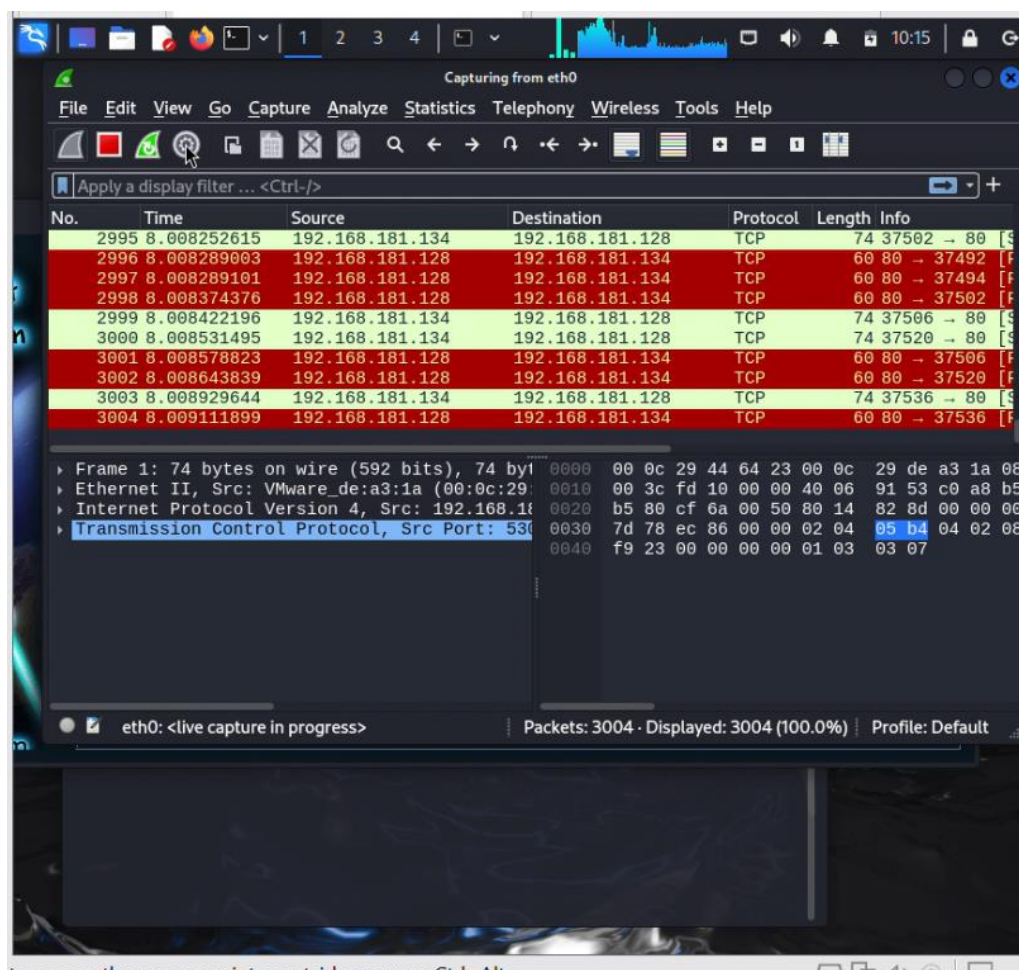
- Địa chỉ nguồn kali 1: 192.168.181.133 địa chỉ máy kali tấn công
- Địa chỉ nguồn kali 2: 192.168.181.134 địa chỉ máy kali tấn công
- Địa chỉ đích: 192.168.181.128 địa chỉ máy ubuntu bị tấn công

Nguyên nhân tấn công với giao thức TCP:

- Trên địa chỉ 192.168.181.128 không hề tồn tại web với URL <https://thu4756.infinityfreeapp.com/> và địa chỉ web là (185.27.134.134)
- Do URL đã được đăng kí và deploy lên các công cụ host free do đó URL của web có địa chỉ web đăng kí được gán bằng địa chỉ của host free.
- Do đó khi tấn công công cụ sẽ tìm phương thức đầu tiên trong phương thức để tấn công (trong giao thức phương thức tấn công đầu tiên là TCP).



Hình 20: Thông số máy Server 1 khi tấn công dùng wireshark để xem quá trình



Hình 21: Thông số Server 2 khi tấn công dùng wireshark để xem quá trình

Bên máy Ubuntu nạn nhân (bị tấn công)

Mở công cụ wireshark để theo dõi tiến trình bị tấn công.

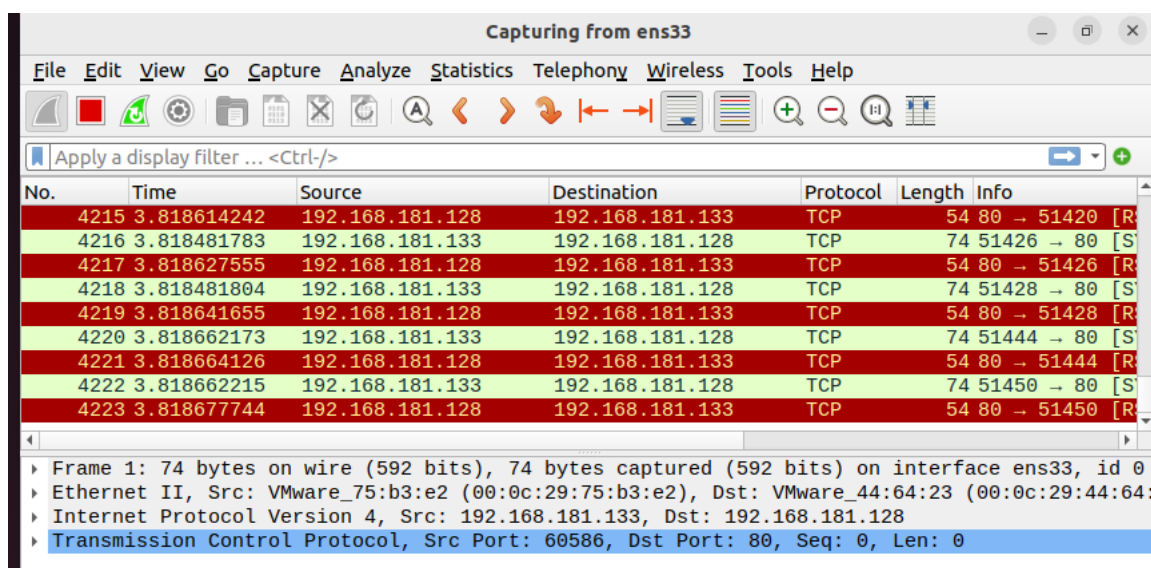
- Địa chỉ nguồn kali 1: 192.168.181.133 địa chỉ máy kali tấn công

Với phương thức TCP

- Địa chỉ đích: 192.168.181.128 là địa chỉ máy Ubuntu bị tấn công

Nguyên nhân chọn hình thức tấn công là HTTP nhưng khi bắt gói lại là tấn công TCP:

- Với địa chỉ website sau khi được public lên internet bằng các công cụ host free trang web đã được thay đổi địa chỉ thành các địa chỉ được đăng kí có sẵn của các công cụ.
- Khi tấn công chọn lock on địa chỉ thì sẽ tấn công với địa chỉ tương ứng. Và thực nghiệm này đã chọn địa chỉ 192.168.181.128 để thực hiện tấn công.
- Giao thức tấn công cũng sẽ được thay đổi tương ứng với phương thức đầu tiên hiển thị trên giao diện.

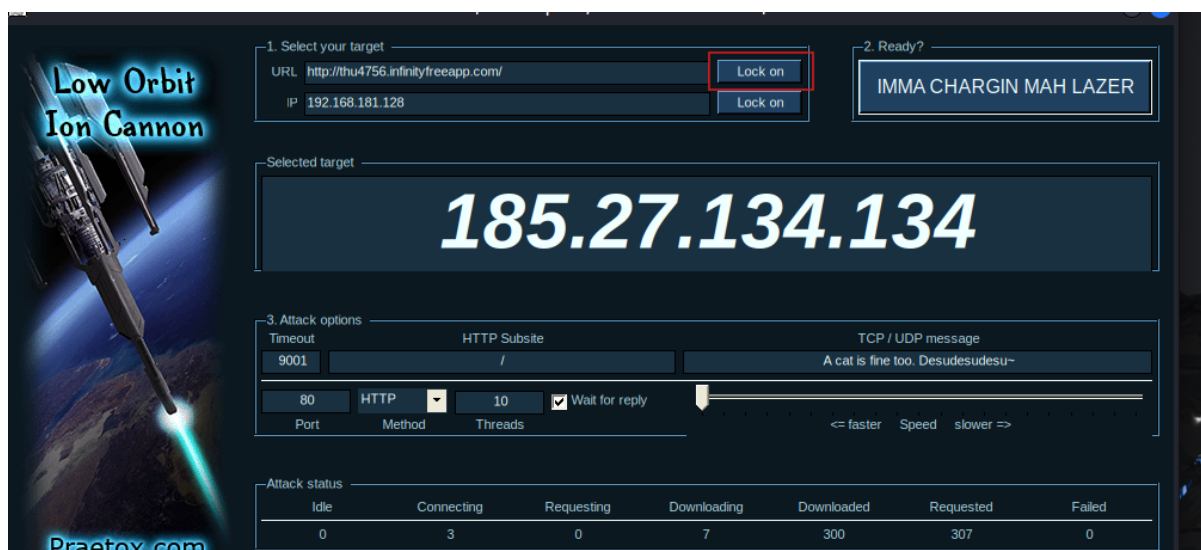


No.	Time	Source	Destination	Protocol	Length	Info
4215	3.818614242	192.168.181.128	192.168.181.133	TCP	54	80 → 51420 [R]
4216	3.818481783	192.168.181.133	192.168.181.128	TCP	74	51426 → 80 [S]
4217	3.818627555	192.168.181.128	192.168.181.133	TCP	54	80 → 51426 [R]
4218	3.818481804	192.168.181.133	192.168.181.128	TCP	74	51428 → 80 [S]
4219	3.818641655	192.168.181.128	192.168.181.133	TCP	54	80 → 51428 [R]
4220	3.818662173	192.168.181.133	192.168.181.128	TCP	74	51444 → 80 [S]
4221	3.818664126	192.168.181.128	192.168.181.133	TCP	54	80 → 51444 [R]
4222	3.818662215	192.168.181.133	192.168.181.128	TCP	74	51450 → 80 [S]
4223	3.818677744	192.168.181.128	192.168.181.133	TCP	54	80 → 51450 [R]

Frame 1: 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface ens33, id 0
Ethernet II, Src: VMware_75:b3:e2 (00:0c:29:75:b3:e2), Dst: VMware_44:64:23 (00:0c:29:44:64:23)
Internet Protocol Version 4, Src: 192.168.181.133, Dst: 192.168.181.128
Transmission Control Protocol, Src Port: 60586, Dst Port: 80, Seq: 0, Len: 0

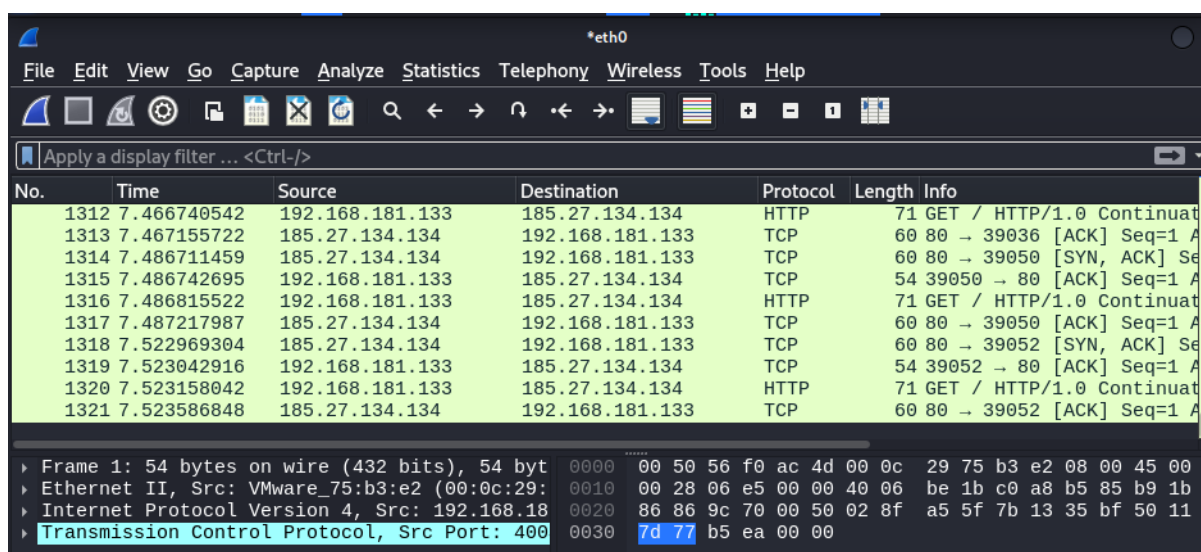
Hình 22: Wireshark bắt các gói tin tấn công

Khi lock on với URL công cụ sẽ tiến hành chọn địa chỉ được đăng ký của web. Và chọn phương thức tấn công như đã hướng dẫn ở trên.



Hình 23: Lock on với địa chỉ của web đã đăng ký

Dùng wireshark để tiến hành theo dõi quá trình tấn công HTTP ở URL (website) muốn tấn công và có thể theo dõi tiến trình tấn công theo qua các thông số nhưng không thể theo dõi ngược lại từ server của web (do địa chỉ IP được các công cụ gán khi đăng ký).



Hình 24: Wireshark từ máy kali tấn công HTTP

Thông số của ubuntu khi bị tấn công:

Tài nguyên CPU tăng cao đột biến từ trung bình đến cao. Điều này xảy ra khi hệ thống phải xử lý một lượng lớn yêu cầu từ kẻ tấn công, dẫn đến việc tăng cao về tải CPU để làm tắc nghẽn tài nguyên của hệ thống đó.

Thông số Network tăng cao khi kẻ tấn công gửi một lượng lớn yêu cầu đến một hệ thống hoặc dịch vụ, lưu lượng mạng sẽ tăng đột ngột do việc cố gắng xử lý các yêu cầu đó.

Nguyên nhân:

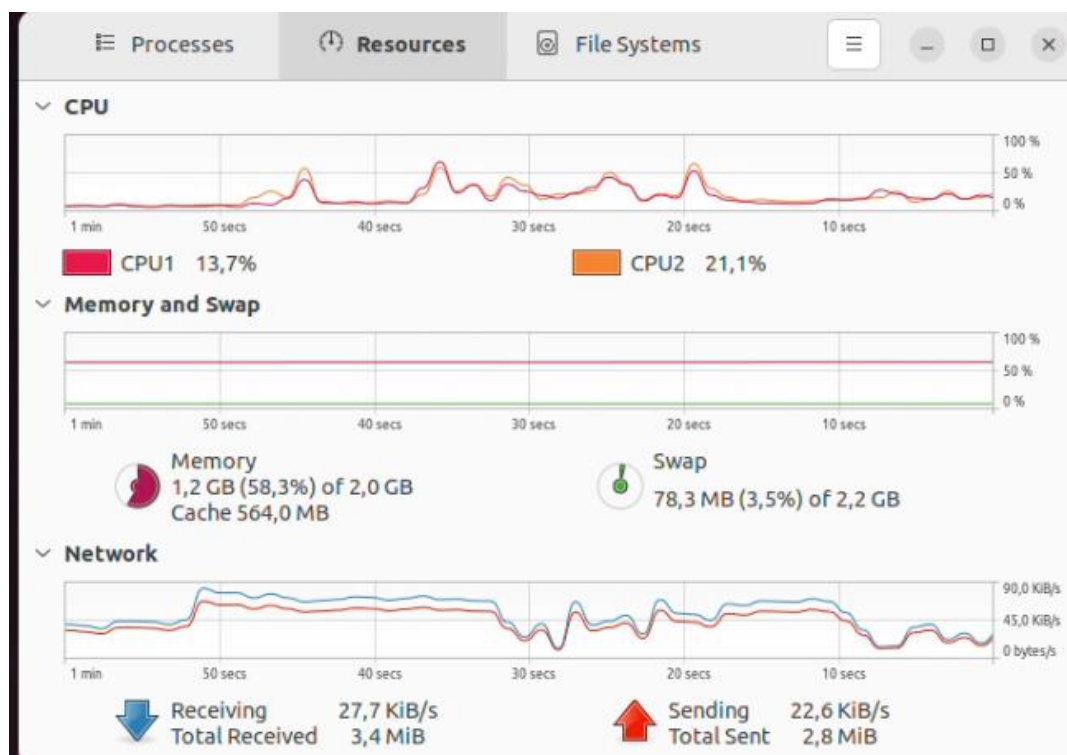
DDoS là tấn công theo kiểu tiêu thụ tài nguyên, trong đó kẻ tấn công gửi một lượng lớn yêu cầu đến một hệ thống hoặc dịch vụ để làm tắc nghẽn tài nguyên của hệ thống đó.

Hậu quả:

- **Giảm tốc độ truy cập:** Vì lưu lượng mạng tăng cao, tốc độ truy cập vào dịch vụ hoặc hệ thống có thể giảm đáng kể, gây ra sự không khả dụng đối với người dùng hợp lệ.
- **Quá tải hệ thống:** Do việc phải xử lý lượng lớn yêu cầu từ kẻ tấn công, hệ thống có thể trở nên quá tải, dẫn đến giảm hiệu suất hoặc sự không ổn định.

Tìm hiểu các cách nhận biết và tìm cách khắc phục:

Xem số liệu để nhận biết một tấn công DDoS đang xảy ra hay không, tiến hành sử dụng các công cụ giám sát hệ thống như Wireshark để phân tích lưu lượng mạng.



Hình 25: Thông số máy Client khi bị tấn công

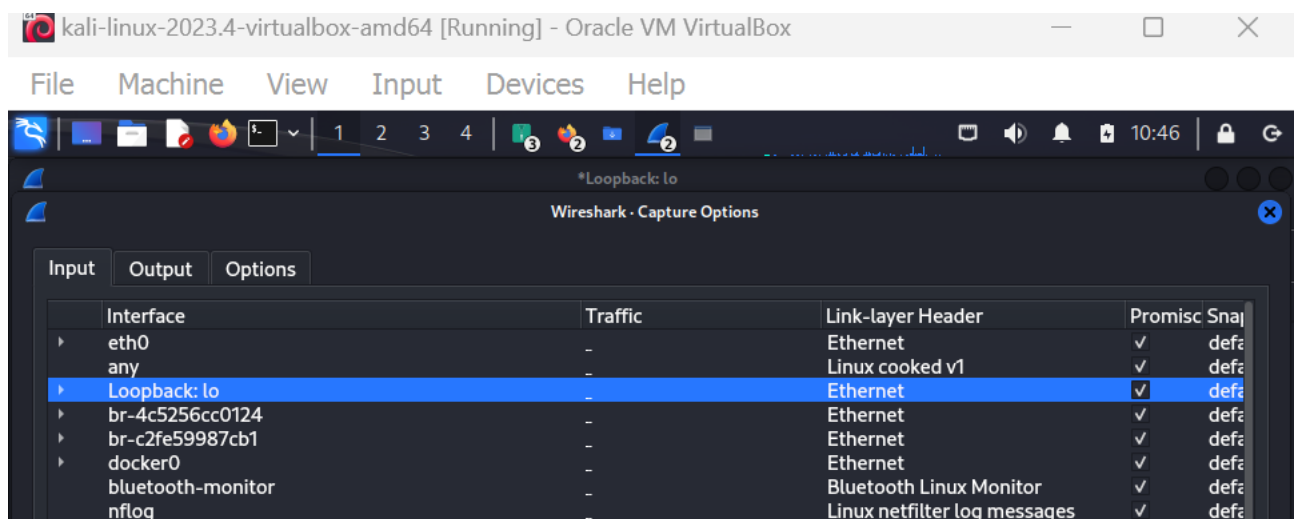
3.2.2 Thực nghiệm tấn công MITM

Định nghĩa

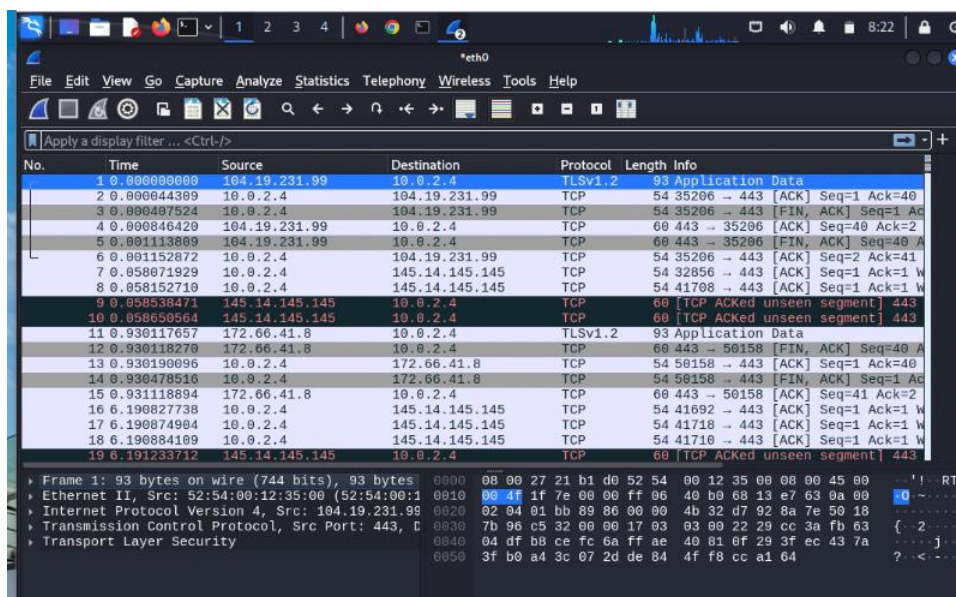
- Tấn công MITM (Man-in-the-Middle) tấn công kẻ đứng giữa là một loại tấn công mạng mà kẻ tấn công giữa hai bên truyền thông và lắng nghe, can thiệp hoặc thậm chí là thay đổi thông tin được truyền qua mạng một cách không được ủy quyền.
- Trong tấn công này, kẻ tấn công thường đóng vai trò như một "trung gian" (middle-man) giữa người gửi và người nhận thông tin, và hai bên này không nhận ra sự tồn tại của kẻ tấn công.

Dùng công cụ hỗ trợ là WireShark

Tải công cụ hỗ trợ và tiến hành với quyền root, dùng công cụ wireshark nhằm mục đích có thể bắt các gói tin truyền đi trên đường truyền và xem nội dung các gói tin bắt được.



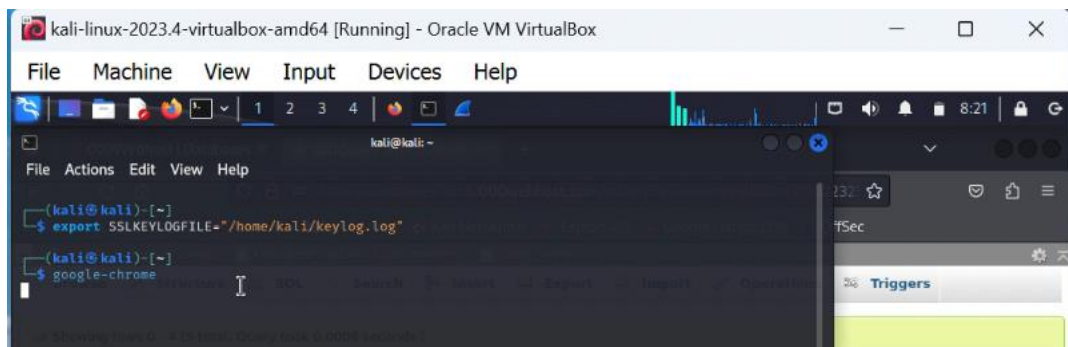
Hình 26: Công cụ wireshark



Hình 27: Công cụ wireshark thực hiện tác vụ

Thực thi câu lệnh tạo 1 logfile mới và logfile này sẽ ghi các lại thao tác trên google-chrome.

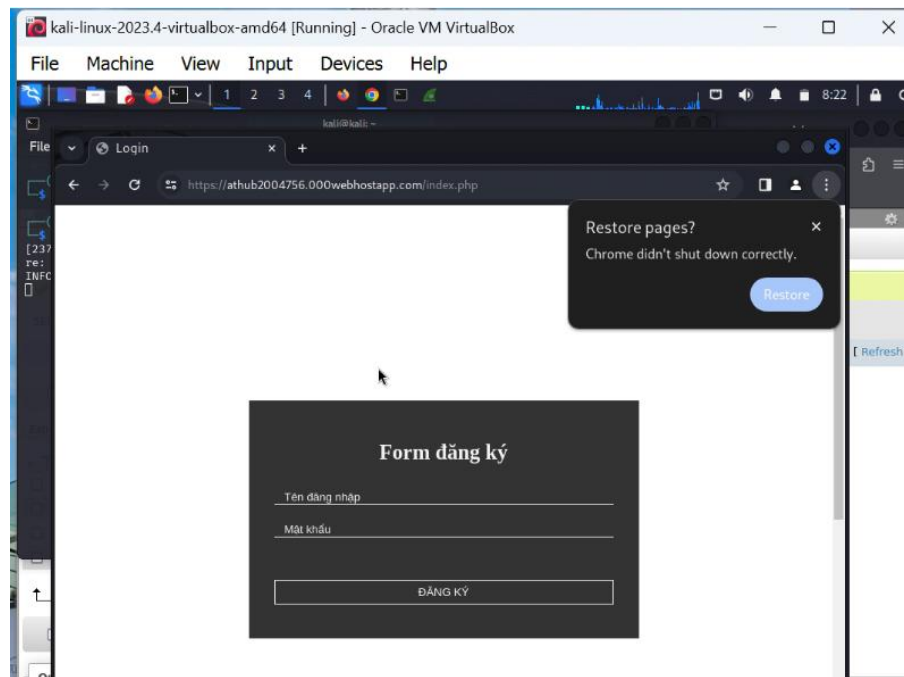
Tiến hành sử dụng logfile này để lọc các gói thông tin bằng công cụ wireshark để có thể đọc nội dung các của các gói tin bắt được.



Hình 28: : Tiến hành ghi log file của trang website muốn truy cập

Tiến hành các thao tác thông thường đối với các website.

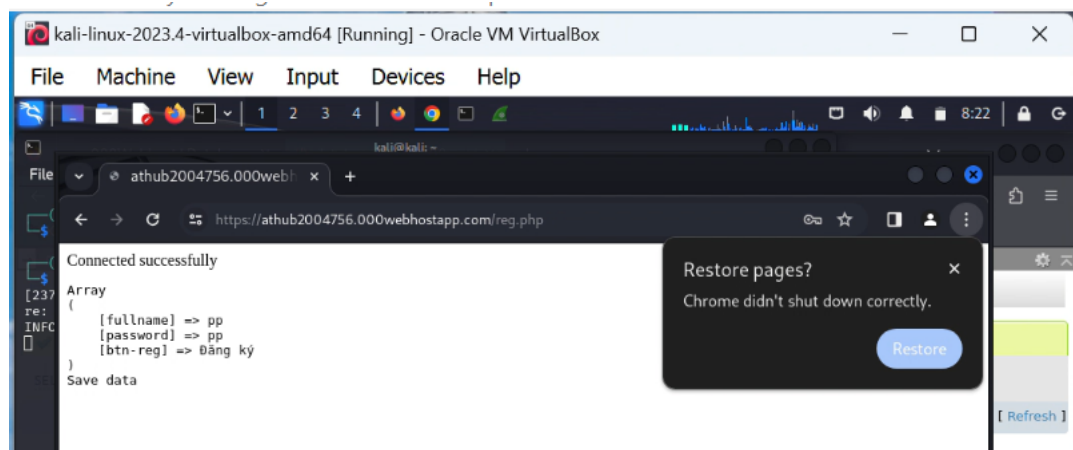
Ví dụ: đăng kí, đăng nhập, ...



Hình 29: Trang website được tạo dùng cho mục đích thử nghiệm

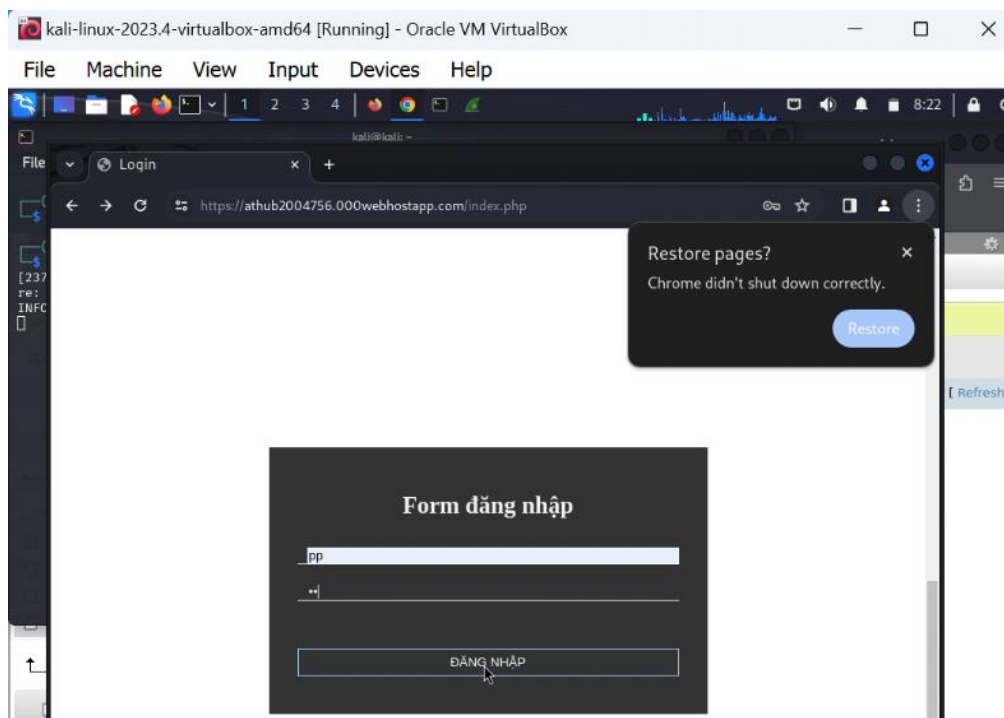
Thực hiện thao tác đăng ký vào website thông thường.

Dữ liệu được lưu vào CSDL của database.



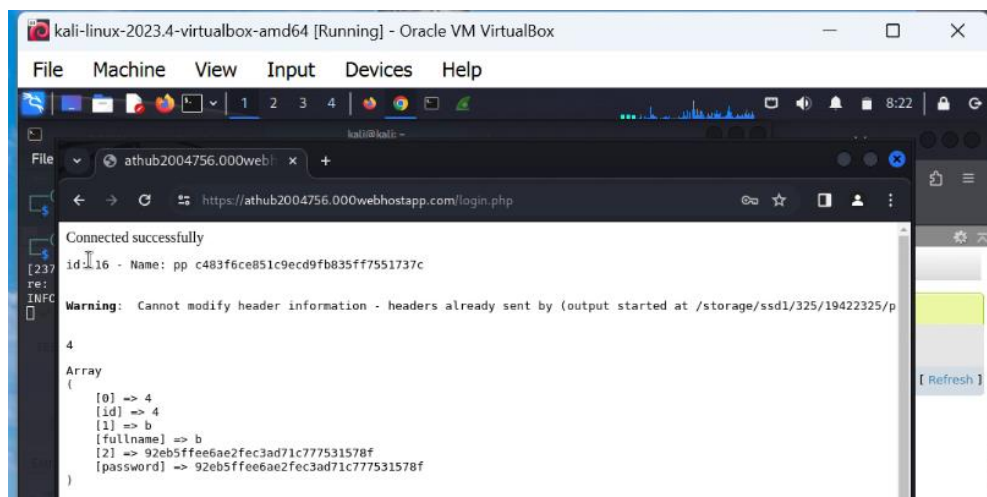
Hình 30: Dữ liệu được lưu vào CSDL

Thực hiện thao tác đăng nhập vào website thông thường.



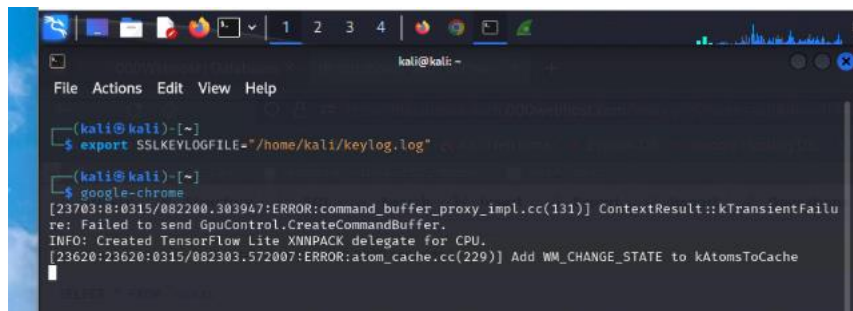
Hình 31: Tiến hành đăng nhập dữ liệu đã đăng ký

Đăng nhập tài khoản có sẵn trong CSDL và đã đăng nhập thành công.



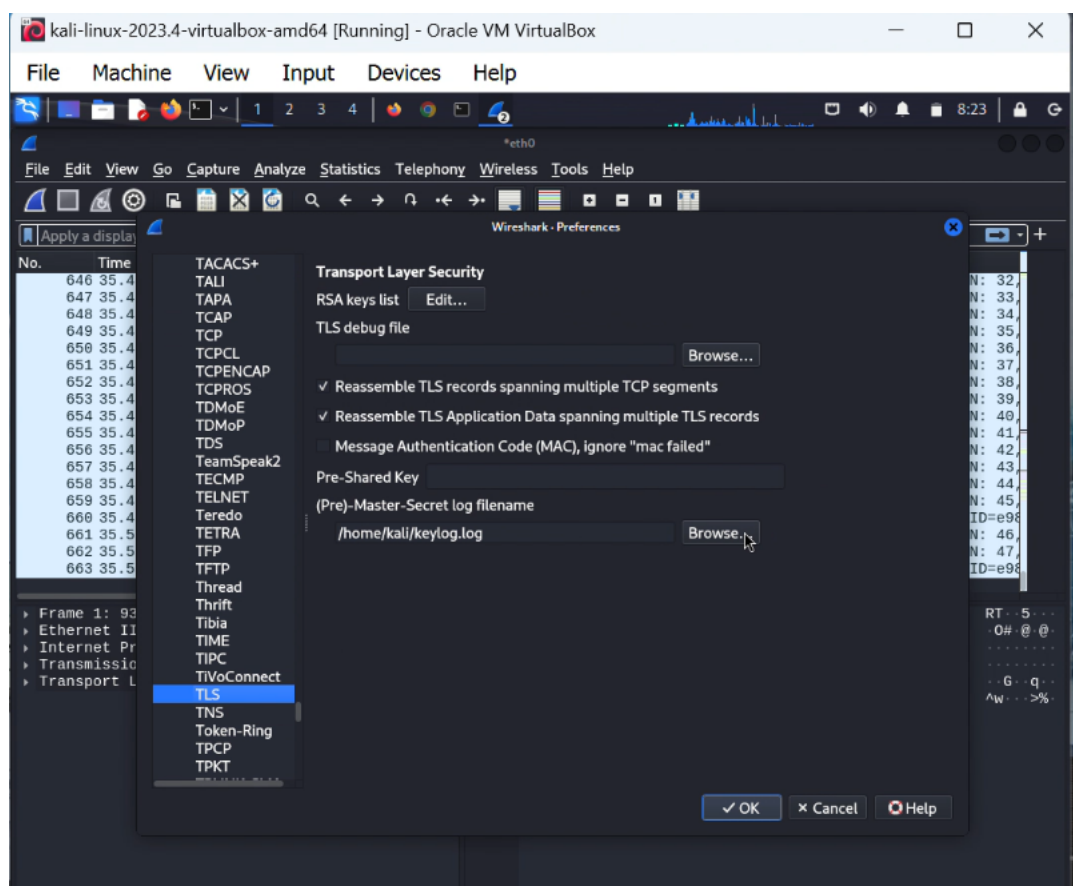
Hình 32: Đăng nhập thành công

Logfile tiến hành ghi lại các thao tác vừa thực hiện.



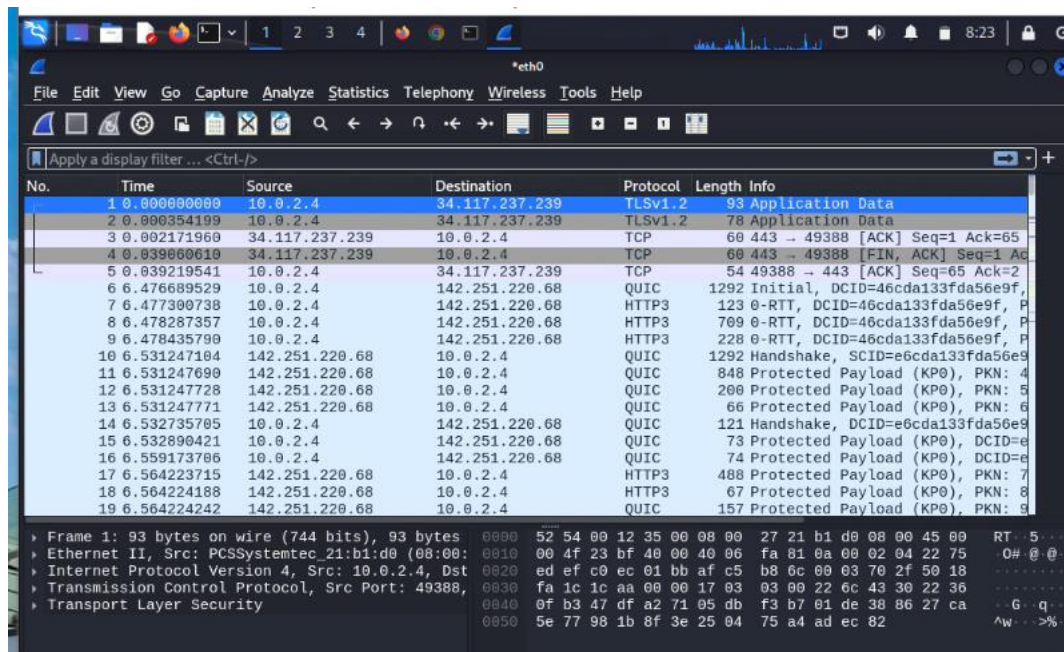
Hình 33: Log file ghi nhận lịch sử truy cập

Tiến hành chọn lọc gói TLS và gán logfile đã ghi vào công cụ wireshark .

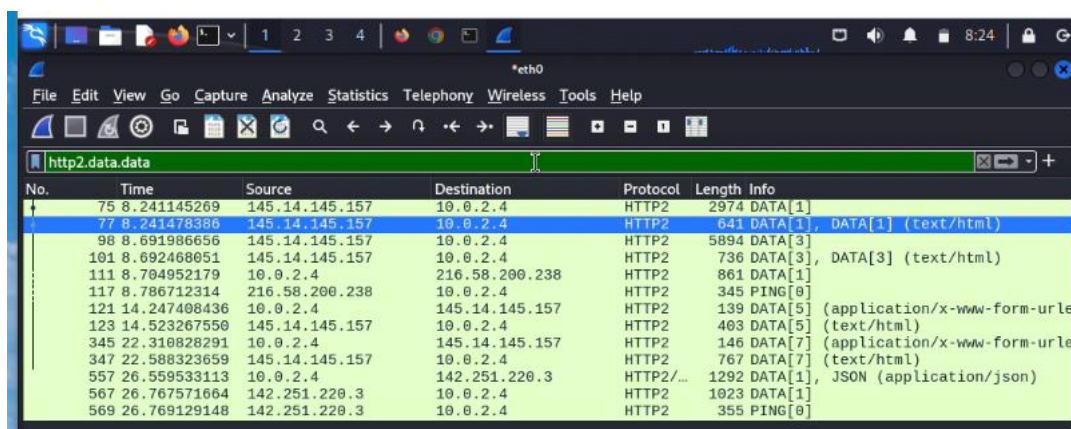


Hình 34: Đưa log file đã tạo phía trên vào đường dẫn

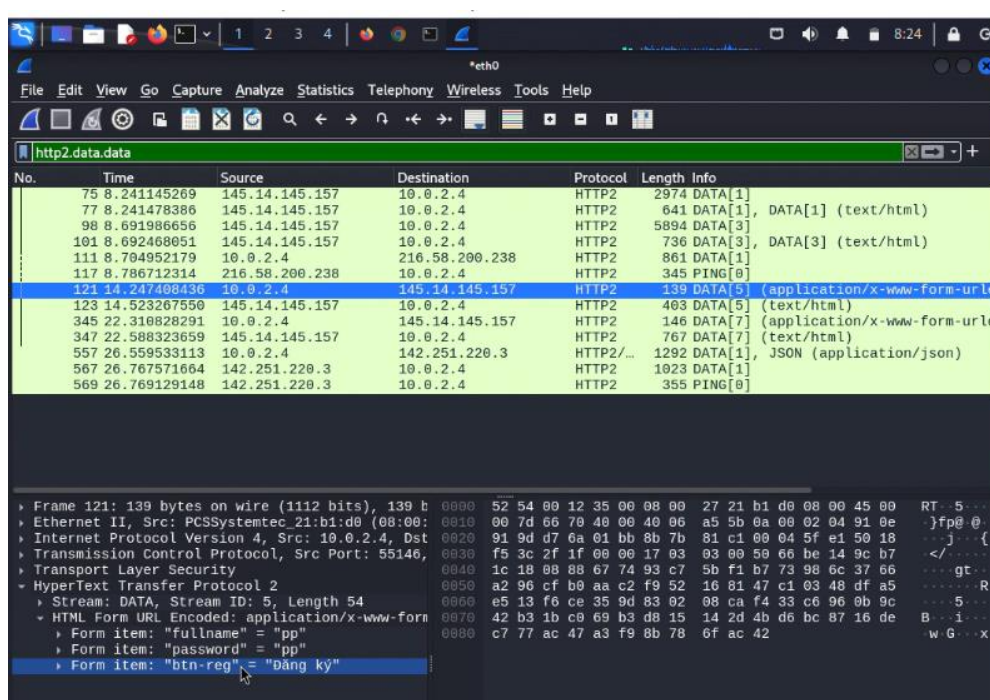
Giao diện wireshark sau khi được lọc dựa trên logfile.

**Hình 35: Công cụ wireshark khi nhận log file**

Tiến hành tìm kiếm các gói tin có dạng phương thức (protocol) http2.data.data.

**Hình 36: Dùng công cụ tìm kiếm để tìm log file cần tìm**

Tại đây tiến hành tìm các thông tin gói (info) có các dạng application sẽ ghi nhận được các dữ liệu vừa thực hiện được truyền đi trên đường truyền.



Hình 37: Bắt được gói tin khi đăng ký và gói tin đăng nhập cũng như vậy

3.3.3 Mô tả thực nghiệm SQL và hash mật khẩu

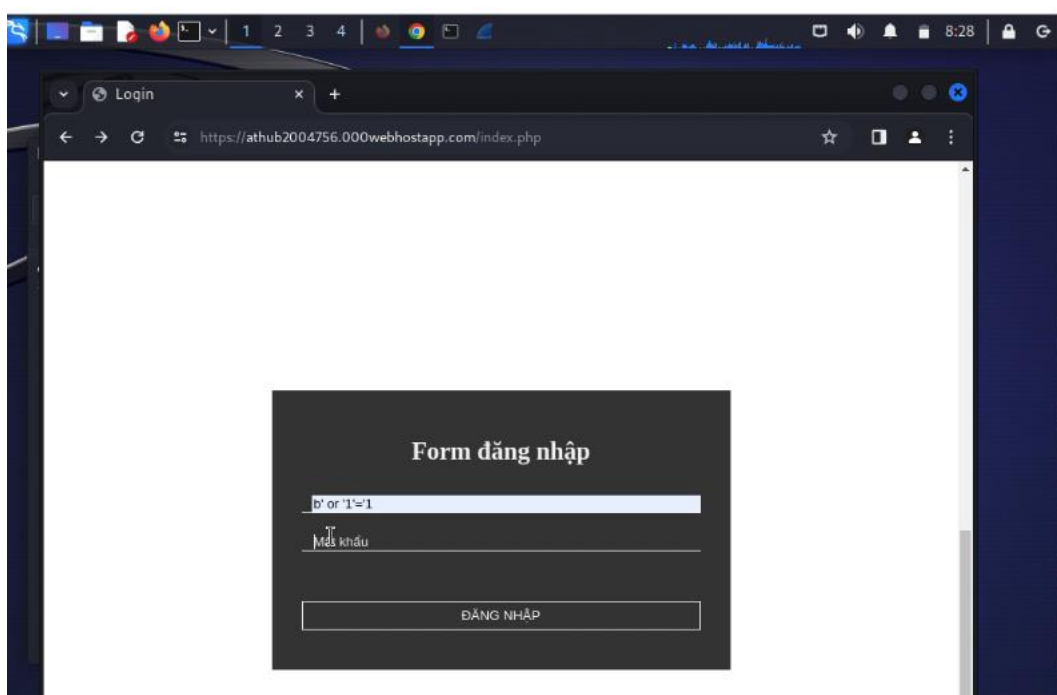
Khái niệm:

SQL injection – còn được gọi là SQLi – sử dụng những lỗ hổng trong các kênh đầu vào (input) của website để nhắm mục tiêu vào cơ sở dữ liệu nằm trong phần phụ trợ của ứng dụng web, nơi lưu giữ những thông tin nhạy cảm và có giá trị nhất.

Mục đích:

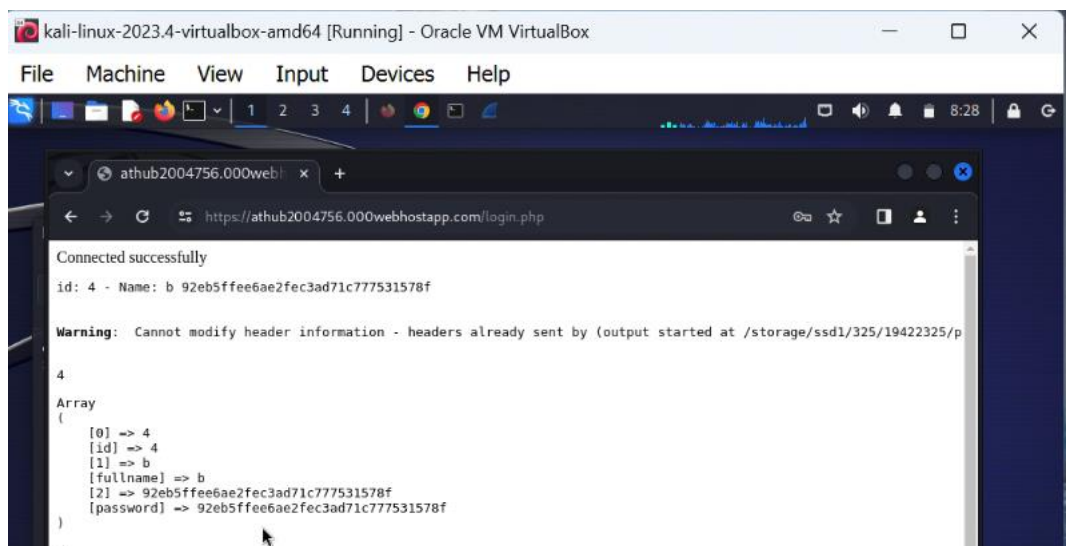
Chúng có thể được kẻ tấn công sử dụng để ăn cắp hoặc xáo trộn dữ liệu, cản trở sự hoạt động của các ứng dụng và trong trường hợp xấu nhất, nó có thể chiếm được quyền truy cập quản trị vào máy chủ cơ sở dữ liệu.

Dùng các dòng lệnh truy xuất SQL dò tìm đơn giản.

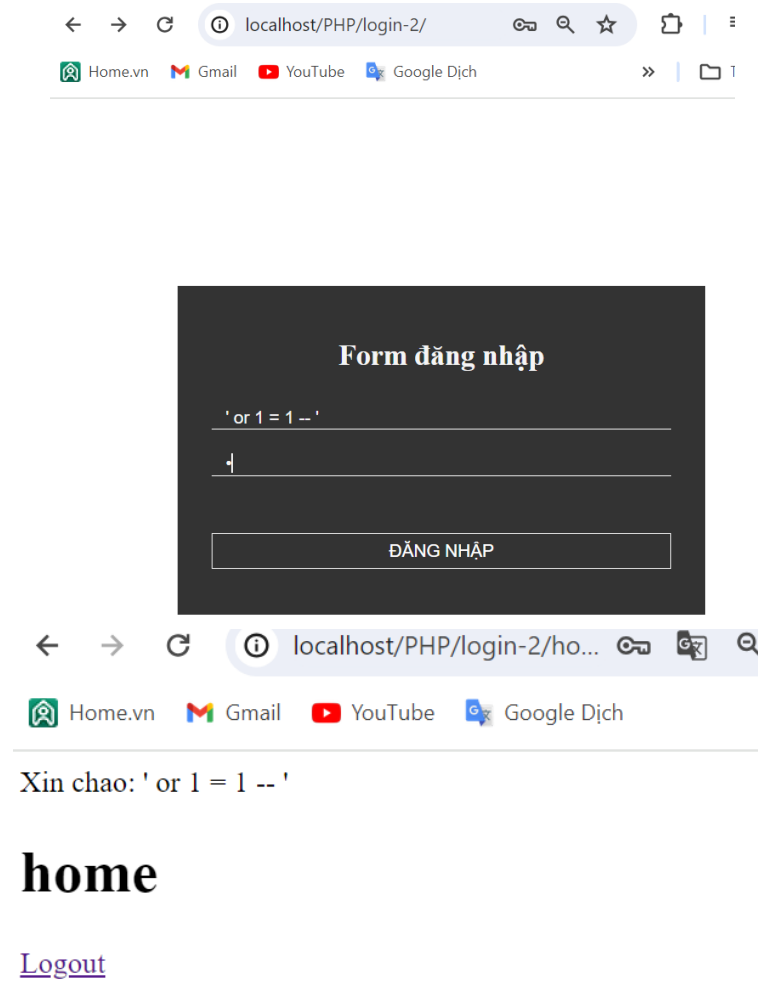


Hình 38: Dùng câu lệnh truy xuất để dò tìm

Dùng lệnh : ' or 1 = 1 -- ' (Nhập vào trường username và password để kiểm tra trang web có lỗ hổng SQL Injection hay không).

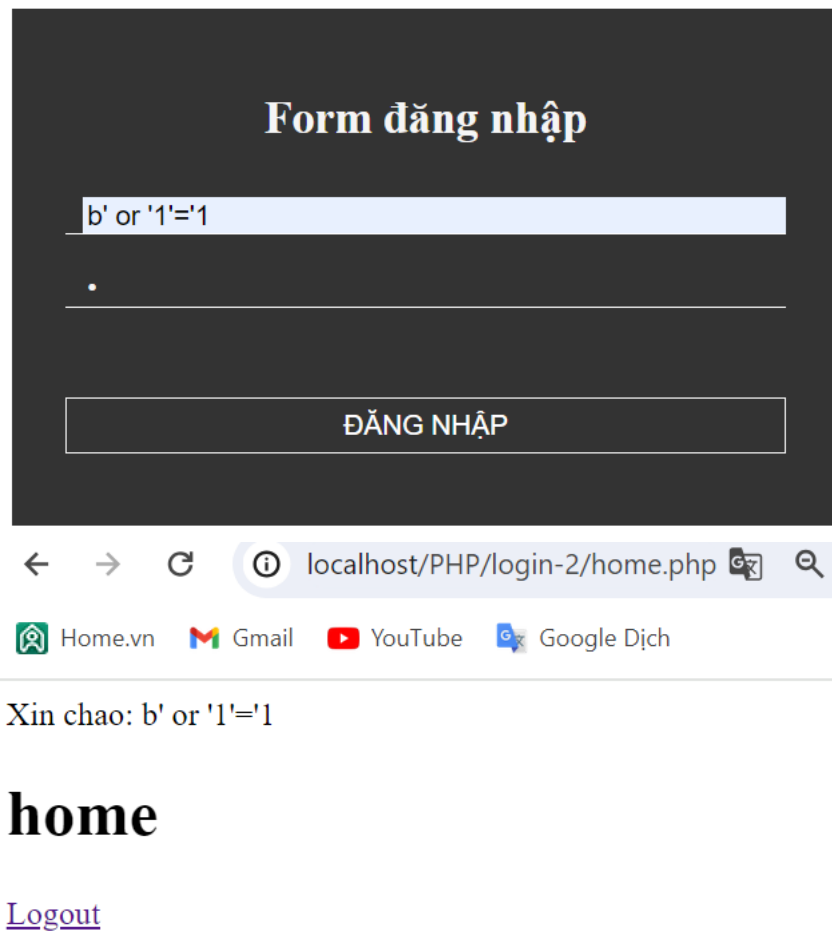


Hình 39: Phát hiện trong CSDL có người trùng tên với dữ liệu dò tìm



Hình 40: Dùng câu lệnh truy xuất để dò tìm khác

Chúng ta đăng nhập được có nghĩa là trang web đang có lỗ hổng SQL Injection



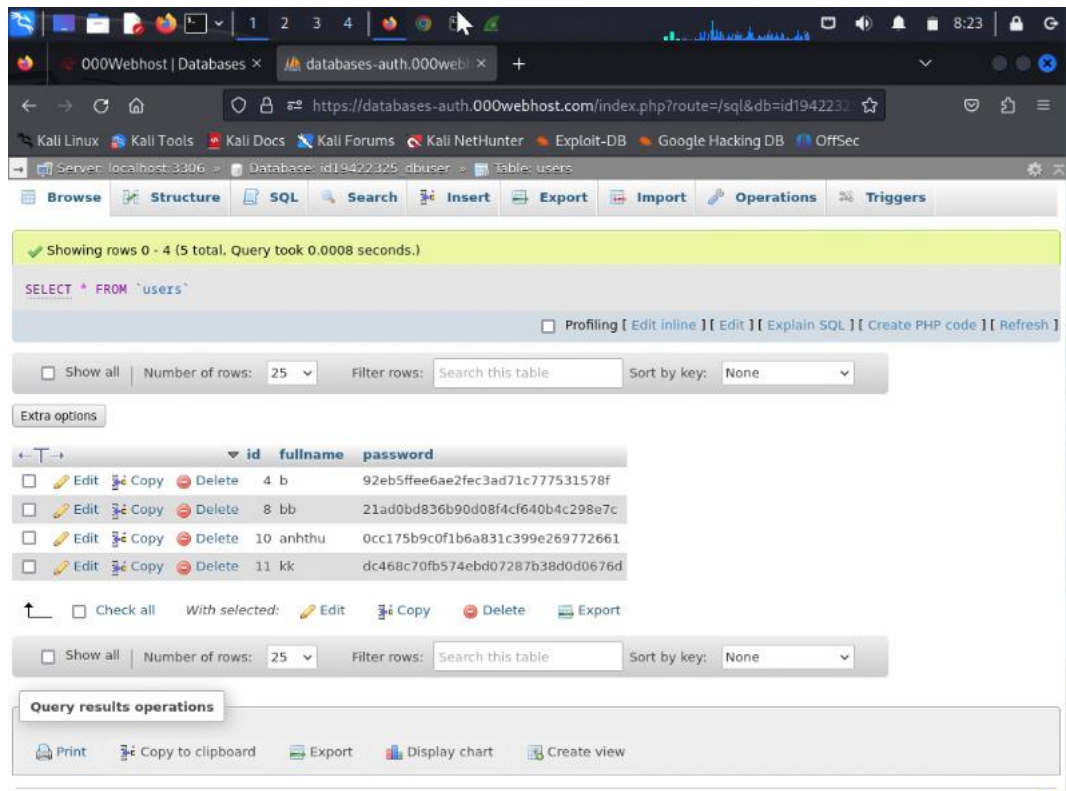
Hình 41: Truy xuất được vào trang quản lý của admin

Với trường hợp dò tìm được

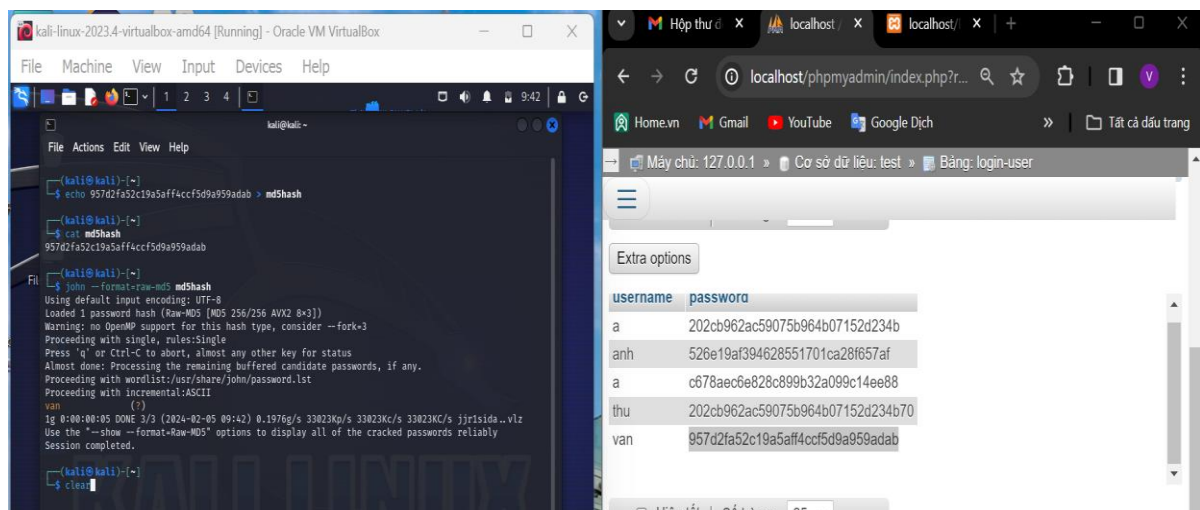
Xác định được trong CSDL có người dùng tên b và nhận được mã hash password của người dùng.

Tiến hành hash password.

Mục đích của việc hash password : Để có thể giải mã password của người dùng sau khi bị hacker dò tìm được các thông tin đơn giản của người dùng (phát hiện username nhưng chỉ nhận được mã md5 của password) hoặc hacker đã tấn công vào được tới các bảng CSDL về thông tin người dùng.

**Hình 42: CSDL các user**

Lấy ngẫu nhiên password từ CSDL để tiến hành hash để có thể thực nghiệm việc có thể đánh cắp dữ liệu người dùng bởi hacker.

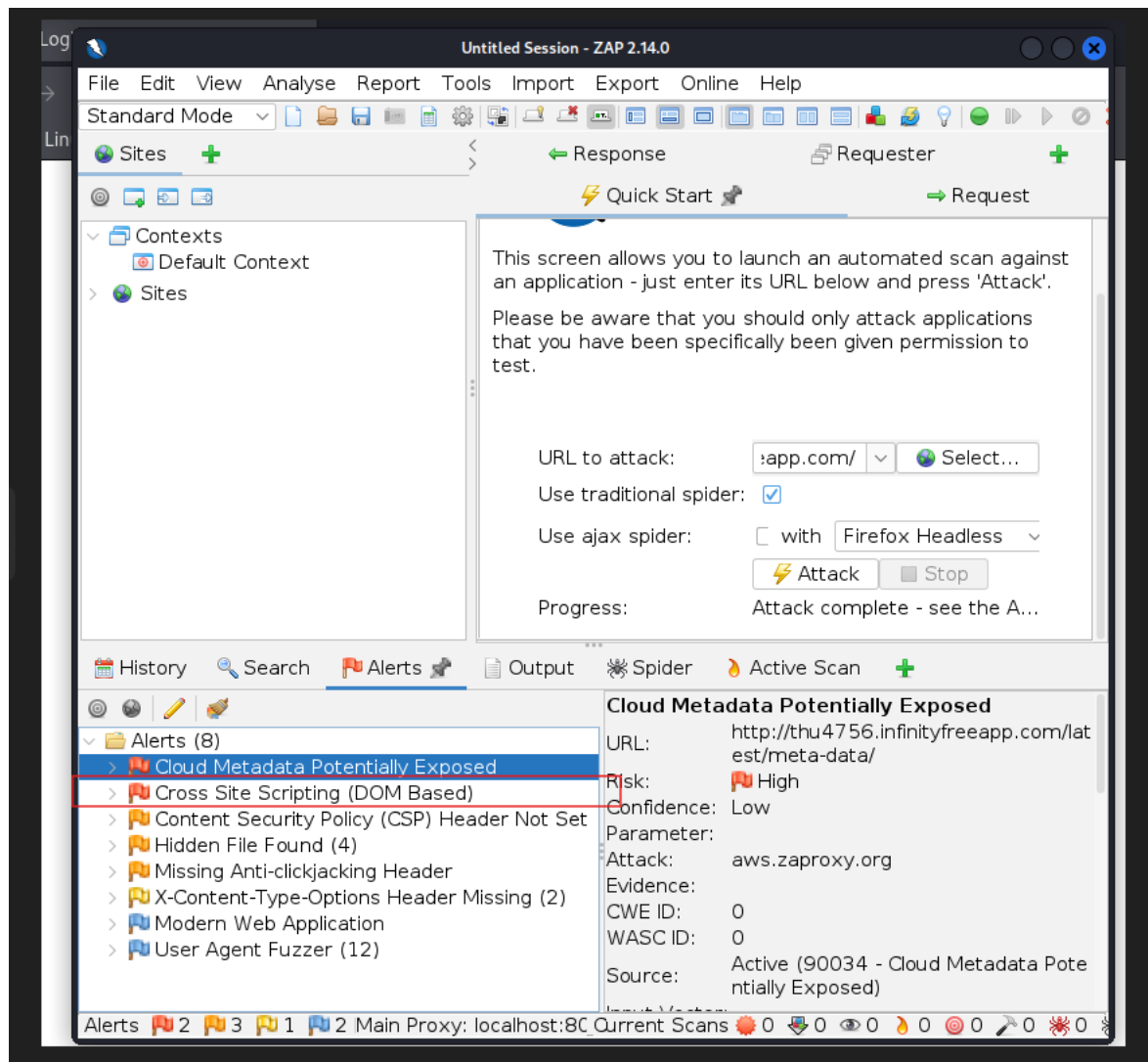
**Hình 43: Quá trình hash password của người dùng bất kì**

3.3.4 Thực nghiệm tấn công XSS

Tấn công XSS bằng cách chèn đoạn script

Công cụ hỗ trợ

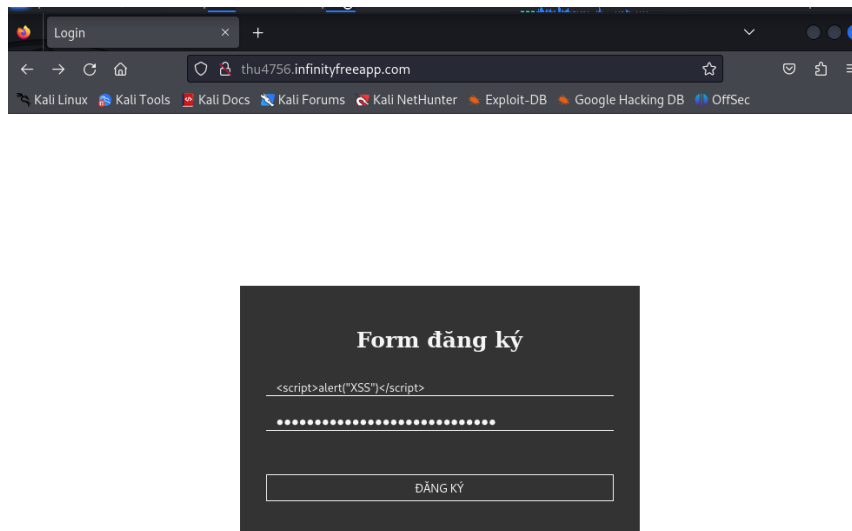
- ZAP: công cụ hỗ trợ phát hiện quét lỗ hổng, kiểm tra tính bảo mật và giám sát phát hiện tấn công XSS.



Hình 44: Kết quả phát hiện XSS

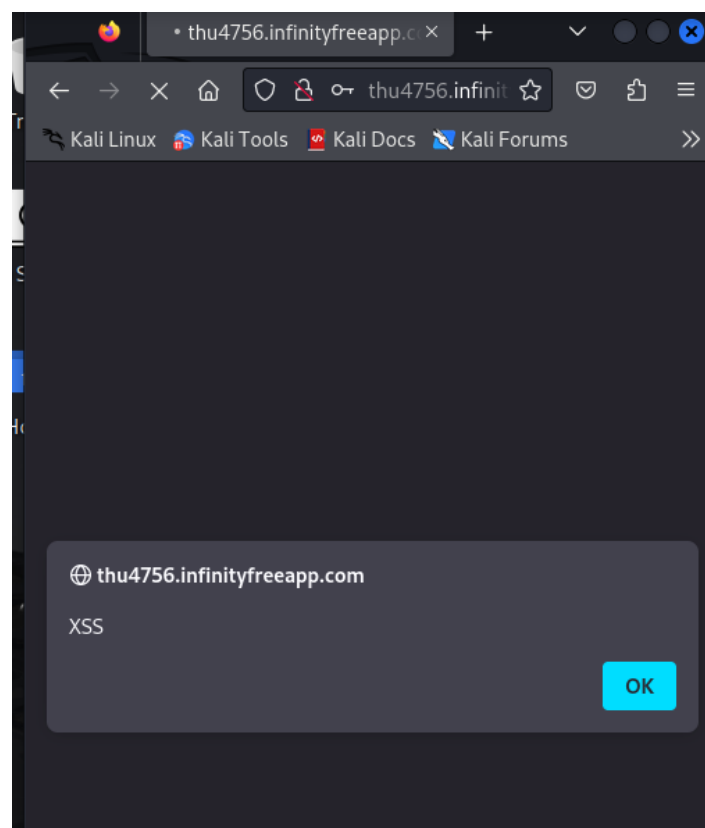
Kết quả sau khi scan trang website bằng công cụ và phát hiện lỗi Cross-site scripting (XSS) và tiến hành tấn công bằng các câu lệnh và ô input của trang đăng nhập và trang ký.

Chèn đoạn script tấn công: `<script>alert("XSS")</script>`



Hình 45: Sử dụng câu lệnh để tấn công

Trường hợp bị tấn công XSS ở đây là: Reflected XSS: Mã độc hại được chèn vào một request (yêu cầu) và sau đó được phản ánh (reflected) trở lại cho người dùng thông qua một đoạn script được thể hiện trên trang web.



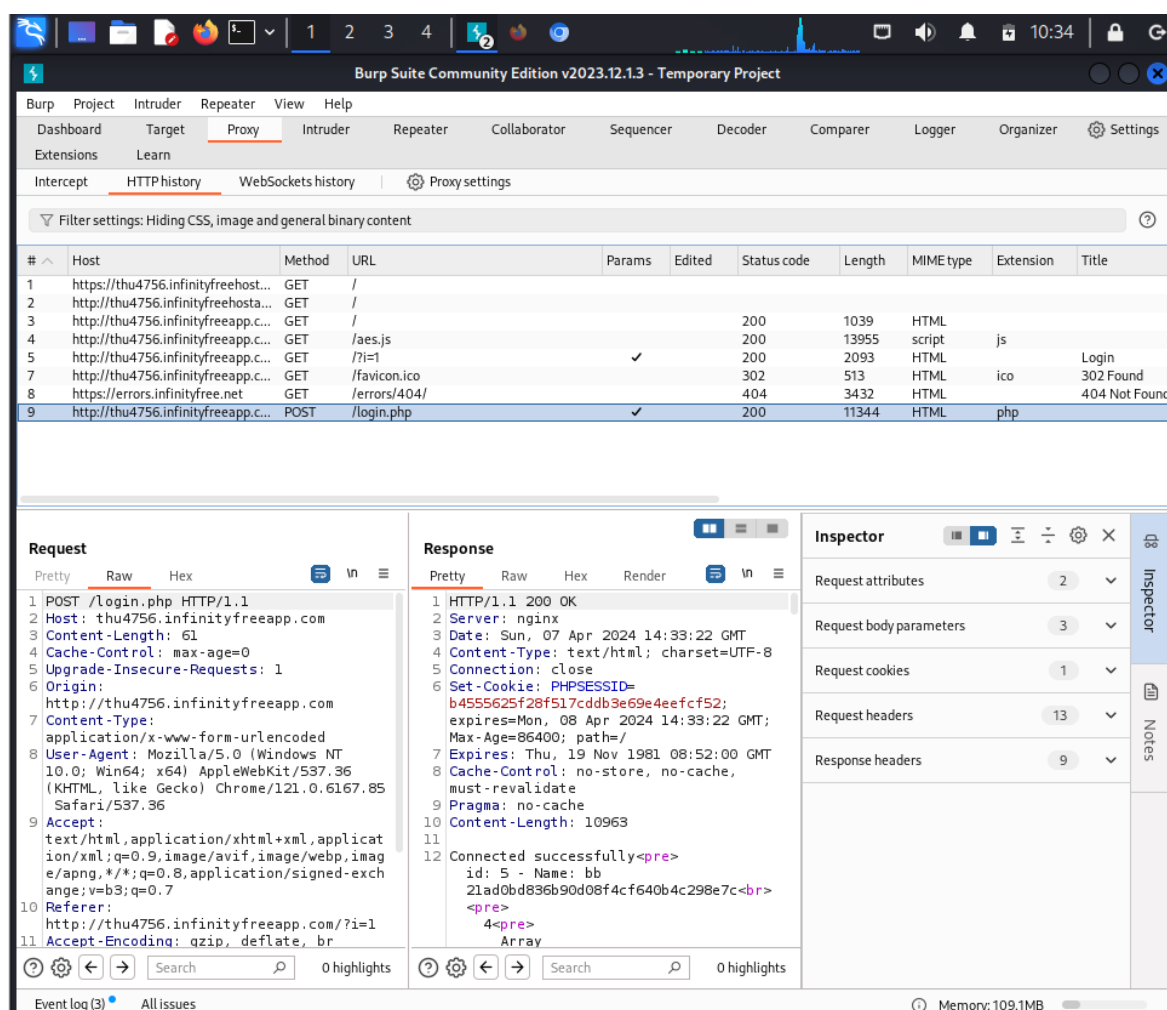
Hình 46: Câu lệnh script được thực thi

Tấn công XSS bằng công cụ BurpSuite

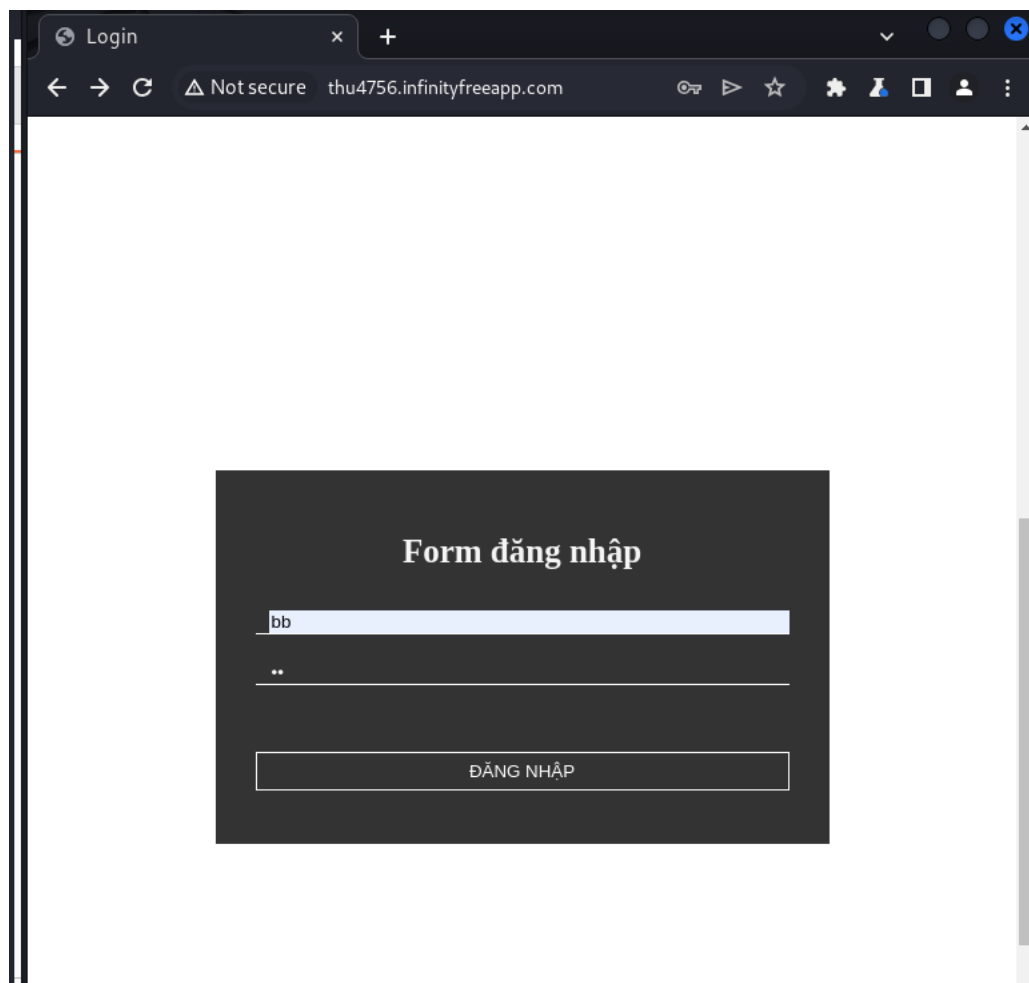
Burp Suite: Công cụ này cho phép kiểm tra và phát hiện lỗ hổng bảo mật trong ứng dụng web và tấn công XSS.

Các bước thực thi:

- Mở công cụ BurpSuite trước khi mở trang website thì mới có thể tấn công XSS.
- Trong quá trình thực thi trang website BurpSuite sẽ ghi nhận được các thông số của trang website ví dụ: cookie,..



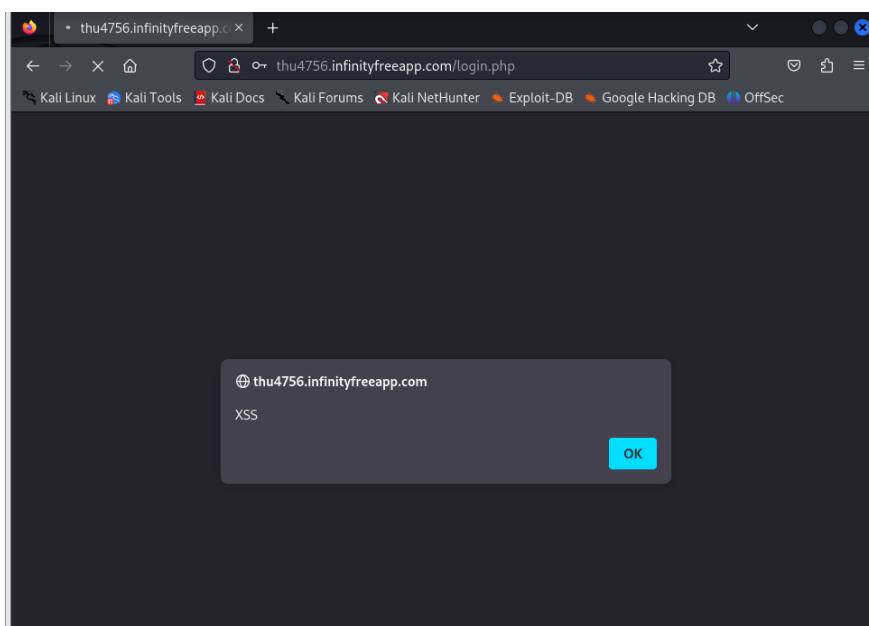
Hình 47: Dùng công cụ BurpSuite để kiểm tra XSS



Hình 48: Login user có trong CSDL

Khi login user có sẵn (đã được đăng kí trong CSDL) thì sẽ hiện ra 1 đoạn script thông báo XSS (như hình bên dưới) điều đó thể hiện kẻ tấn đã chèn 1 mã script để tiến hành tấn công độc hại vào trang web (HTML) trên trình duyệt của người dùng cuối. Và trường hợp bị tấn công XSS là DOM-based XSS.

DOM-based XSS: Loại XSS này xảy ra khi mã độc hại được thực thi trên trình duyệt của người dùng chỉ dựa trên dữ liệu từ phía client. Điều này có thể xảy ra khi mã JavaScript sử dụng dữ liệu từ URL hoặc từ các phần tử HTML trên trang mà không được xử lý đúng cách và hacker sẽ lợi dụng lỗ hổng này để thực hiện các hành vi chiếm dụng tài khoản người dùng hoặc các hành vi trái phép mà không bị truy cứu trách nhiệm.



Hình 49: Kết quả sau khi bị tấn công

CHƯƠNG 3: QUY TRÌNH GIA CỐ HỆ THỐNG GIA CỐ WEBSITE VỚI NHIỀU CÁCH THỨC

1. Sử dụng chứng chỉ SSL

Định nghĩa:

Chứng chỉ SSL (SSL certificate) là một loại tài liệu số được sử dụng để xác minh tính xác thực của một trang web và bảo vệ thông tin giao tiếp trên internet. Chúng là một phần quan trọng của giao thức SSL/TLS (Secure Sockets Layer/Transport Layer Security), giúp mã hóa dữ liệu truyền tải giữa máy khách và máy chủ, đảm bảo tính bí mật và toàn vẹn của thông tin.

Mục tiêu:

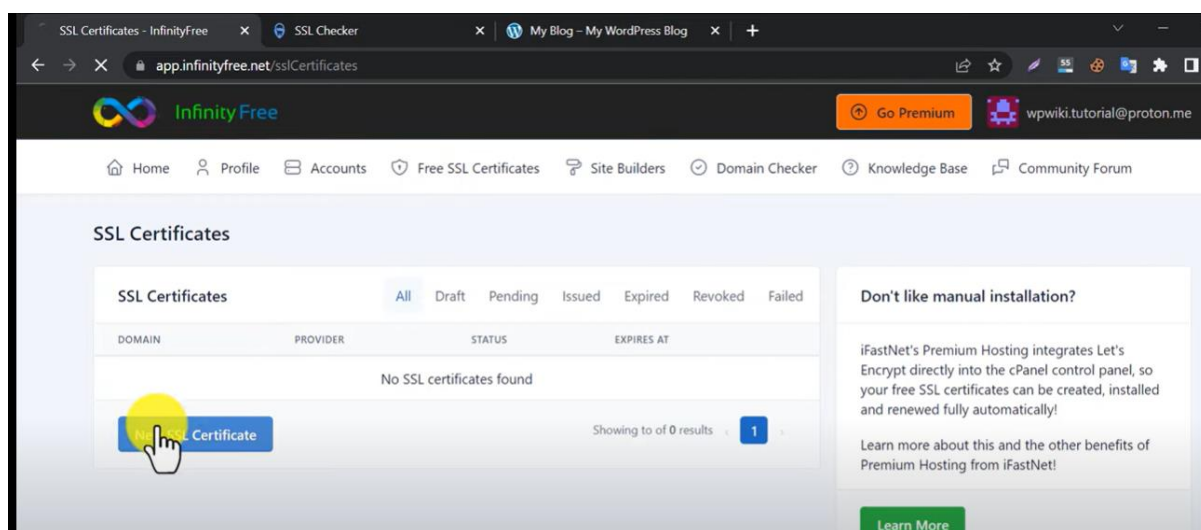
Nhằm khắc phục và hạn chế việc các dữ liệu bị truyền đi trên đường truyền do không được bảo mật và có thể bị bắt trên đường truyền bởi các công cụ có thể là Wireshark và việc xin cấp chứng chỉ SSL (chứng chỉ an toàn website) đã có thể hạn chế được lỗ hổng này. Và sau khi xin chứng chỉ SSL và áp dụng và website của đề tài và nhận được kết quả Wireshark không bắt được gói tin.

Quy trình xin chứng chỉ và quét lại đường truyền trong quá trình đăng ký và đăng nhập bằng công cụ Wireshark.

1. Quá trình xin chứng chỉ

- 1.1. Nhập yêu cầu tạo chứng chỉ SSL
- 1.2. Nhập tên domain muốn cấp chứng chỉ SSL
- 1.3. Chọn các option để cấp chứng chỉ theo option
- 1.4. Hệ thống cấp các thông tin cho domain
- 1.5. Điền các thông tin hệ thống đã cấp cho domain
- 1.6. Hệ thống ghi nhận và tiến hành cấp chứng chỉ
- 1.7. Tiến hành điền các khóa mà hệ thống đã cấp điền vào domain
- 1.8. Trạng thái website được cập nhật
2. Quá trình quét lại đường truyền
- 2.1. Sử dụng công cụ sslshopper để kiểm tra chứng chỉ SSL cho website
3. Quá trình đăng nhập lại để kiểm tra
- 3.1. Sử dụng công cụ wireshark để kiểm tra đường truyền
- 3.2. Tiến hành các thao tác đăng nhập thông thường để kiểm tra
- 3.3. Dừng tiến hành kiểm tra và đọc các gói tin được bắt trên wireshark

Nền tảng sử dụng Infinity có hỗ trợ xin chứng chỉ SSL free với một vài tính năng đơn giản và hợp pháp.



Hình 50: Tạo chứng chỉ SSL

Nhập tên miền đã đăng ký (deploy) với hệ thống trên đường truyền và tạo yêu cầu xin chứng chỉ SSL.

Order new Free SSL Certificate

Enter the domain of the website for which you want an SSL certificate.

Domain Name

thu4756.infinityfreeapp.com

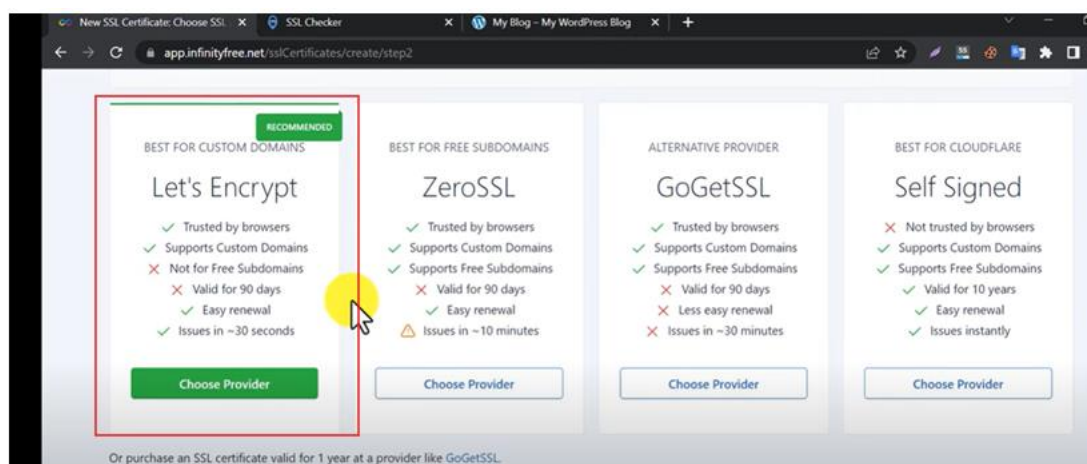
The www. subdomain is automatically included.

⬇ Advanced Options

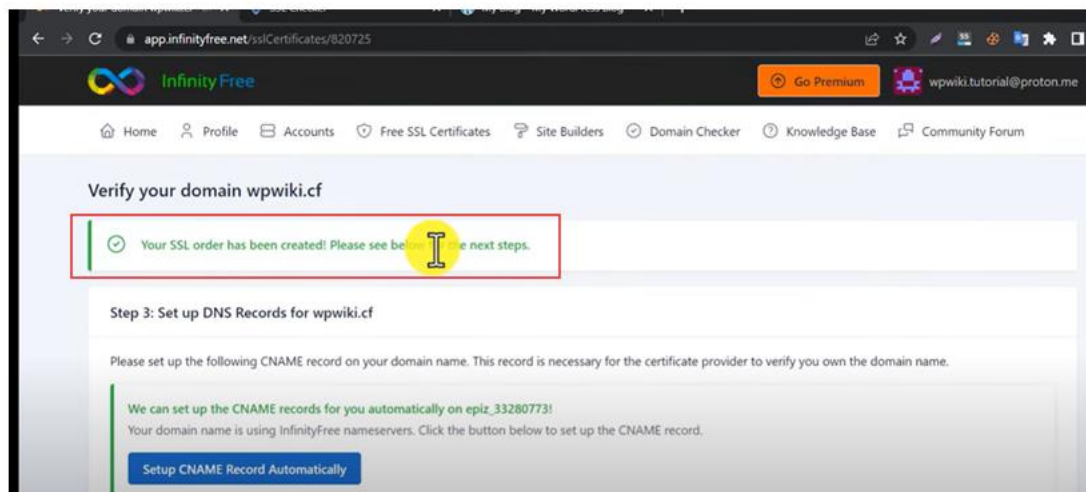
[Back](#) [+ Create Order](#)

Hình 51: Điền tên domain vào

Có các option để lựa chọn và tính phí với nhiều chức năng và ứng dụng kèm theo để có thể theo dõi đơn giản nên thực nghiệm chọn option free và tiến hành các bước kế tiếp.

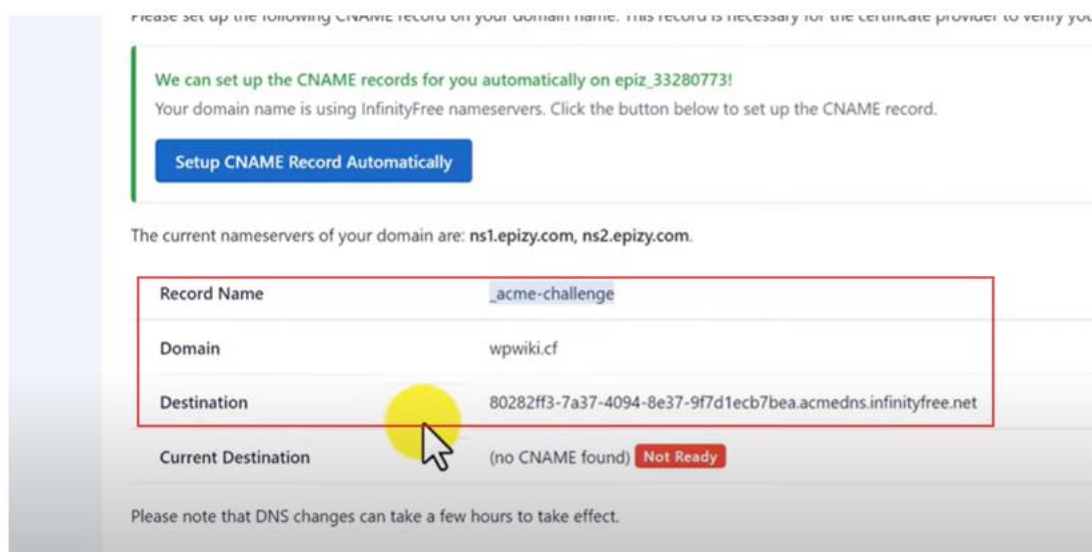
**Hình 52: Chọn option free cho chứng chỉ SSL**

Yêu cầu xin cấp chứng chỉ đã được phê duyệt và tiến hành làm thêm các bước để có thể kích hoạt.



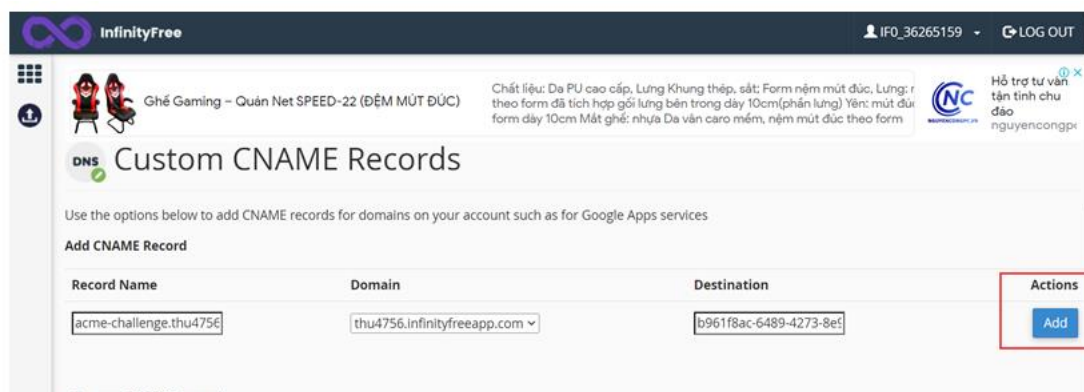
Hình 53: Yêu cầu đã được tạo

Các thông tin về các khóa: tên xác nhận, điểm nhận, và tên miền đã được cung cấp và copy các khóa vào các ô input thông tin để có thể kích hoạt.



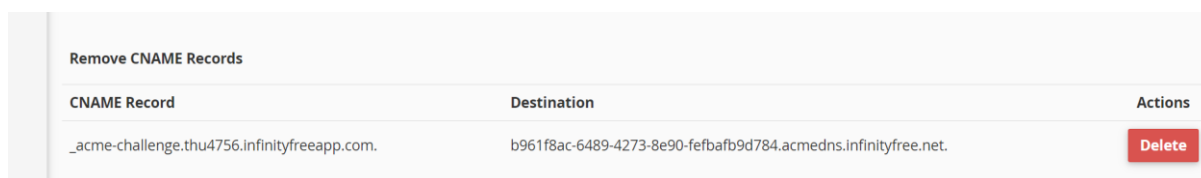
Hình 54: Lưu các thông tin SSL trong lúc tạo

Điền các khóa và chọn Add để chức năng thêm để có thể xác nhận các thông tin dữ liệu được cung cấp đã được thêm vào trang website.



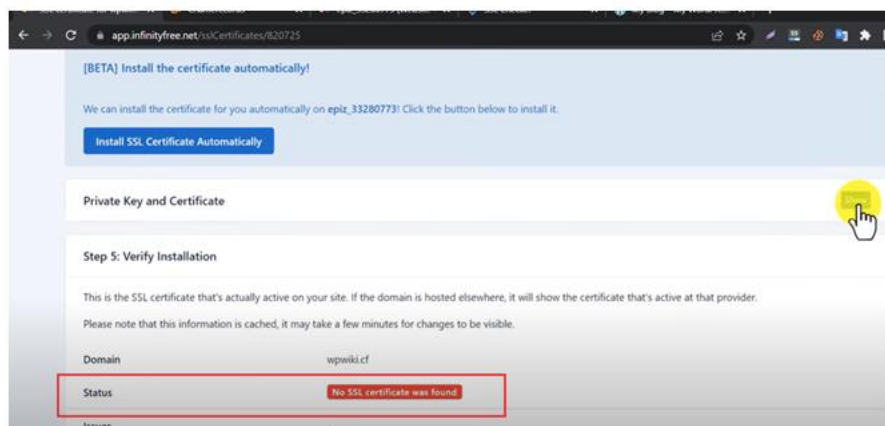
Hình 55: Điền các thông tin SSL trong lúc tạo vào các mục

Các thông tin đã được xác nhận và tiến hành lưu trữ.



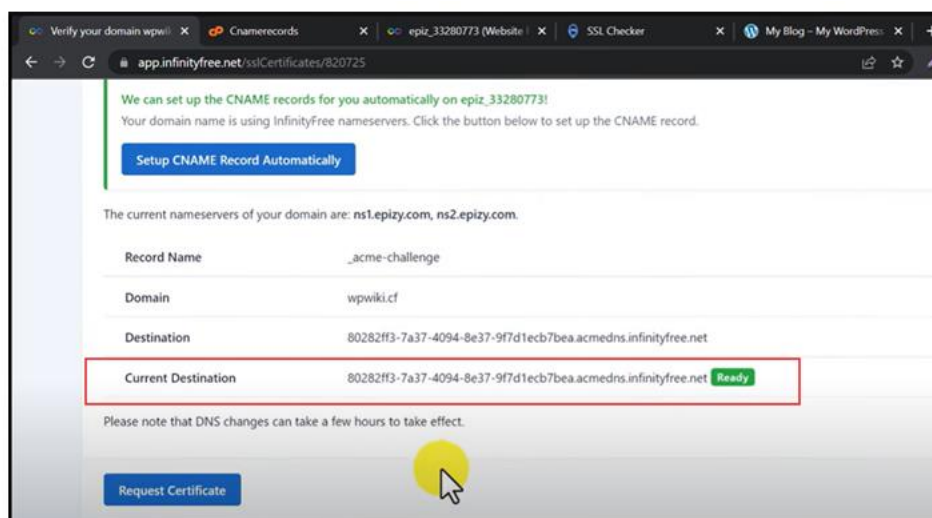
Hình 56: Chọn Add và nhận được kết quả như trên

Chúng chỉ được gửi đi và thời gian cấp chứng chỉ có thể từ 8-12 tiếng. Và được thông báo qua email đã đăng ký.



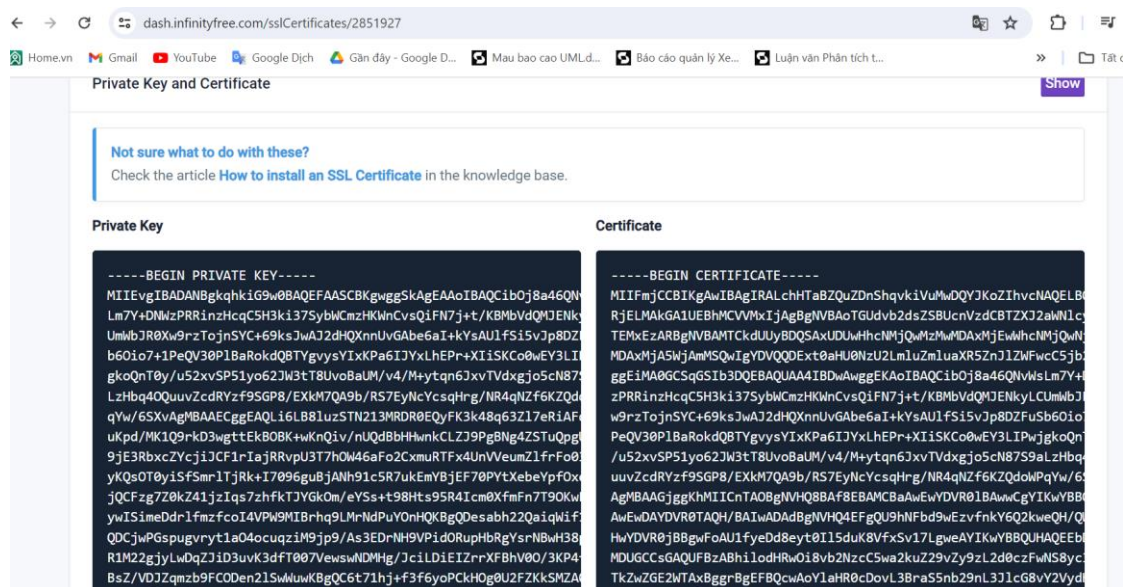
Hình 57: Trạng thái ssl trong lúc đợi chứng chỉ cấp

Sau khi nhận được các thông báo SSL được cấp và đây là trạng thái của web được thể hiện trên nền tảng Infinity sau khi được cấp chứng chỉ.



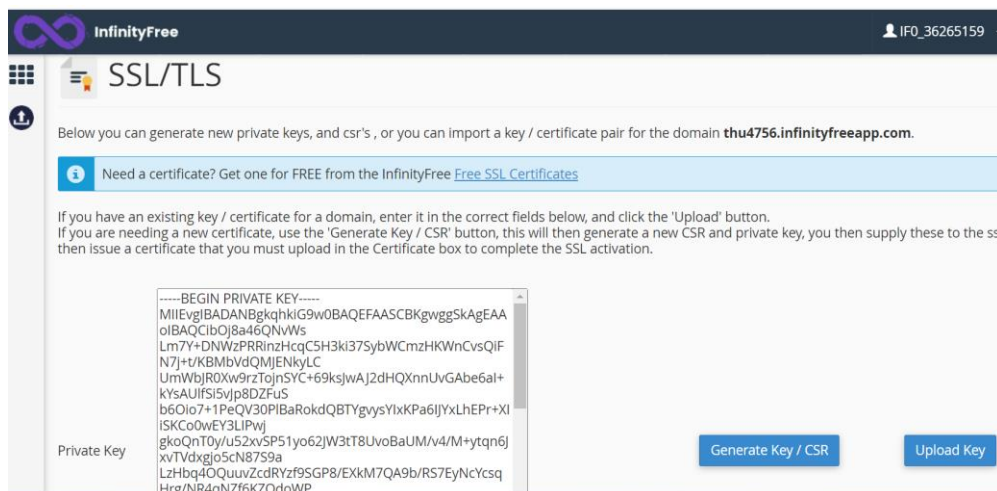
Hình 58: Trạng thái web đang đợi cấp

Sau khi chứng chỉ được cấp và thông báo qua email đăng kí tools thì các khóa public và khóa private được cung cấp.



Hình 59: Các khóa chứng chỉ được cấp

Tiến hành thêm các khóa được cung cấp vào thông tin trang website để có thể chứng thực.



Below you can generate new private keys, and csr's , or you can import a key / certificate pair for the domain **thu4756.infinityfreeapp.com**.

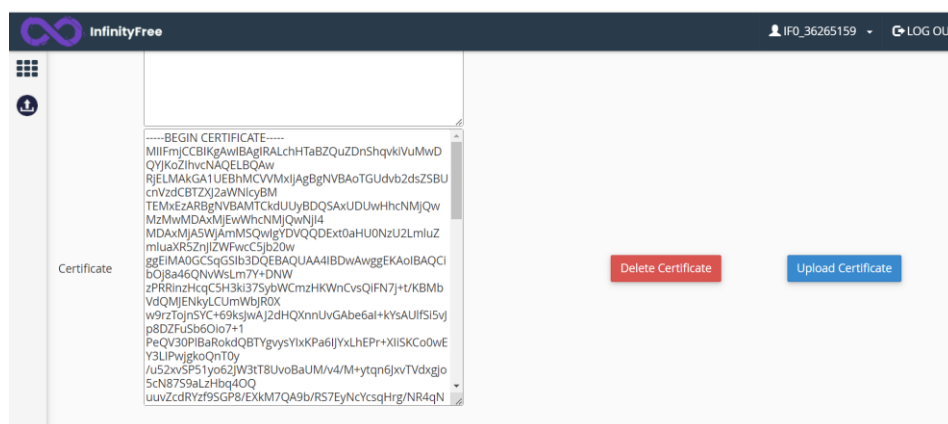
Need a certificate? Get one for FREE from the InfinityFree [Free SSL Certificates](#)

If you have an existing key / certificate for a domain, enter it in the correct fields below, and click the 'Upload' button.
If you are needing a new certificate, use the 'Generate Key / CSR' button, this will then generate a new CSR and private key, you then supply these to the ssl then issue a certificate that you must upload in the Certificate box to complete the SSL activation.

Private Key

```
-----BEGIN PRIVATE KEY-----
MIIEvgIBADANBgkqhkiG9w0BAQEFAASCBKggggSkAgEAA
oIBAQCibOj8a46QNVWw
Lm7Y+DNWzPRRinzHcqC5H3ki37SybWCmzHKWnCvsQIF
N7j+t/KBMbVdQMjENkyLC
UmWbJROXw9rzTojnSYC+69ksjwAJ2dHQXnnUvGAb6aI+
kYsAUfSI5vjp8DZFuS
b6Oio7+1PeQV30PIBaRokdQBTYgvyYixKPa6JJYxLhEPr+XI
ISKCo0wEY3LIPWj
gkoQnT0y/u52xvSP51yo62JW3t8UvoBaUM/v4/M+ytqn6j
xvTVdxgjo5cN87S9a
LzHbq4OQuuvZcdRyzf9SGP8/EXKM7QA9b/RS7EyNcYcsq
Hrg/NR4qNzF6KZQdoWP
-----END PRIVATE KEY-----
```

Generate Key / CSR Upload Key

Hình 60: Điền vào khóa riêng được cấp

-----BEGIN CERTIFICATE-----
MIIFmJCCBikGAWIARALchHTaBZQuZDnShqykiVuMwD
QYjkoZlhcNAQELBQAw
RjELMAkGA1UEBhMCVVMxIjAgBgNVBAoTGUdvb2dsZSUz
cnVzdCBTZXJ2aWVudC8w
TEMxEzARBgNVBAMTCkdUyYyBDQSAxUDUwHhcNMjQw
MzIwMDAwMDAwMjEwWWhcNMjQwMjE0
MDAwMjEwMDAwMjEwWWhcNMjQwMjE0
mluaXR5ZnJlZWFwcC5jb2w
ggEIMAGCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQCI
bOj8a46QNVWwLm7Y+DNW
zPRRinzHcqC5H3ki37SybWCmzHKWnCvsQIFN7j+t/KBMb
VdQMjENkyLCUmWbJROX
w9rzTojnSYC+69ksjwAJ2dHQXnnUvGAb6aI+kYsAUfSI5v
p8DZFuSb6Oio7+1
PeQV30PIBaRokdQBTYgvyYixKPa6JJYxLhEPr+XIISKCo0wE
Y3LIPWjgkoQnT0y
/u52xvSP51yo62JW3t8UvoBaUM/v4/M+ytqn6jxvTVdxgjo
5cN87S9aLzHbq4OQ
uuvZcdRyzf9SGP8/EXKM7QA9b/RS7EyNcYcsqHrg/NR4qN
-----END CERTIFICATE-----

Delete Certificate Upload Certificate

Hình 61: Điền vào chứng chỉ được cấp

Các thông tin về cấu hình website được ghi nhận sau khi điền các thông tin khóa được cấp và đã thể hiện trạng thái kích hoạt.

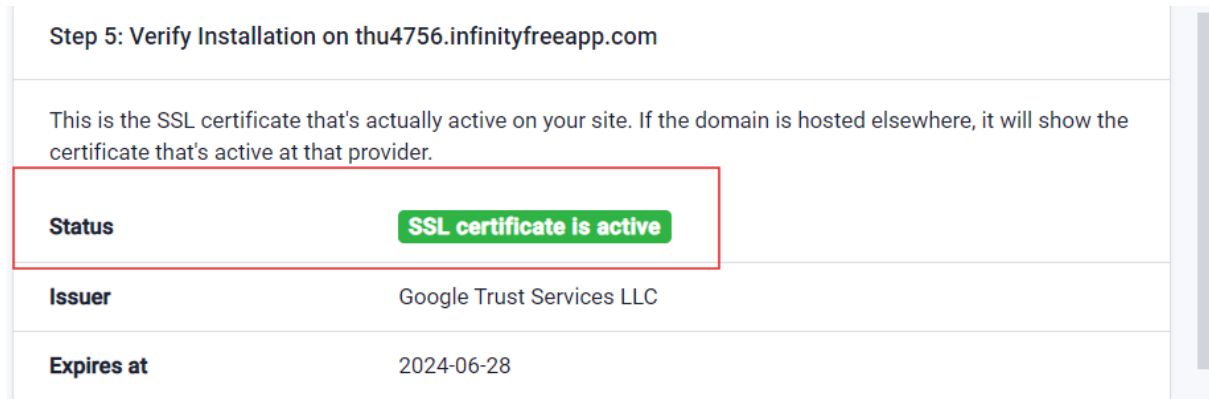
SSL Certificates				All	Pending	Issued	Expired	Revoked	Failed
DOMAIN	PROVIDER	STATUS	EXPIRES AT						
thu4756.infinityfreeapp.com	Google Trust	Issued	2024-06-28						

+ New SSL Certificate

Showing 1 to 1 of 1 results < 1 >

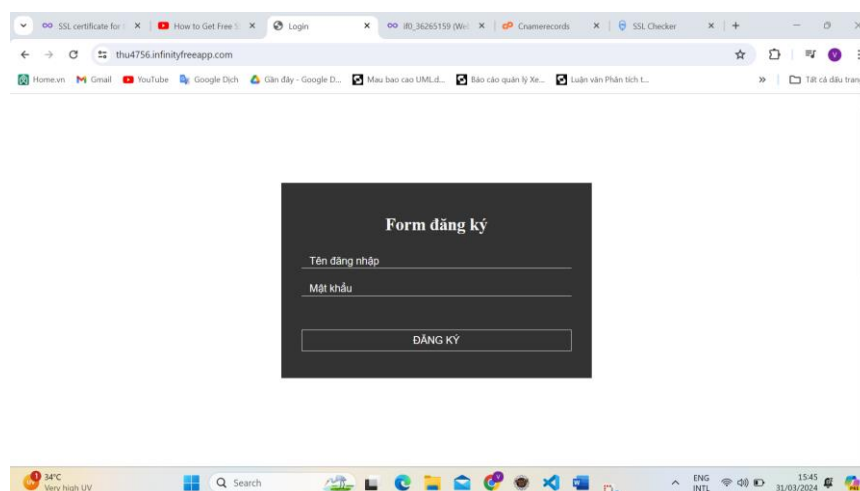
Hình 62: Trạng thái website sau khi được cấp chứng chỉ SSL

Trạng thái thông tin chứng chỉ SSL sau khi điền các khóa được cấp và tiến hành update.



Hình 63: Thông tin chứng chỉ SSL

Trang website đã thể hiện các kết nối an toàn.

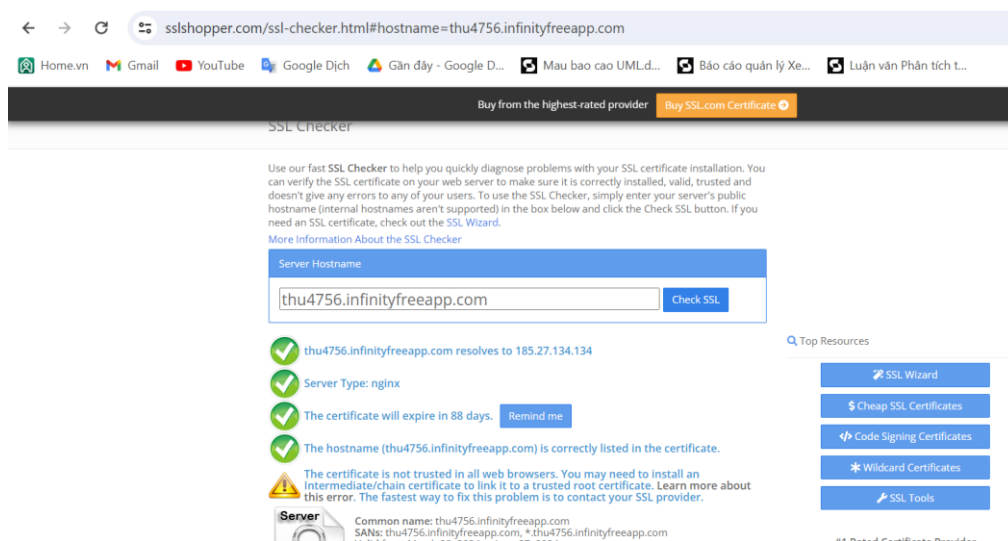


Hình 64: Trang web đã được cấp chứng chỉ và hiện là kết nối an toàn

Nhằm kiểm tra các chứng chỉ mới được cung cấp và thêm vào có hoạt động hay không do đó sử dụng tools sslshopper và nikto để kiểm tra.

Tiến hành nhập domain của trang vào và chọn kiểm tra nhận được kết quả.

Sử dụng công cụ SSLShopper có sẵn để kiểm tra



Hình 65: :Chọn kiểm tra tên miền

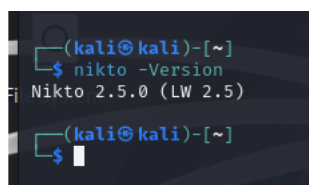
Kết quả trả về sau khi được kiểm tra theo từng dòng.

- Địa chỉ của trang web được cấp từ nền tảng Infinity là 185.27.134.134
- Máy chủ chịu trách nhiệm cho ứng dụng là Nginx (Nginx là một máy chủ web và proxy reverse phổ biến được sử dụng cho các trang web lớn và có tải trọng cao. Nó nổi tiếng với hiệu suất cao và khả năng mở rộng tốt)
- Chứng chỉ SSL đã được áp dụng và có giá trị trong vòng 88 ngày.
- Hostname đã được cấp chứng chỉ trong danh sách.
- Chứng chỉ SSL chỉ áp dụng được trên một số nền tảng nhất định không áp dụng tất cả các ứng dụng web browsers.

Sử dụng công cụ Nikto kiểm tra về SSL

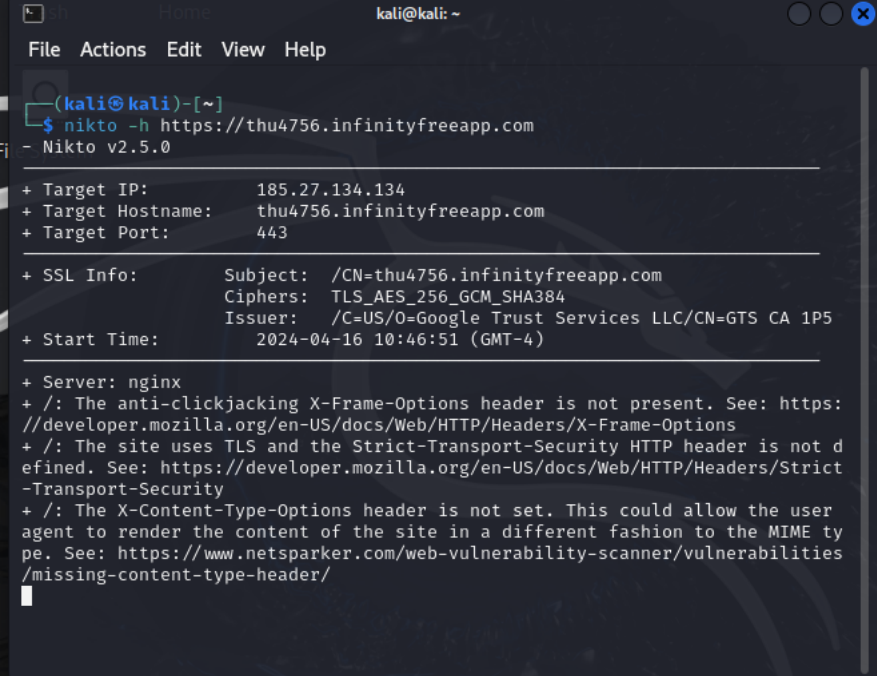
Định nghĩa

Là một công cụ được sử dụng trong kiểm thử bảo mật để phát hiện các lỗ hổng bảo mật trong các máy chủ web.



Hình 66: Kiểm tra phiên bản nikto

Tiến hành thực hiện lệnh nikto -h <https://thu4756.infinityfreeapp.com> để tiến hành kiểm tra các lỗ hổng bảo mật.



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ nikto -h https://thu4756.infinityfreeapp.com  
- Nikto v2.5.0  
  
+ Target IP: 185.27.134.134  
+ Target Hostname: thu4756.infinityfreeapp.com  
+ Target Port: 443  
  
+ SSL Info: Subject: /CN=thu4756.infinityfreeapp.com  
Ciphers: TLS_AES_256_GCM_SHA384  
Issuer: /C=US/O=Google Trust Services LLC/CN=GTS CA 1P5  
+ Start Time: 2024-04-16 10:46:51 (GMT-4)  
  
+ Server: nginx  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

Hình 67: Dùng lệnh kiểm tra trang website

Lệnh "nikto -h [URL]", nó sẽ quét máy chủ web tại URL đã chỉ định và tìm kiếm các lỗ hổng bảo mật, cung cấp thông tin chi tiết về các lỗ hổng đó, bao gồm cả thông tin về phiên bản phần mềm, cấu hình không an toàn, và các vấn đề khác có thể gây nguy hiểm cho hệ thống.

- **Anti-clickjacking X-Frame-Options header không tồn tại:** Điều này có nghĩa là trang web không đặt header X-Frame-Options, một cơ chế bảo vệ chống lại việc nhúng trang web vào trong một iframe không mong muốn.
- **Strict-Transport-Security header không được định nghĩa:** Điều này ngụ ý rằng trang web không thiết lập header Strict-Transport-Security (HSTS). HSTS là một cơ chế bảo mật để đảm bảo rằng trình duyệt sẽ giao tiếp với máy chủ bằng cách sử dụng HTTPS, ngay cả khi người dùng gõ vào địa chỉ HTTP. Thiếu HSTS có thể tạo ra các rủi ro bảo mật liên quan đến tấn công trung gian.
- **X-Content-Type-Options header không được đặt:** Điều này có nghĩa là trang web không đặt header X-Content-Type-Options, một cơ chế bảo vệ chống lại việc trình duyệt hiển thị nội dung của trang web theo cách khác với MIME type.

```
Fi (kali@kali)-[~]
$ nikto -h https://thu4756.infinityfreeapp.com -ssl
- Nikto v2.5.0

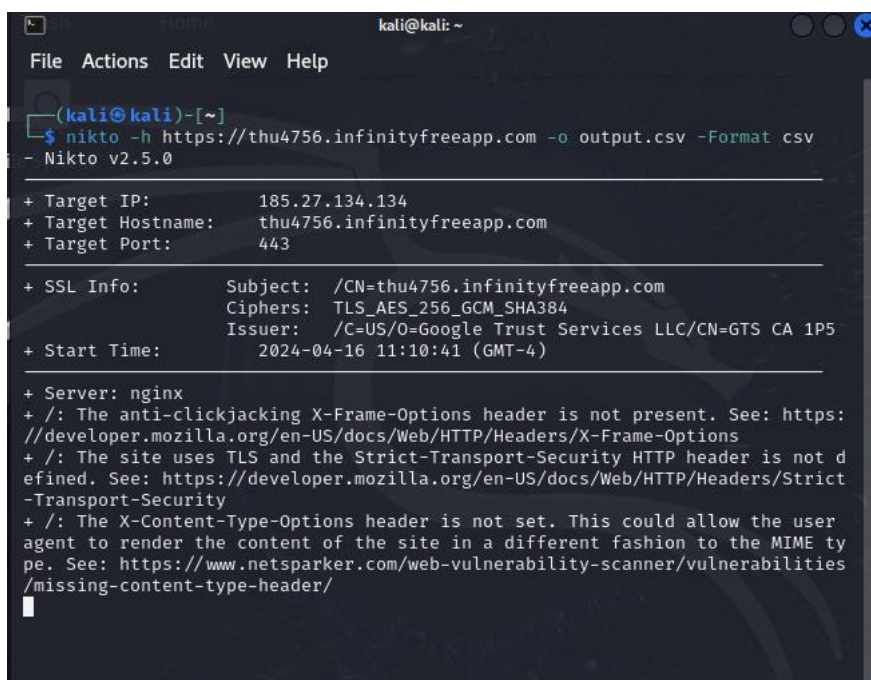
+ Target IP: 185.27.134.134
+ Target Hostname: thu4756.infinityfreeapp.com
+ Target Port: 443

+ SSL Info: Subject: /CN=thu4756.infinityfreeapp.com
            Ciphers: TLS_AES_256_GCM_SHA384
            Issuer: /C=US/O=Google Trust Services LLC/CN=GTS CA 1P5
+ Start Time: 2024-04-16 10:50:00 (GMT-4)

+ Server: nginx
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

Hình 68: Dùng lệnh kiểm tra ssl của trang website

- Lệnh "nikto -h [URL] -ssl" được sử dụng để kiểm tra bảo mật của máy chủ web thông qua kết nối HTTPS (SSL). Khi bạn thêm cờ "-ssl" vào lệnh nikto, nó sẽ chỉ quét các lỗ hổng bảo mật liên quan đến kết nối SSL/TLS trên máy chủ web đã chỉ định.
- Việc này bao gồm việc kiểm tra các cấu hình SSL/TLS của máy chủ, chứng chỉ SSL/TLS được sử dụng, và các vấn đề bảo mật khác liên quan đến việc sử dụng giao thức HTTPS để đảm bảo tính bảo mật và an toàn của dữ liệu truyền qua mạng.
- TLS_AES_256_GCM_SHA384 là một chuẩn mã hóa và thuật toán băm được sử dụng trong quá trình kết nối bảo mật SSL/TLS giữa trình duyệt web và máy chủ web. Khi bạn thấy thông báo này, nó chỉ ra rằng kết nối SSL/TLS giữa trình duyệt và máy chủ sử dụng mã hóa AES với key 256-bit và chế độ hoạt động GCM, cùng với thuật toán băm SHA384 để đảm bảo tính bảo mật và toàn vẹn của dữ liệu truyền qua mạng.
- **TLS_AES_256_GCM** : Đây là thuật toán mã hóa dữ liệu, trong đó AES (Advanced Encryption Standard) với key độ dài 256-bit được sử dụng để mã hóa dữ liệu. GCM (Galois/Counter Mode) là một chế độ hoạt động của AES, cung cấp tính toàn vẹn của dữ liệu và bảo mật chống lại tấn công hiệu suất cao.
- **SHA-384**: Đây là thuật toán băm được sử dụng để tạo ra giá trị băm cho các thông điệp trong quá trình trao đổi khóa và xác thực.

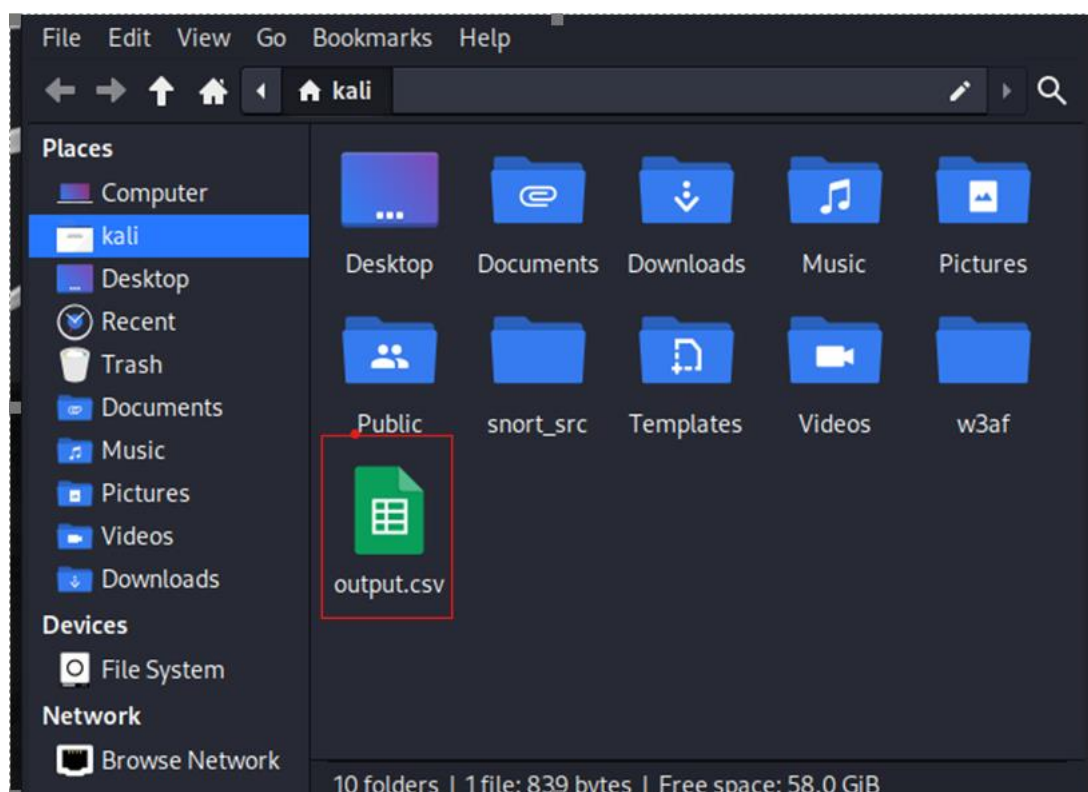


```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)~  
$ nikto -h https://thu4756.infinityfreeapp.com -o output.csv -Format csv  
- Nikto v2.5.0  
  
+ Target IP: 185.27.134.134  
+ Target Hostname: thu4756.infinityfreeapp.com  
+ Target Port: 443  
  
+ SSL Info: Subject: /CN=thu4756.infinityfreeapp.com  
Ciphers: TLS_AES_256_GCM_SHA384  
Issuer: /C=US/O=Google Trust Services LLC/CN=GTS CA 1P5  
+ Start Time: 2024-04-16 11:10:41 (GMT-4)  
  
+ Server: nginx  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

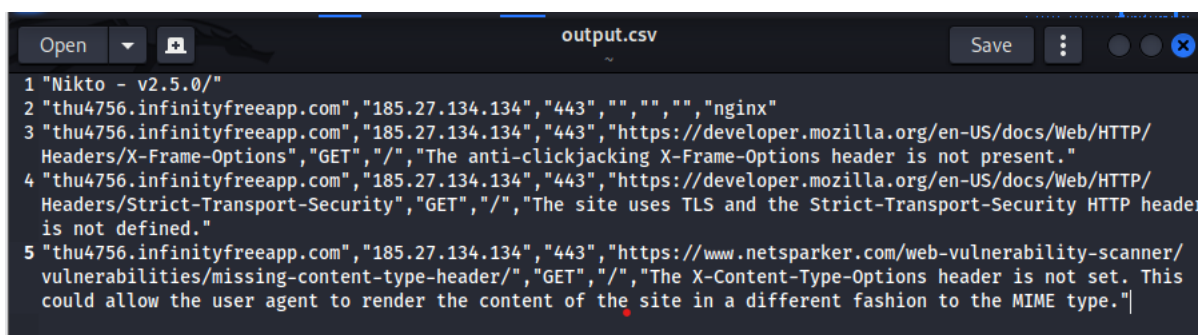
Hình 69: Lệnh lưu trữ các trạng thái

Lệnh "nikto -h [URL] -o [filename]" được sử dụng để chạy công cụ Nikto để quét máy chủ web tại URL đã chỉ định và lưu kết quả của quét vào một tệp CSV có tên bạn chỉ định.

Trong trường hợp này, khi chạy lệnh "nikto -h <https://thu4756.infinityfreeapp.com> -o output.csv", Nikto sẽ quét máy chủ web tại địa chỉ "<https://thu4756.infinityfreeapp.com>" và lưu kết quả của quét vào tệp có tên "output.csv" dưới dạng tệp CSV. Điều này giúp tổ chức và lưu trữ thông tin từ quá trình quét một cách dễ dàng để kiểm tra sau này.



Hình 70: File kết quả được ghi



Hình 71: Nội dung file kết quả

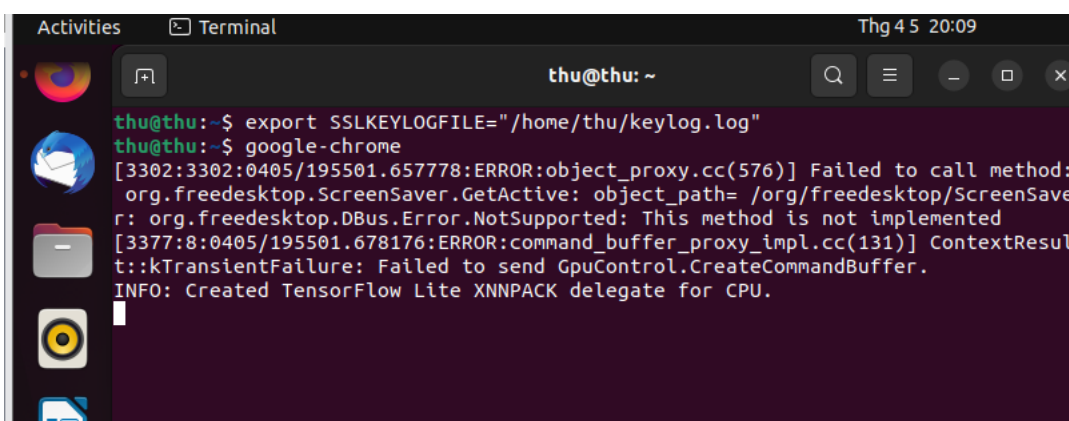
Nội dung ghi của tệp CSV này là kết quả của quá trình quét bảo mật trên máy chủ web tại địa chỉ "thu4756.infinityfreeapp.com" với địa chỉ IP tương ứng là "185.27.134.134" trên cổng 443 (HTTPS).

Tóm lại, tệp CSV này cung cấp một bản tóm tắt về các vấn đề bảo mật được Nikto phát hiện trên máy chủ web tại địa chỉ "thu4756.infinityfreeapp.com", giúp quản trị viên hoặc chuyên gia bảo mật có thể xem và điều chỉnh cấu hình bảo mật để cải thiện tính an toàn của hệ thống. Dưới đây là ý nghĩa của từng cột:

- **Version:** "Nikto - v2.5.0/" là phiên bản của Nikto được sử dụng trong quá trình quét.
- **Host, IP, Port:** Lần lượt là tên miền của máy chủ web, địa chỉ IP của máy chủ, và cổng được sử dụng.
- **URL, Method, Parameter:** Đây là các chi tiết về URL mà Nikto đã truy cập, phương thức HTTP được sử dụng, và các tham số (nếu có) đi kèm với URL.
- **Issue URL:** Đây là URL của tài liệu hoặc nguồn tham khảo mà Nikto đề cập đến khi báo cáo vấn đề bảo mật.
- **Issue Method:** Là phương thức HTTP mà Nikto đã sử dụng để truy cập vào URL được báo cáo.
- **Issue Path:** Đây là đường dẫn của URL mà Nikto đề cập đến khi báo cáo vấn đề bảo mật.
- **Issue Description:** Là mô tả của vấn đề bảo mật được Nikto phát hiện, cung cấp thông tin về lỗi và hậu quả tiềm ẩn, cũng như liên kết tới nguồn tham khảo để tìm hiểu thêm về vấn đề.

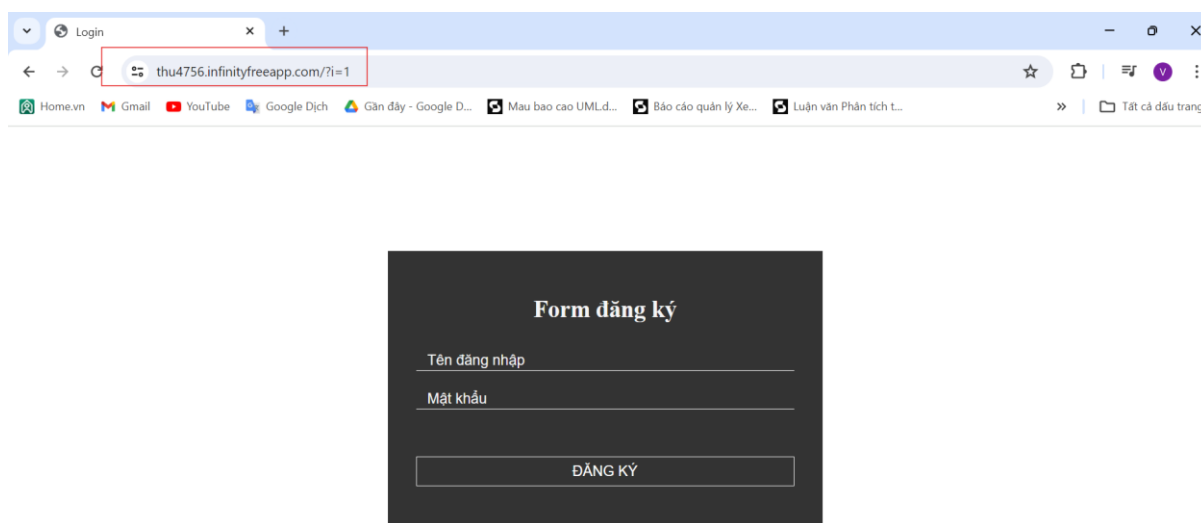
Nhằm kiểm tra tính khả dụng của chứng chỉ SSL tiến hành thực nghiệm bắt gói tin truyền đi trên đường truyền một lần nữa để xem các thông tin nhận được khác biệt như thế nào so với khi chưa có chứng chỉ SSL.

Tiến hành tạo logfile và sử dụng google-chrome để thực thi các tác vụ thông thường trên website.

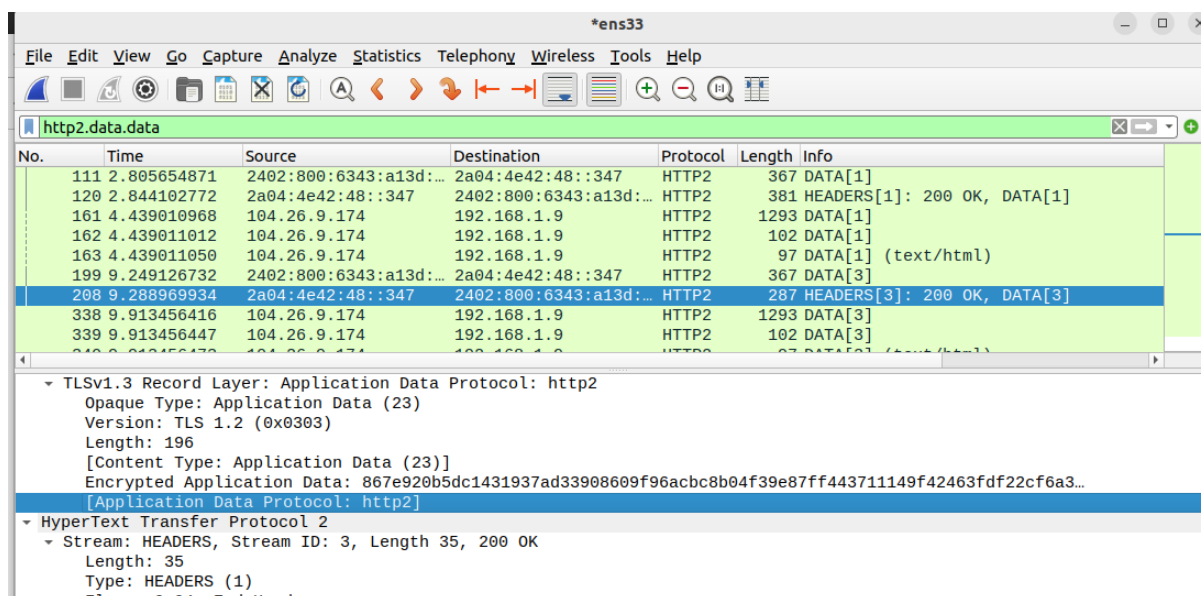


Hình 72: Dùng logfile ghi nhận lại lịch sử ứng dụng

Tải trang web trên ứng dụng google-chrome và xem trên URL trang website đã không còn cảnh báo không bảo mật hoặc truy cập không tin tưởng.

**Hình 73: Tiến hành đăng nhập và đăng ký**

Trang website đã được cấp chứng chỉ SSL free và đạt được các hiệu năng cơ bản của SSL khi thử bắt các gói tin bằng wireshark không còn bị rò rỉ thông tin như khi chưa có chứng chỉ SSL.

**Hình 74: Các dữ liệu không còn bị bắt trên đường truyền**

2. Gia cố tấn công XSS

Nguyên nhân

Lợi dụng các thiếu sót trong quá trình xây dựng website hoặc các sơ sót trong việc truy xuất dữ liệu đầu vào.

Cách phòng chống

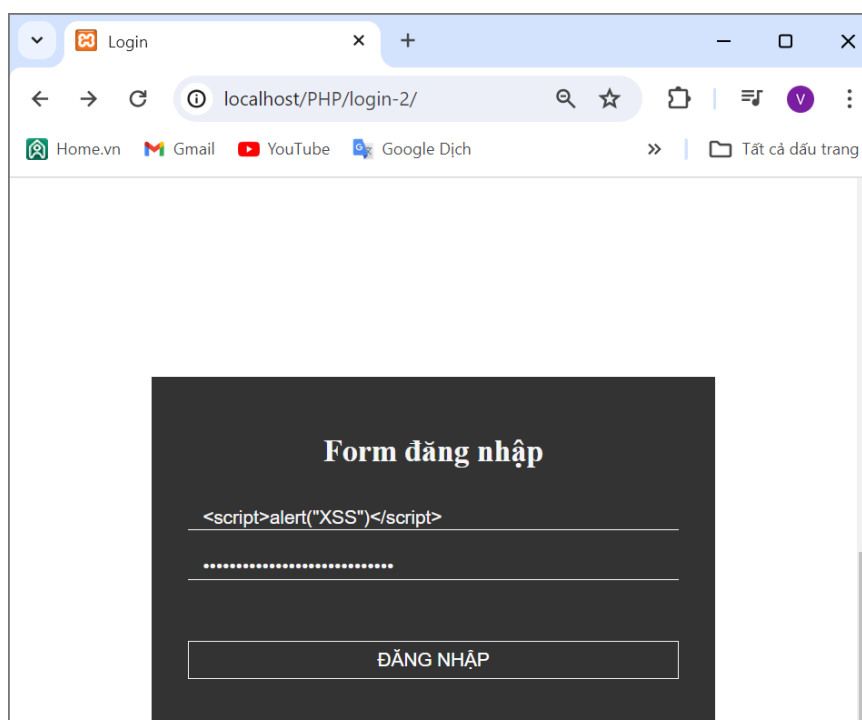
- Kiểm tra và xử lý đúng cách dữ liệu người dùng trước khi chèn vào DOM (mã hóa dữ liệu đầu vào), giới hạn truy cập tài nguyên bên cạnh đó cũng phải kiểm tra các dữ liệu được truy xuất trên web (đăng nhập, đăng ký).
- Sử dụng các framework hoặc thư viện chống XSS có sẵn để xử lý bảo mật.
- Đảm bảo tất cả các phiên bản phần mềm và các thành phần của trang web được cập nhật mới nhất để khắc phục các lỗ hổng bảo mật.
- Dùng tường lửa (firewall) chống lại được các cuộc tấn công XSS đơn giản, ở mức độ chuyên sâu cần sử dụng tường lửa chuyên biệt.

Công cụ hỗ trợ

- ZAP: công cụ hỗ trợ phát hiện quét lỗ hổng, kiểm tra tính bảo mật và giám sát phát hiện tấn công XSS.
- Burp Suite: Công cụ này cho phép kiểm tra và phát hiện lỗ hổng bảo mật trong ứng dụng web và tấn công XSS.

Gia có XSS bằng cách đơn giản nhất kiểm tra các truy xuất đầu vào.

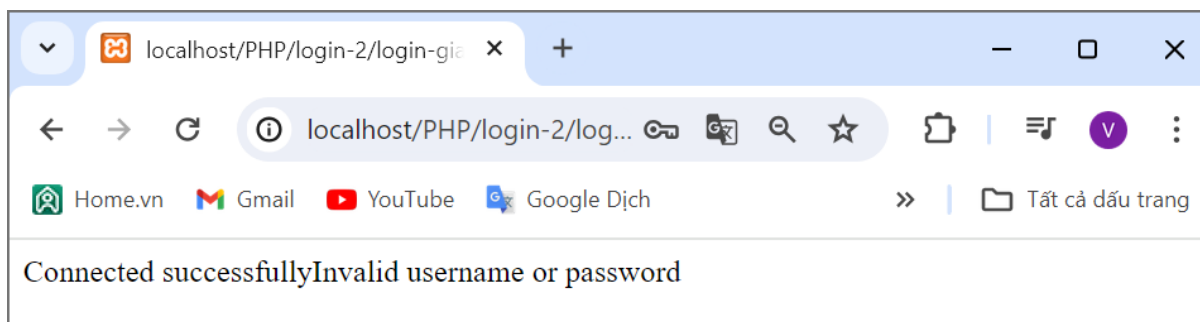
Thực hiện bằng cách chèn đoạn script vào ô input.



Hình 75: Thực thi chèn lệnh script

Kết quả sau khi chèn thực thi đoạn script tấn công.

Đồng thời thể hiện rõ kiểm tra các ký tự truy xuất đầu vào cũng là quá trình quan trọng có thể ngăn chặn các tấn công XSS, SQL.



Hình 76: Kết quả sau khi chèn đoạn script

3. Gia cố lỗ hổng SQL Injection

Nguyên nhân

- Do sự thiếu sót của việc xác định rõ các ký tự đầu vào và chính các lỗ hổng đó đã bị lợi dụng để tấn công dữ liệu mà người dùng nhập vào trường input và để người dùng có thể chèn các câu lệnh để đăng nhập vào hệ thống.
- Chúng ta có thể gia cố bằng cách lọc các ký tự từ các cột trong CSDL rõ ràng hơn từ các trường input để xác nhận người dùng chính xác hơn.
- Lỗ hổng chưa được gia cố: có thể dẫn đến việc chỉ lấy từ dữ liệu từ các ô input sau đó tiến hành so sánh với CSDL đôi khi sẽ dẫn đến việc chỉ đúng với 1 dòng dữ liệu vẫn có thể đăng nhập thành công.

```
$sql = "SELECT * FROM users WHERE fullname='$username' AND password='$hashpassword'";
$result = $conn->query($sql);

if ($result->num_rows > 0) {
    // output data of each row
    while($row = $result->fetch_assoc()) {
        echo "<pre>";
        echo "id: " . $row["id"]. " - Name: " . $row["fullname"]. " " . $row["password"]. "<br>";
        $_SESSION['username']=$username;
        $_SESSION['password']=$password;
    }
}
```

Hình 77: Dữ liệu các cột trong CSDL chưa được kiểm tra

Tiến hành gia cố bằng cách kiểm tra các dữ liệu đầu vào sau đó so sánh với dữ liệu lấy từ CSDL và đúng cả hai phần dữ liệu mới có thể đăng nhập thành công.

```

// tạo câu lệnh select
$stmt = $conn->prepare("SELECT * FROM users WHERE fullname=? AND password=?");
// liên kết với câu lệnh
$stmt->bind_param("ss", $username, $password);
// thực thi câu lệnh
$stmt->execute();
// lấy tập kết quả
$result = $stmt->get_result();
// kiểm tra xem hàng được trả về
if ($result->num_rows > 0) {
    //lấy dữ liệu người dùng
    $row = $result->fetch_assoc();
    // lưu trữ dữ liệu vào các biến
    $_SESSION['username'] = $row['fullname'];
    $_SESSION['password'] = $row['password'];
    // chuyển trang
    header('Location: home.php');
    exit();
} else {
    echo "Invalid username or password";
}

```

Hình 78: Kiểm tra các cột trong CSDL

Form đăng nhập

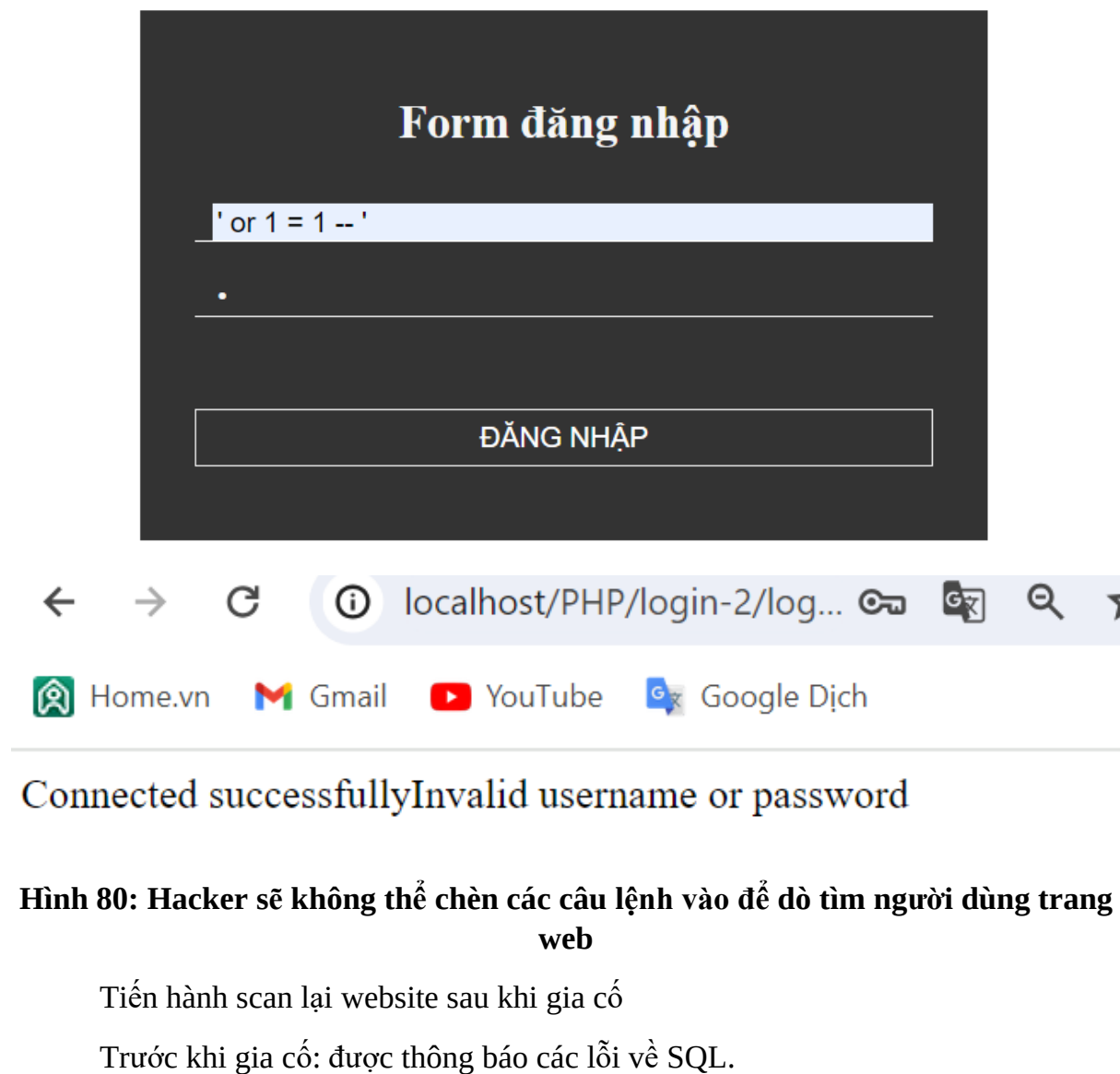
.

localhost/PHP/login-2/log...

Home.vn Gmail YouTube Google Dịch

Connected successfullyInvalid username or password

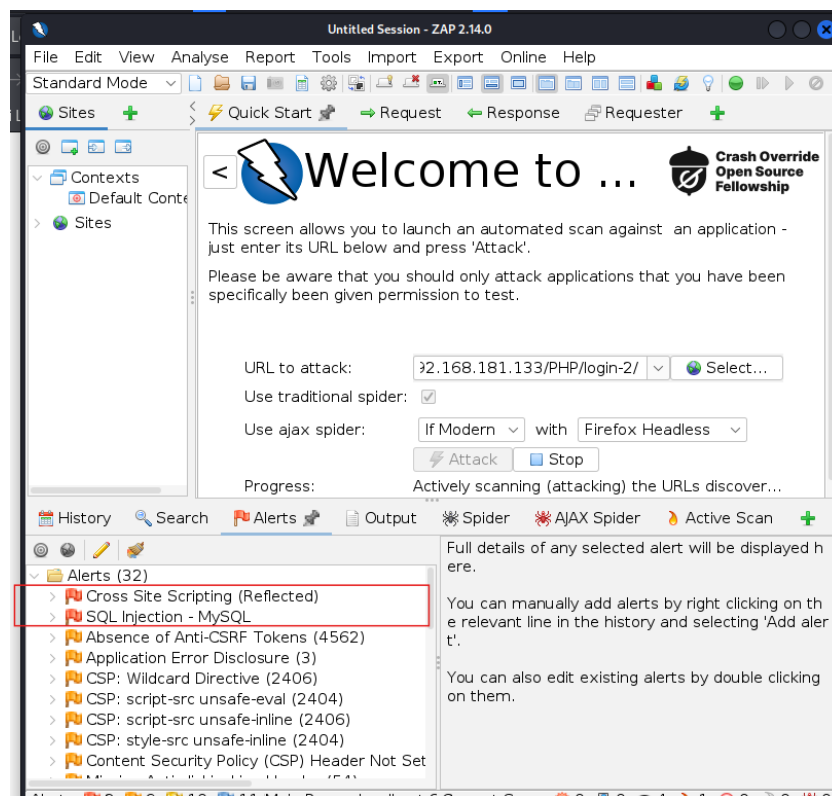
Hình 79: Hacker sẽ không thể chèn các câu lệnh vào để tấn công trang web



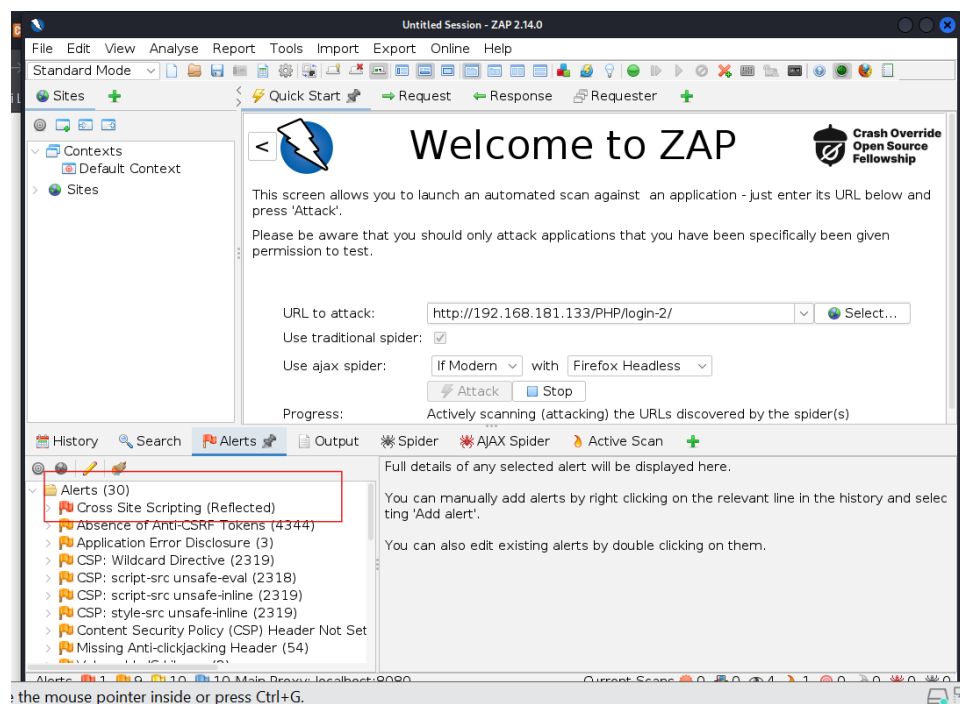
Hình 80: Hacker sẽ không thể chèn các câu lệnh vào để dò tìm người dùng trang web

Tiến hành scan lại website sau khi gia cố

Trước khi gia cố: được thông báo các lỗi về SQL.

**Hình 81: Trước khi gia cố**

Tiến hành web lại 1 lần nữa thông báo không còn thông báo lỗi SQL.

**Hình 82: Sau khi gia cố**

Kết luận:

- Với các loại tấn công trên có thể được gia cố cũng như hạn chế các tổn thất từ việc kiểm định từ đầu vào (các ô input) cũng như nhờ vào các chứng chỉ được kiểm định và cấp phép.
- Để có thể có quản trị, theo dõi tốt nhất các trạng thái của web thì bên cạnh việc gia cố thì việc theo dõi, quan sát, theo vết, đánh giá, kiểm tra các thao tác, thay đổi được thực thi trên ứng dụng cũng rất quan trọng.
- Để có thể thực hiện các việc theo dõi, ghi nhận các thông số cũng như các quá trình thao tác được thực thi thì nên sử dụng các công cụ theo dõi.

CHƯƠNG 4: THỰC HIỆN CÁC CÔNG CỤ THEO DÕI, LƯU TRỮ CÁC TÁC VỤ ĐƯỢC THỰC THI

1. Sử dụng công cụ fail2ban

Định nghĩa:

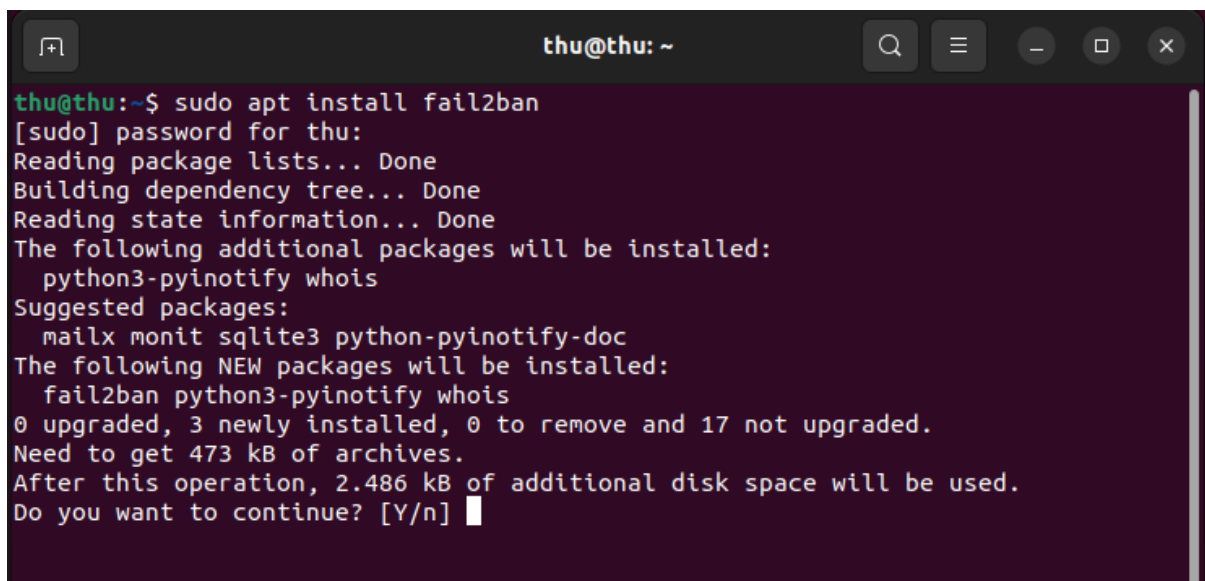
Fail2ban là một công cụ phòng ngừa xâm nhập được sử dụng phổ biến trên các hệ thống Linux để bảo vệ khỏi các cuộc tấn công Brute-force và các loại tấn công khác liên quan đến việc thử và lỗi đăng nhập.

Cách hoạt động của fail2ban như sau:

- **Giám sát logs:** Fail2ban theo dõi các tập tin log của các ứng dụng như SSH, Apache, và các dịch vụ khác để phát hiện các mẫu hoạt động đáng ngờ, chẳng hạn như nhiều lần thử đăng nhập không thành công.
- **Phát hiện mẫu đáng ngờ:** Khi fail2ban phát hiện các mẫu đáng ngờ, nó sẽ áp dụng các quy tắc được cấu hình để xác định liệu hành vi đó có phải là một cuộc tấn công hay không. Thực thi biện pháp phòng ngừa: Nếu một hành vi bị nghi ngờ được phát hiện, fail2ban sẽ thực thi các biện pháp phòng ngừa, chẳng hạn như chặn địa chỉ IP của người dùng đó trong một khoảng thời gian nhất định.
- **Ghi lại và báo cáo:** Fail2ban ghi lại các sự kiện quan trọng và cung cấp báo cáo về các hoạt động xâm nhập cố gắng để quản trị viên có thể kiểm tra và phản ứng phù hợp.

Mục tiêu:

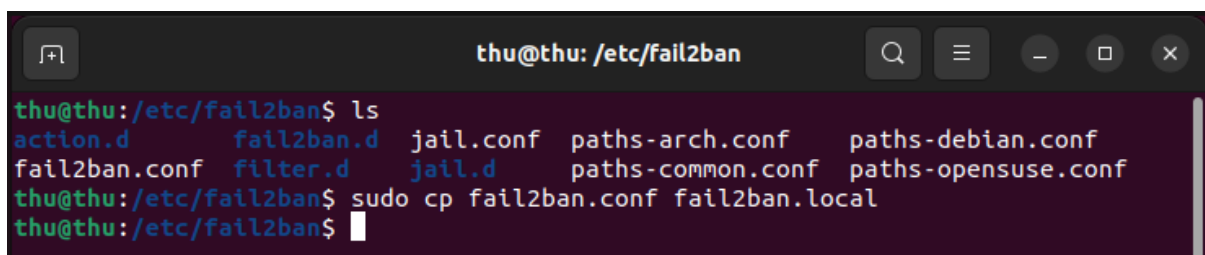
Fail2ban là một công cụ mạnh mẽ giúp nâng cao bảo mật hệ thống Linux bằng cách giảm thiểu rủi ro từ các cuộc tấn công Brute-force và các hành vi không mong muốn khác.

A terminal window titled 'thu@thu: ~' showing the command 'sudo apt install fail2ban'. The output indicates that several additional packages (python3-pyinotify, whois) will be installed along with fail2ban. It also shows the disk space requirements and asks for confirmation to continue.

```
thu@thu:~$ sudo apt install fail2ban
[sudo] password for thu:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  python3-pyinotify whois
Suggested packages:
  mailx monit sqlite3 python-pyinotify-doc
The following NEW packages will be installed:
  fail2ban python3-pyinotify whois
0 upgraded, 3 newly installed, 0 to remove and 17 not upgraded.
Need to get 473 kB of archives.
After this operation, 2.486 kB of additional disk space will be used.
Do you want to continue? [Y/n]
```

Hình 83: Tải công cụ fail2ban

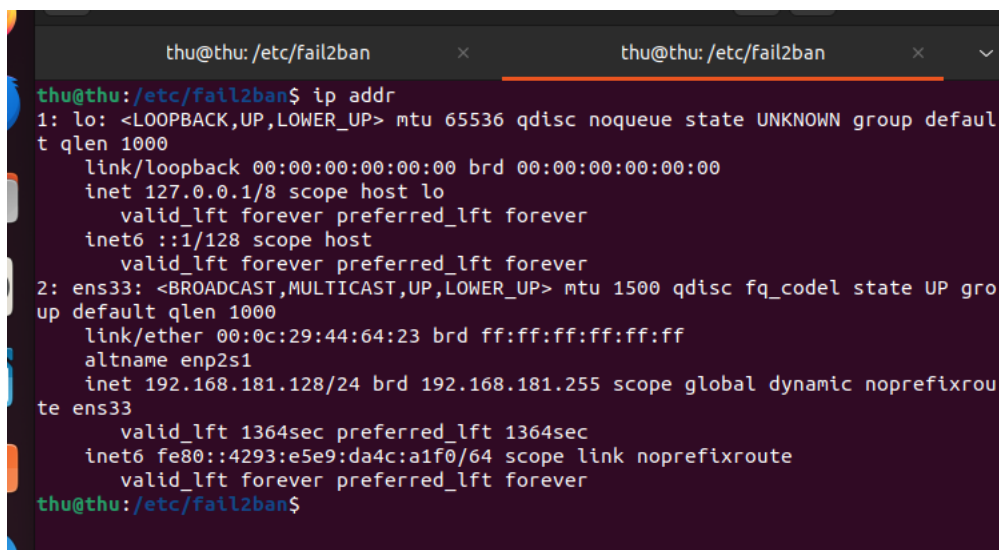
Copy file gốc fail2ban.conf thành fail2ban.local

A terminal window titled 'thu@thu: /etc/fail2ban' showing the command 'ls' and 'sudo cp fail2ban.conf fail2ban.local'. The output of 'ls' lists various configuration files in the directory.

```
thu@thu:/etc/fail2ban$ ls
action.d      fail2ban.d    jail.conf     paths-arch.conf  paths-debian.conf
fail2ban.conf filter.d      jail.d        paths-common.conf paths-opensuse.conf
thu@thu:/etc/fail2ban$ sudo cp fail2ban.conf fail2ban.local
thu@thu:/etc/fail2ban$
```

Hình 84: Copy file

Xem địa chỉ localhost của máy ubuntu.



```
thu@thu: /etc/fail2ban$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:44:64:23 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.181.128/24 brd 192.168.181.255 scope global dynamic noprefixroute ens33
        valid_lft 1364sec preferred_lft 1364sec
    inet6 fe80::4293:e5e9:da4c:a1f0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
thu@thu: /etc/fail2ban$
```

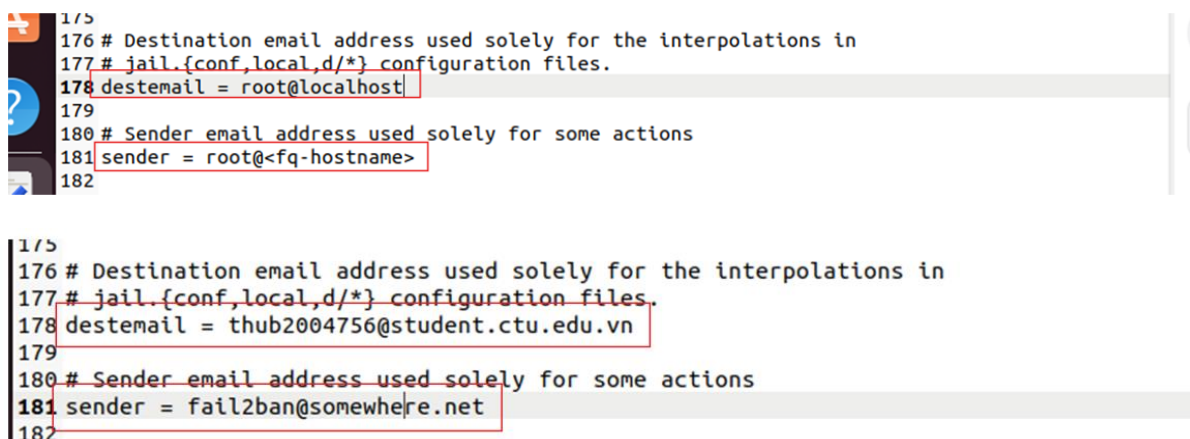
Hình 85: Địa chỉ ip của máy ubuntu

Thêm các địa chỉ cho cấu hình để fail2ban bỏ qua không chặn bởi công cụ với lý do đảm bảo an toàn cho máy tính của bạn.

```
91 # "ignoreip" can be a list of IP addresses, CIDR masks or DNS hosts. Fail2ban
92 # will not ban a host which matches an address in this list. Several addresses
93 # can be defined using space (and/or comma) separator.
94 ignoreip = 127.0.0.1/8 ::1 192.168.181.0/24
95
96 # External command that will take an tagged arguments to ignore, e.g. <ip>,
97 # and return true if the IP is to be ignored. False otherwise.
```

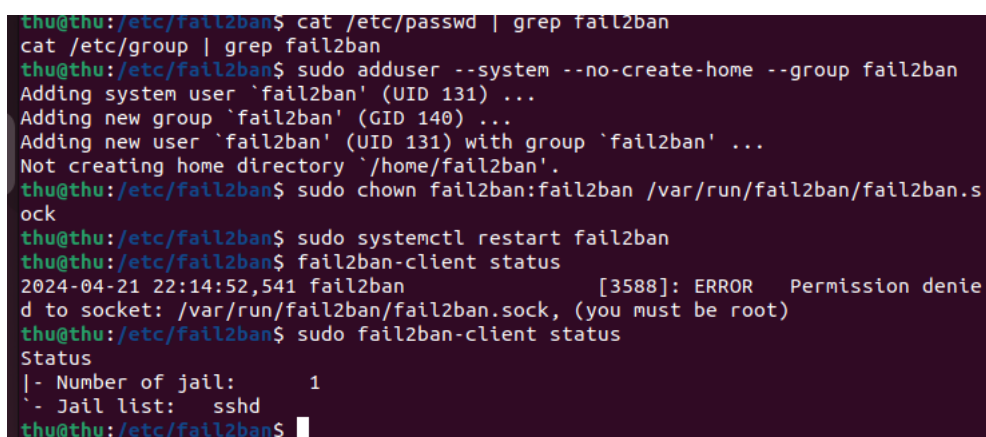
Hình 86: Cấu hình

- Thay đổi email đích (destemail) gửi thông điệp khi có 1 địa chỉ IP đăng nhập nhiều lần nhưng không thành công và bị block và thay đổi thành email của chủ server.
- Thay đổi địa chỉ email sẽ nhận thông báo khi có sự cảnh báo là email của hệ thống fail2ban@somewhere.net (bắt buộc).



Hình 87: Thay đổi cấu hình

Tạo người dùng, cấp quyền fail2ban và thực thi lệnh khởi động chương trình fail2ban.



Hình 88: Kết quả thu được

Kết quả thu được hệ thống khởi động với việc theo dõi SSH (SSHD) ghi nhận các login từ xa từ máy chủ nếu có.

2. Sử dụng công cụ Snort

Định nghĩa:

Snort là một công cụ mã nguồn mở và một hệ thống phát hiện xâm nhập (IDS - Intrusion Detection System) và ngăn chặn xâm nhập (IPS - Intrusion Prevention System) được sử dụng rộng rãi trên hệ thống mạng để phát hiện và ngăn chặn các cuộc tấn công mạng.

Mục đích:

- Để hạn chế và phát hiện từ sớm các dấu hiệu tấn công DDOS sử dụng công cụ Snort. Do tấn công DDOS không thể phòng chống chỉ có thể hạn chế sự tổn thất sau khi bị tấn công.
- Do tấn công DDOS là tấn công có chủ đích (gây tổn thất về danh tiếng hoặc doanh thu cho nạn nhân) và tấn công mang tính diện rộng (ở nhiều máy tính bị nhiễm mã độc, các máy botnet và từ nhiều quốc gia).
- Do đó, phải xây dựng 1 máy chủ với sức chịu đựng và sức xử lý lớn đồng thời kiểm tra logfile thường xuyên hoặc sử dụng các công cụ theo dõi logfile thường xuyên (Snort,...) nhằm phát hiện và khắc phục trước khi cuộc tấn công diễn ra nhằm hạn chế tổn thất ở mức tối đa.

Sử dụng công cụ Snort để giám sát truy cập của máy.

```
thu@thu:~$ sudo apt install snort -y
```

Hình 89: Tải công cụ Snort trên ubuntu

Do ứng dụng snort phải luôn luôn được hoạt động nhằm có thể quan sát các hoạt động của máy tính và để có thể phát hiện tấn công mạng trong một mạng máy tính nên cấu hình về dung lượng ổ đĩa có thể sẽ tăng lên nếu được lưu giữ logfile liên tục và để có thể giải quyết được vấn đề về dung lượng cần phải xóa các ứng dụng không sử dụng để có thể giải phóng dung lượng.

```
thu@thu:~$ sudo apt autoremove
```

Hình 90: Xóa các công cụ không sử dụng

Tiến hành download snort

```
thu@thu:~$ wget https://www.snort.org/rules/community -O ~/community.tar.gz
--2024-04-08 08:00:21-- https://www.snort.org/rules/community
Resolving www.snort.org (www.snort.org)... 104.19.222.12, 104.19.221.12, 2606:47
00::6813:de0c, ...
Connecting to www.snort.org (www.snort.org)|104.19.222.12|:443... connected.
HTTP request sent, awaiting response...
```

Hình 91: Download công cụ gói tin Snort

```
libdaq
thu@thu:~$ sudo tar -xvf ~/community.tar.gz -C ~/
community-rules/
community-rules/community.rules
community-rules/VRT-License.txt
community-rules/LICENSE
community-rules/AUTHORS
community-rules/snort.conf
community-rules/sid-msg.map
thu@thu:~$
```

Hình 92: Tiến hành giải nén

Copy các tệp tin ở thư mục community-rules sang thư mục etc/snort/rules

```
thu@thu:~$ ls
community-rules      libdaq
community.tar.gz     Music
Desktop             Pictures
Documents           Public
Downloads           snap
dtdm                snort
google-chrome-stable_current_amd64.deb  snort3
gperftools-2.9.1     snort-source-files
gperftools-2.9.1.tar.gz  Templates
keylog.log           Videos
thu@thu:~$ sudo cp ~/community-rules/* /etc/snort/rules
thu@thu:~$
```

Hình 93: Dùng lệnh copy

Dùng lệnh ls để xem các tệp tin, thư mục đã được sao chép

```
thu@thu:~$ ls /etc/snort/rules
attack-responses.rules  community-web-dos.rules  policy.rules
AUTHORS                 community-web-iis.rules  pop2.rules
backdoor.rules          community-web-misc.rules  pop3.rules
bad-traffic.rules       community-web-php.rules  porn.rules
chat.rules              ddos.rules              rpc.rules
community-bot.rules     deleted.rules           rservices.rules
community-deleted.rules dns.rules               scan.rules
community-dos.rules     dos.rules               shellcode.rules
community-exploit.rules experimental.rules      sid-msg.map
community-ftp.rules     exploit.rules           smtp.rules
community-game.rules    finger.rules            snmp.rules
community-icmp.rules    ftp.rules              snort.conf
community-imap.rules    icmp-info.rules        sql.rules
community-inappropriate.rules  icmp.rules            telnet.rules
community-mail-client.rules  imap.rules            tftp.rules
community-misc.rules       info.rules             virus.rules
community-nntp.rules      iptables               VRT-License.txt
community-oracle.rules    LICENSE                web-attacks.rules
community-policy.rules    local.rules            web-cgi.rules
community.rules           misc.rules             web-client.rules
community-sip.rules       multimedia.rules       web-coldfusion.rules
community-smtp.rules      mysql.rules            web-frontpage.rules
community-sql-injection.rules  netbios.rules        web-iis.rules
community-virus.rules     nntp.rules            web-misc.rules
community-web-attacks.rules  oracle.rules          web-php.rules
community-web-cgi.rules    other-ids.rules       x11.rules
community-web-client.rules  p2p.rules
thu@thu:~$
```

Hình 94: Liệt kê các tệp đã được copy

Nhằm đảm bảo cho việc thực hiện tiến hành khởi động ứng dụng sử dụng các câu lệnh đều dùng câu lệnh sudo.

Khởi động chương trình trước khi thực thi hệ thống.

```

thu@thu:~$ sudo snort -T -c /etc/snort/snort.conf
Running in Test mode

--== Initializing Snort ==--
Initializing Output Plugins!
Initializing Preprocessors!
Initializing Plug-ins!
Parsing Rules file "/etc/snort/snort.conf"
PortVar 'HTTP_PORTS' defined : [ 80:81 311 383 591 593 901 1220 1414 1741 1830
2301 2381 2809 3037 3128 3702 4343 4848 5250 6988 7000:7001 7144:7145 7510 7777
7779 8000 8008 8014 8028 8080 8085 8088 8090 8118 8123 8180:8181 8243 8280 8300
8800 8888 8899 9000 9060 9080 9090:9091 9443 9999 11371 34443:34444 41080 50002
55555 ]
PortVar 'SHELLCODE_PORTS' defined : [ 0:79 81:65535 ]
PortVar 'ORACLE_PORTS' defined : [ 1024:65535 ]
PortVar 'SSH_PORTS' defined : [ 22 ]
PortVar 'FTP_PORTS' defined : [ 21 2100 3535 ]
PortVar 'SIP_PORTS' defined : [ 5060:5061 5600 ]
PortVar 'FILE_DATA_PORTS' defined : [ 80:81 110 143 311 383 591 593 901 1220 14
14 1741 1830 2301 2381 2809 3037 3128 3702 4343 4848 5250 6988 7000:7001 7144:71
45 7510 7777 7779 8000 8008 8014 8028 8080 8085 8088 8090 8118 8123 8180:8181 82
43 8280 8300 8800 8888 8899 9000 9060 9080 9090:9091 9443 9999 11371 34443:34444
41080 50002 55555 ]
PortVar 'GTP_PORTS' defined : [ 2123 2152 3386 ]
Detection:
Search-Method = AC-Full-Q
Split Any/Any group = enabled

```

Hình 95: Khởi động ứng dụng

Khởi động chương trình thành công và nhận được thông báo snort đã đang thực thi hoặc đang tồn tại.

```

Snort successfully validated the configuration!
Snort exiting
thu@thu:~$

```

Hình 96: ứng dụng hoạt động

Nhằm để có thể phát hiện các tấn công admin phải tự đặt ra các rules nhằm quản lý và có thể quan sát các truy cập mà đối với cơ quan, công ty xem đó là truy cập trái phép hoặc truy cập đáng nghi để có thể tiến hành ngăn chặn.

```

thu@thu:~$ sudo nano /etc/snort/rules/local.rules

```

Hình 97: Đặt các rules theo quy định của admin

```

GNU nano 6.2 /etc/snort/rules/local.rules *
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
# -----
# LOCAL RULES
# -----
# This file intentionally does not come with signatures. Put your local
# additions here.
alert icmp any any -> $HOME_NET any (msg:"ICMP test";sid:10000001; rev:001)

```

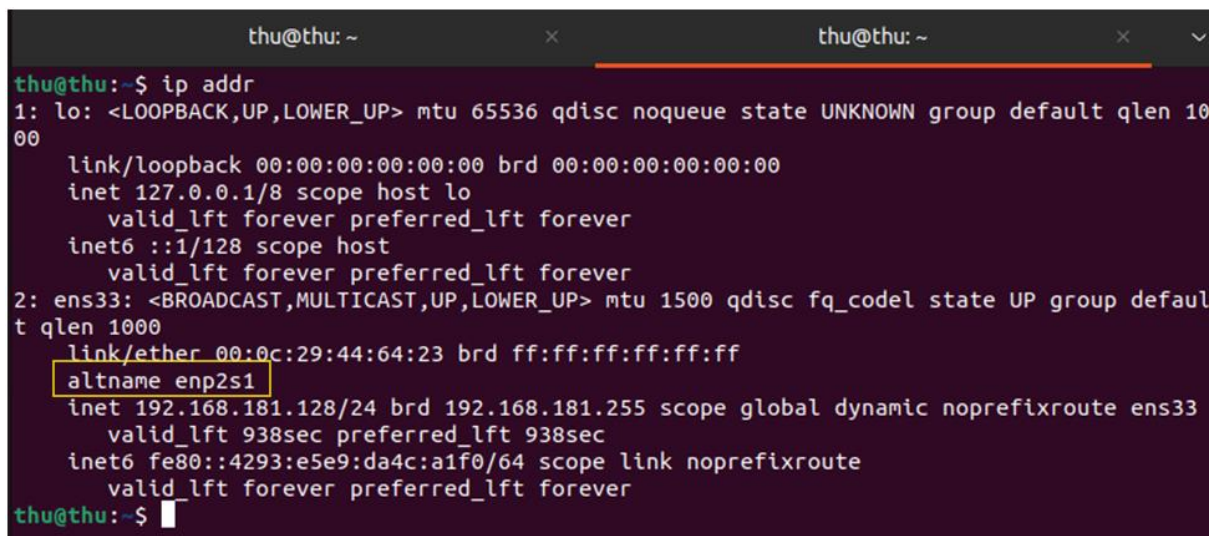
Hình 98: Tạo rules cho ứng dụng

alert icmp any any -> \$HOME_NET any (msg:"ICMP test";sid:10000001; rev:001;)

- **Alert:** Đây là hành động được thực hiện khi quy tắc được kích hoạt. Trong trường hợp này, alert có nghĩa là Snort sẽ tạo ra một cảnh báo khi một gói tin phù hợp với quy tắc này được nhận dạng.
- **ICMP :** Đây là giao thức mà quy tắc này áp dụng cho. Trong trường hợp này, quy tắc này sẽ áp dụng cho giao thức ICMP.
- **Any any -> \$HOME_NET any:** Đây là phần mô tả nguồn và đích của gói tin mà quy tắc này áp dụng cho. Trong đó:
 - ‘Any any :’ đề cập đến bất kỳ địa chỉ IP nguồn và đích nào.
 - \$HOME_NET: là một biến môi trường được định nghĩa trong tập tin cấu hình Snort. Thường thì nó được đặt để tham chiếu đến mạng nội bộ mà Snort đang giám sát.
 - Any: cho biết cổng nguồn và đích của gói tin, nghĩa là không có sự ràng buộc về cổng.
- **msg: ‘ICMP test’ :** Phần này định nghĩa một thông điệp cảnh báo mà Snort sẽ tạo ra nếu quy tắc này kích hoạt. Trong trường hợp này, thông điệp cảnh báo sẽ là "ICMP test".
- **Sid: 10000001:** Đây là số nhận dạng duy nhất của quy tắc. Số này phải là duy nhất trong tập tin cấu hình của Snort và thường được sử dụng để xác định cụ thể quy tắc nào đã kích hoạt.
- **Rev:001;** Đây là số phiên bản của quy tắc. Nó giúp theo dõi các phiên bản cập nhật của quy tắc này.

Tóm lại, quy tắc này sẽ tạo ra một cảnh báo khi Snort nhận dạng một gói tin ICMP từ bất kỳ nguồn nào đến mạng nội bộ, với thông điệp cảnh báo là "ICMP test".

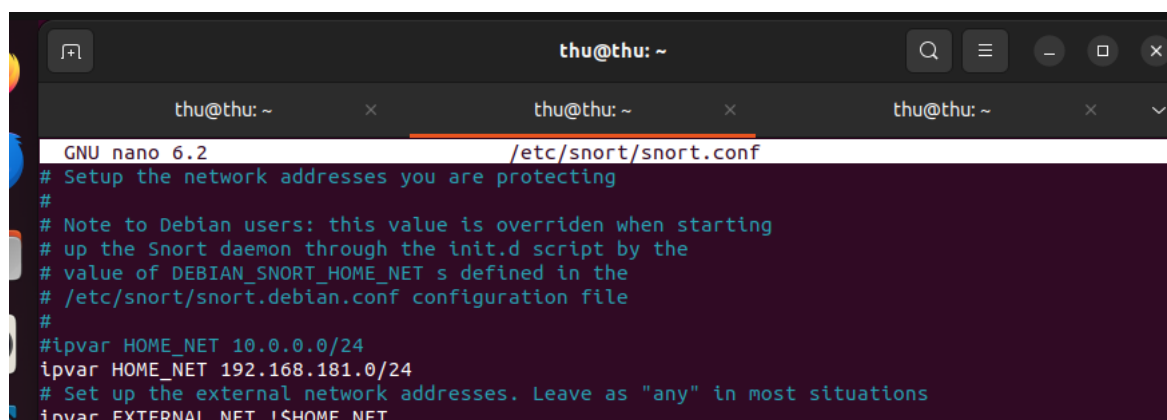
Xem địa chỉ ip của máy và thông tin tên đường truyền mạng



```
thu@thu: ~  
thu@thu:~$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 00:0c:29:44:64:23 brd ff:ff:ff:ff:ff:ff  
    altnam enp2s1  
    inet 192.168.181.128/24 brd 192.168.181.255 scope global dynamic noprefixroute ens33  
        valid_lft 938sec preferred_lft 938sec  
    inet6 fe80::4293:e5e9:da4c:a1f0/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
thu@thu:~$
```

Hình 99: Thông tin cấu hình và card mạng

Thiết lập các thông tin đường truyền mạng theo từng máy



```
thu@thu: ~  
GNU nano 6.2 /etc/snort/snort.conf  
# Setup the network addresses you are protecting  
#  
# Note to Debian users: this value is overridden when starting  
# up the Snort daemon through the init.d script by the  
# value of DEBIAN_SNORT_HOME_NET s defined in the  
# /etc/snort/snort.debian.conf configuration file  
#  
#ipvar HOME_NET 10.0.0.0/24  
ipvar HOME_NET 192.168.181.0/24  
# Set up the external network addresses. Leave as "any" in most situations  
ipvar EXTERNAL_NET !$HOME_NET
```

Hình 100: Thay đổi các thông tin để ứng dụng

Sau khi tiến hành đặt rules cho ứng dụng tiến hành thực thi ứng dụng.

```
thu@thu:~$ sudo snort -A console -i enp2s1 -u snort -g snort -c /etc/snort/snort.conf
```

Hình 101: Khởi động ứng dụng

Dùng máy kali tiến hành ping thông điệp sang máy ubuntu


```
(kali@kali)-[~]
$ ping 192.168.181.128
PING 192.168.181.128 (192.168.181.128) 56(84) bytes of data.
64 bytes from 192.168.181.128: icmp_seq=1 ttl=64 time=0.843 ms
64 bytes from 192.168.181.128: icmp_seq=2 ttl=64 time=0.483 ms
64 bytes from 192.168.181.128: icmp_seq=3 ttl=64 time=3.44 ms
64 bytes from 192.168.181.128: icmp_seq=4 ttl=64 time=0.563 ms
64 bytes from 192.168.181.128: icmp_seq=5 ttl=64 time=0.642 ms
^C
--- 192.168.181.128 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4030ms
rtt min/avg/max/mdev = 0.483/1.193/3.436/1.127 ms
(kali@kali)-[~]
$
```

Hình 102: Ping thông điệp từ máy kali

Trên máy Snort lập tức xuất hiện cảnh báo về lệnh ping và trong thư mục /var/log/snort phải có file log về sự kiện trên.

Do đó, admin có thể kiểm tra các hoạt động của trạng thái để có thể đánh giá và tìm ra các rủi ro từ bên ngoài qua các thông tin được ghi nhận.

```
Preprocessor Object: SF_SDF Version 1.1 <Build 1>
Commencing packet processing (pid=4221)
04/08-08:56:48.732508  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.133
-> 192.168.181.128
04/08-08:56:48.732554  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.128
-> 192.168.181.133
04/08-08:56:49.733637  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.133
-> 192.168.181.128
04/08-08:56:49.733675  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.128
-> 192.168.181.133
04/08-08:56:50.747682  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.133
-> 192.168.181.128
04/08-08:56:50.747904  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.128
-> 192.168.181.133
04/08-08:56:51.749169  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.133
-> 192.168.181.128
04/08-08:56:51.749201  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.128
-> 192.168.181.133
04/08-08:56:52.762113  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.133
-> 192.168.181.128
04/08-08:56:52.762144  [*] [1:10000001:1] ICMP test  [*] [Priority: 0] {ICMP} 192.168.181.128
-> 192.168.181.133
```

Hình 103: Thông điệp máy ubuntu nhận được và ghi nhận

- **ICMP** : Đây là giao thức mà quy tắc này áp dụng cho. Trong trường hợp này, quy tắc này sẽ áp dụng cho giao thức ICMP.
 - Đề cập đến địa chỉ IP 192.168.181.133 (nguồn) và 192.168.181.128 (đích).
- **(msg:'ICMP test')** : Phần này định nghĩa một thông điệp cảnh báo mà Snort sẽ tạo ra nếu quy tắc này kích hoạt. Trong trường hợp này, thông điệp cảnh báo sẽ là "ICMP test".

Tóm lại, quy tắc này sẽ tạo ra một cảnh báo khi Snort nhận dạng một gói tin ICMP từ bất kỳ nguồn nào đến mạng nội bộ, với thông điệp cảnh báo là "ICMP test".

KẾT QUẢ ĐẠT ĐƯỢC

Với những thử nghiệm trên đã thực hiện được một phần và mô phỏng các bước kiểm tra, tấn công và gia cố đơn giản các dạng tấn công thường gặp ở trang website cũng như sử dụng thêm các công cụ theo dõi và ghi nhận các tiến trình thực thi để có thể quản lý và truy xuất trong tương lai.

Tổng kết

- Với thực nghiệm tấn công DDOS
 - Là kiểu tấn công không thể phòng ngừa từ xa do đây là một dạng tấn công có kế hoạch, mục tiêu rõ ràng nhằm hạ uy tín, tính thương mại của đối thủ.
 - Nhưng với dạng tấn công này có thể nhận biết trước từ các công cụ theo dõi liên tục như Snort, fail2ban, ... và có thể hạn chế hoặc ngăn chặn trực tiếp các mối nguy hại như chặn (block), đóng (close) các cổng đang bị tấn công,...
 - Đồng thời gia cố hệ thống hoặc tăng khả năng chịu lỗi của các thiết bị cũng như các chứng chỉ liên quan nhằm tăng khả năng chịu tải cho trang web.
 - Với thực nghiệm tấn công SQL Injection, XSS
 - Là kiểu tấn công lợi dụng các lỗ hổng ở các ô input từ việc truy xuất đầu vào để có thể đánh cắp thông tin cũng như thực hiện các hành vi đánh cắp tài khoản người dùng trái phép từ đó thực hiện các hành vi trái phép mà không bị truy tố.
 - Nhưng với dạng tấn công này có thể gia cố bằng việc kiểm tra các truy xuất đầu vào, lọc các ký tự đặc biệt,..
 - Với thực nghiệm tấn công MITM (tấn công kẻ đứng giữa)
 - Là kiểu tấn công lợi dụng các kết cấu không an toàn cấu trúc web để có thể dùng công cụ wireshark để bắt các gói tin và thay đổi các thông tin truyền đi nhằm thực hiện các mục đích xấu.
 - Việc sử dụng chứng chỉ SSL cũng hạn chế việc rò rỉ các thông tin truyền đi trên đường truyền do các thông tin truyền đi đã được mã hóa và việc sử dụng chứng chỉ cũng tăng tính độ tin cậy và lòng tin người dùng về mức độ an toàn của website.
- Bên cạnh các việc tấn công thì các việc gia cố cũng rất quan trọng
- Gia cố kiểm tra truy xuất đầu vào

- Gia cố bằng cách sử dụng các chứng chỉ SSL
- Kiểm tra thường xuyên các truy xuất CSDL, kiểm tra các lỗ hổng về giao diện

Ngoài việc gia cố thì việc theo dõi thường xuyên, giám sát các tác vụ được thực thi đồng thời ghi nhận các tác vụ đó vào logfile để có thể kiểm tra trong tương lai.

- Sử dụng các công cụ Snort, Fail2ban
 - Việc sử dụng công cụ Snort để theo dõi, giám sát, ghi nhận các thông tin được thao tác sẽ dễ dàng quản lý trong việc kiểm soát trong tương lai.
 - Việc sử dụng công cụ Fail2ban để theo dõi, giám sát, ghi nhận các thông tin được truy xuất từ xa của các nhà quản trị thao tác sẽ dễ dàng quản lý trong việc kiểm soát trong tương lai.

Bên cạnh các công cuộc thử nghiệm phát hiện các lỗi phổ biến thường gặp ở website ngoài ra còn phát hiện thêm các lỗ hổng mới đồng thời hiểu được mức độ ứng dụng và phạm vi các chứng chỉ cấp phép bên cạnh đó hiểu được các cú pháp tìm kiếm các thông tin trang được xử lý.

Nâng cao hơn trong việc tìm hiểu thêm các công cụ tiến hành theo dõi, ghi log, giám sát các thao tác trên tác vụ thường ngày nhằm đảm bảo các tính liên tục, tính nghiêm ngặt và các xử lý trong tương lai.

Thực nghiệm đã cung cấp cái nhìn tổng quát về cơ chế hoạt động của website, từ quá trình quét để tìm ra lỗ hổng ban đầu đến thực nghiệm đa dạng các cuộc tấn công liên quan đến các lỗ hổng đã phát hiện và tìm đó khắc phục nhờ vào việc quản lý các truy xuất đầu vào, kiểm tra các phiên làm việc an toàn để hạn chế việc bị lợi dụng để mất hoặc thất thoát các dữ liệu người dùng.

Việc đánh giá hiệu suất làm việc thường xuyên của một website cũng phản ánh được mức độ uy tín, sẵn dùng của các doanh nghiệp và tạo một mối quan hệ tin tưởng đến cho khách hàng thì việc theo dõi, giám sát, đánh giá thường xuyên năng suất của một website là điều không thể thiếu do đó phải sử dụng thêm các công cụ theo dõi từ xa và liên tục nhằm giúp xác định tốc độ và khả năng mở rộng của nó trong các môi trường mạng khác nhau, từ đó đề xuất các cải tiến để nâng cao hiệu suất hoạt động.

Ngoài ra, thực nghiệm còn đưa ra các cách gia cố bảo mật cụ thể để tăng cường tính an toàn của hệ thống, đặc biệt là trong việc xác thực các ký tự đầu vào và việc so sánh các dữ liệu đầu vào. Những đề xuất cải tiến và phát triển từ nghiên cứu sẽ giúp định hướng cho sự tiến bộ của các công nghệ an ninh mạng trong tương lai. Tổng kết lại, thực nghiệm này không chỉ là một sự phân tích sâu sắc về nhận biết các cuộc tấn

công mạng, mà còn là một đóng góp quan trọng cho việc bảo vệ thông tin và dữ liệu trên mạng máy tính. Hy vọng rằng các kết quả này sẽ có được sự áp dụng và phát triển trong các ứng dụng thực tiễn, đóng góp vào sự an toàn và tin cậy của các hệ thống thông tin hiện đại.

TÀI LIỆU THAM KHẢO

1. <https://www.youtube.com/watch?v=0TVctjoTItM&list=LL&index=15&t=251s>. *Crack by Wireshark*.
2. <https://www.youtube.com/watch?v=ASpN9s7aPu0>,
<https://www.youtube.com/watch?v=7ZOkWoJ-D2U>. *Cấu hình Snort*.
3. <https://www.youtube.com/watch?v=bJI7zLDjEWU&list=LL&index=19>. *Tấn công DOS*.
4. <https://www.youtube.com/watch?v=dkUBYKFIUqE&t=317s>. *Hướng dẫn dùng ZAP*.
5. https://www.youtube.com/watch?v=dMTNsvS_Jb4. *Chứng chỉ SSL free*.
6. <https://www.youtube.com/watch?v=kgdoVeyoO2E>. *Dùng fail2ban*.
7. <https://www.youtube.com/watch?v=NEKnpyackNk>. *Scan website dùng python kiểm tra header*.
8. https://www.youtube.com/watch?v=v_RM25kj_DY. *Sử dụng công cụ Nikto*.
9. <https://www.youtube.com/watch?v=VP9eQhUASYQ&list=LL&index=18&t=63s>. *Scan web with BurpSite*.
10. <https://www.youtube.com/watch?v=W1TZ5owGNzs>,
<https://www.youtube.com/watch?v=ADtJwqa-bOc>. *ConnectData Online*.
11. <https://www.youtube.com/watch?v=ZZtTLHEJnnw&t=155s>. *Bắt gói tin TCP trên wireshark*.